

ASSISTING GDPR COMPLIANCE THROUGH STATIC ANALYSIS OF ANDROID APPS

PhD Defense

3rd September, 2026

Mugdha Khedkar



GDPR Compliance



- GDPR is the toughest privacy and security law in the world¹.
- It was put into effect on May 25, 2018.
- It regulates collection and processing of **personal data** of individuals located in the European Union.
- GDPR compliance asks the following questions (not a comprehensive list):
 - What personal data are you collecting, and why?
 - How is the data stored, and for how long is it retained?
 - Who has access to the data?
 - Is the data shared with third parties or transferred outside the EU?
 - What security measures protect the data?

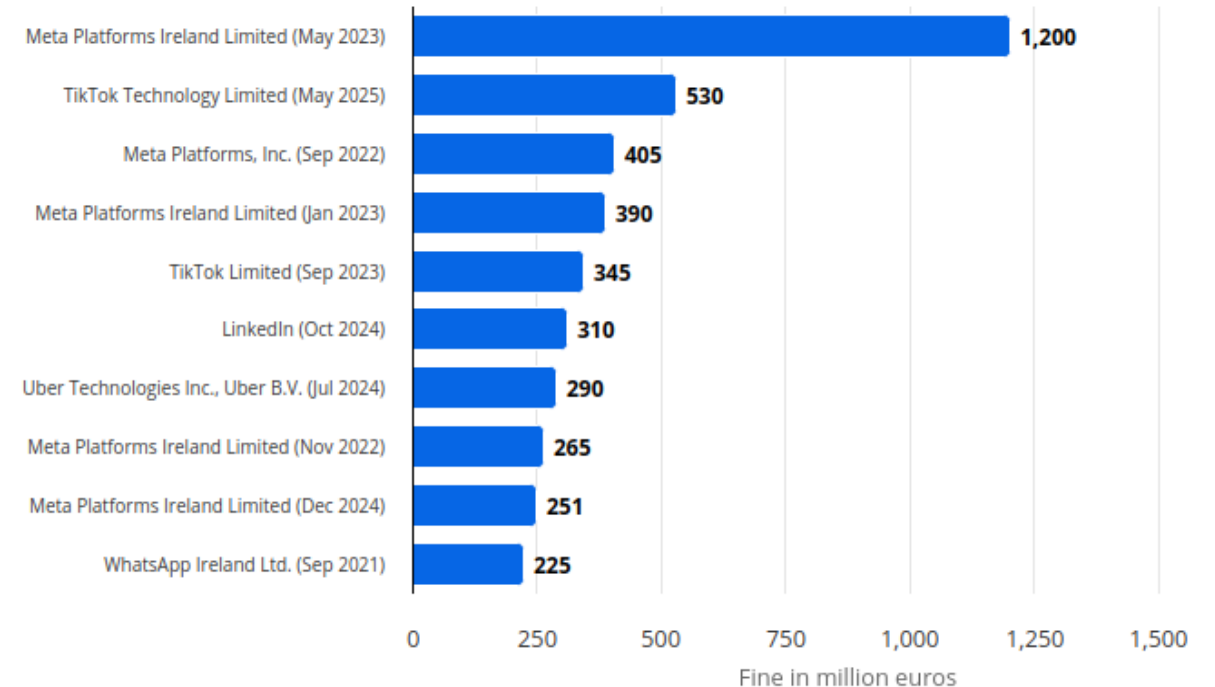
1. <https://gdpr.eu/what-is-gdpr/>

Why GDPR Compliance Matters

GDPR violations are enforceable with fines up to **4% of global worldwide annual turnover**¹.

Millions of Android apps are affected. **Google blocked 2.36M policy-violating apps in 2024** and banned 158,000 developer accounts².

Largest fines issued for GDPR violations (as of May 2026)



Source: [statista.com/statistics/1133337/largest-fines-issued-gdpr](https://www.statista.com/statistics/1133337/largest-fines-issued-gdpr)

1. <https://gdpr-info.eu/art-83-gdpr/>

2. <https://www.forbes.com/sites/alexvakulov/2025/02/02/google-plays-security-236m-apps-blocked-for-violations-in-2024/>

Addressing Difficulties in GDPR Compliance

Two gaps exist in real-world privacy assessments:



Compliance is self-declared.

Developers self-declare data collection (e.g., in Google Play's **Data Safety Section**) without validating it against the source code.



Existing tools are technical.

Tools target **security specialists**, presenting results at a level of abstraction that's inaccessible to Data Protection Officers and legal experts.



THIS THESIS ASKS:

How can *static analysis of an app's source code* make GDPR compliance **reliable, explainable, and accessible** for both app developers and privacy professionals?



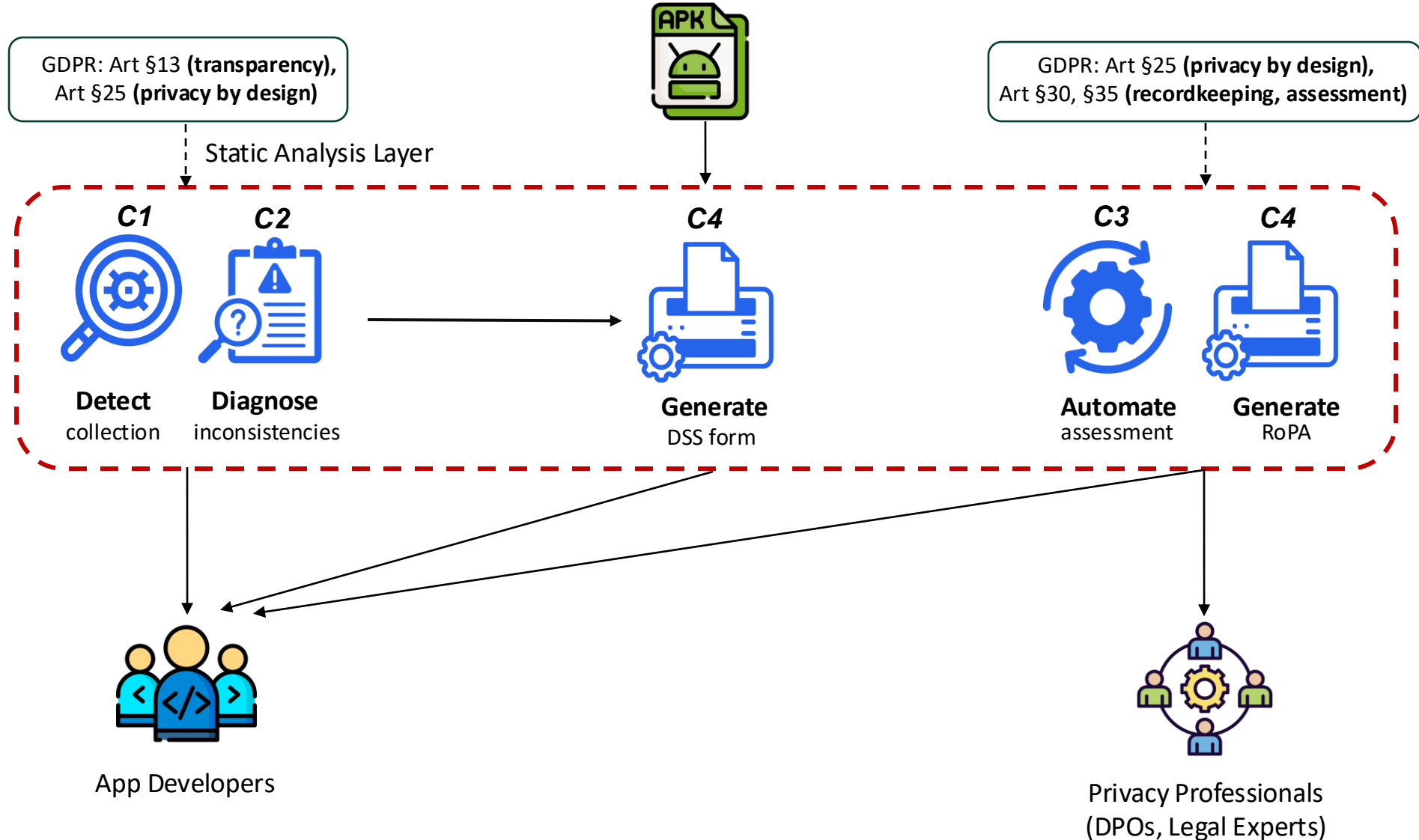
Why Static Analysis?

- Static analysis covers all possible execution instances **without executing the app**.
- It is commonly used to find security vulnerabilities in the source code^{1,2}.
- It can be useful for giving **legal guarantees**.

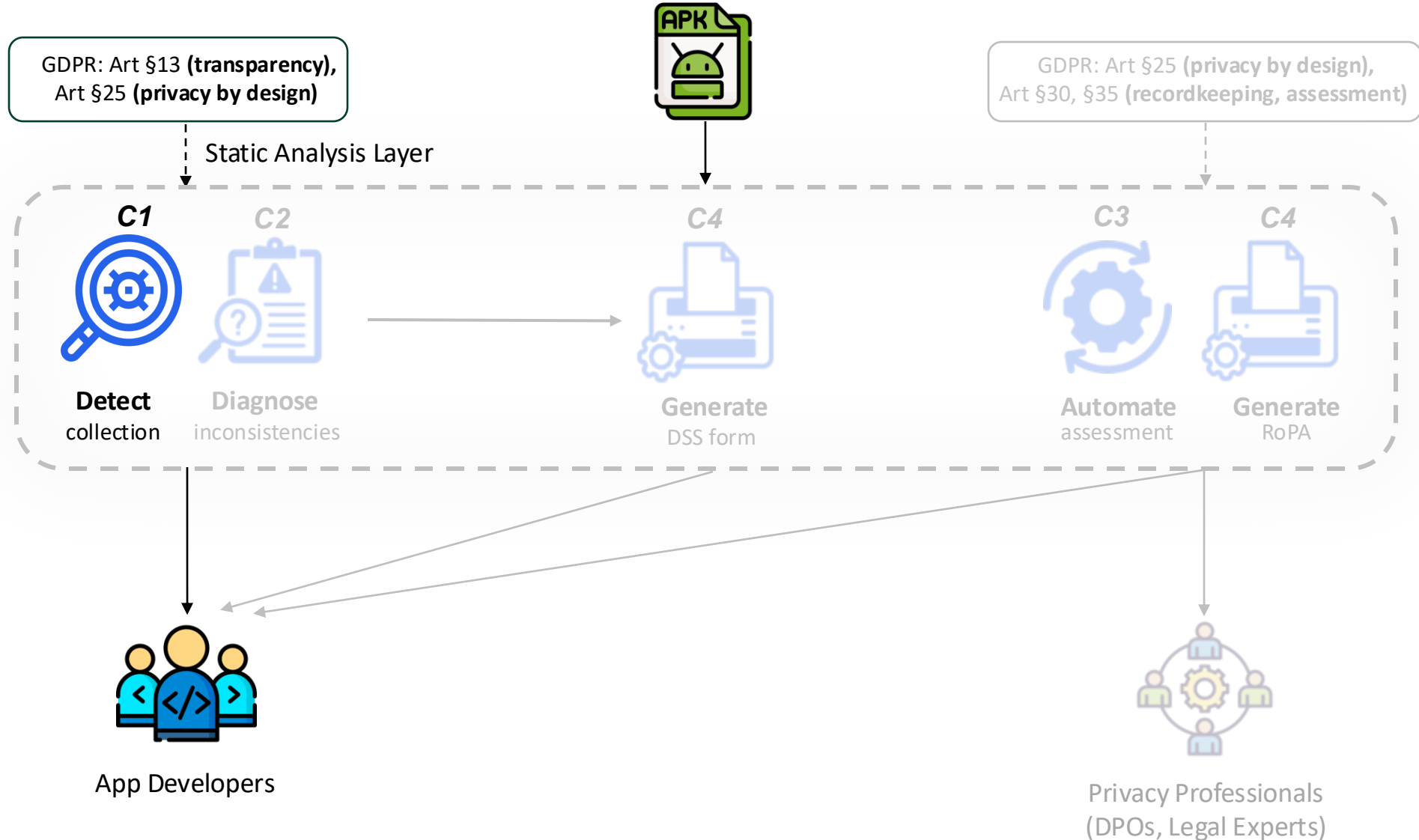


1. Steven Arzt, Siegfried Rasthofer, Christian Fritz, Eric Bodden, Alexandre Bartel, Jacques Klein, Yves Le Traon, Damien Outeau, and Patrick McDaniel. 2014. FlowDroid: precise context, flow, field, object-sensitive and lifecycle-aware taint analysis for Android apps. In Proceedings of the 35th ACM SIGPLAN Conference on Programming Language Design and Implementation (PLDI '14). Association for Computing Machinery, New York, NY, USA, 259–269. <https://doi.org/10.1145/2594291.2594299>.
2. G. Piskachev, R. Krishnamurthy and E. Bodden, "SecuCheck: Engineering configurable taint analysis for software developers," *2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Luxembourg, 2021, pp. 24-29, doi: 10.1109/SCAM52516.2021.00012.

Thesis Contributions

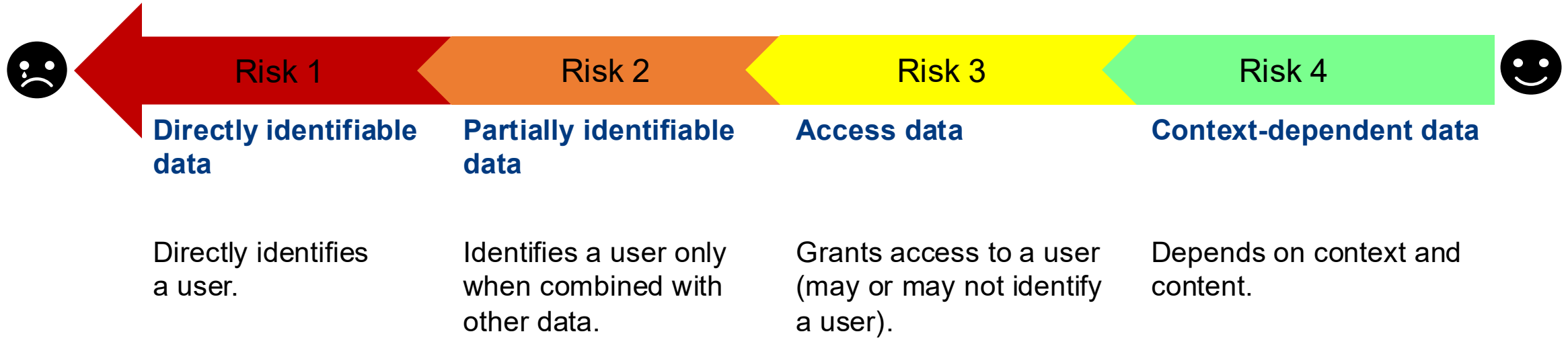


Contribution 1



Data Collection

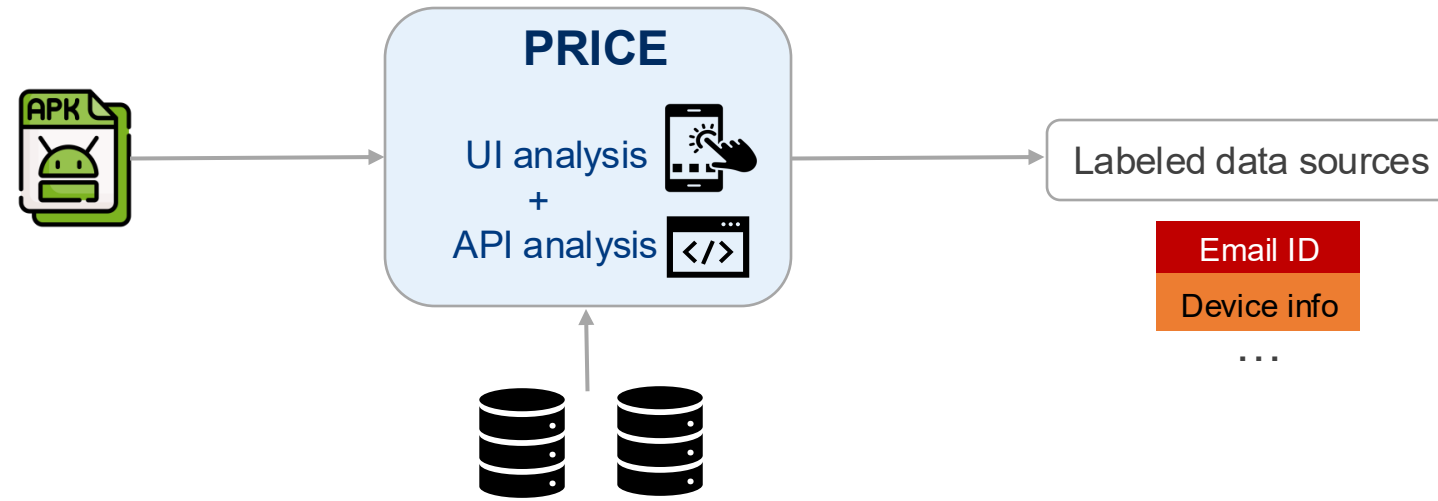
Defining privacy-related data for Android




PERSONAL
DATA

Labelling Collected Data

Privacy-Relevant Input Classification Engine (PRICE)



Uses customized datasets to label static sources of personal data in the user interface (UI) and system APIs of an Android app.

Two Experiments on PRICE

Experiment 1: *Data collection by random apps*

7,500 apps

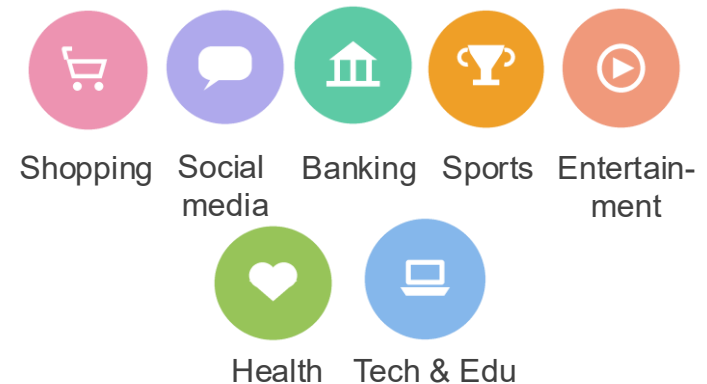
- Sourced from AndroZoo¹
- Released after Oct 2018, post-GDPR
- APK size $\leq$ 300 MB

1. <https://androzoo.uni.lu/>
2. <https://www.appbrain.com/stats/google-play-rankings>
3. <https://androidrank.org/android-most-popular-google-play-apps?price=free>

Experiment 2: *UI-based data collection by domain apps*

700 apps

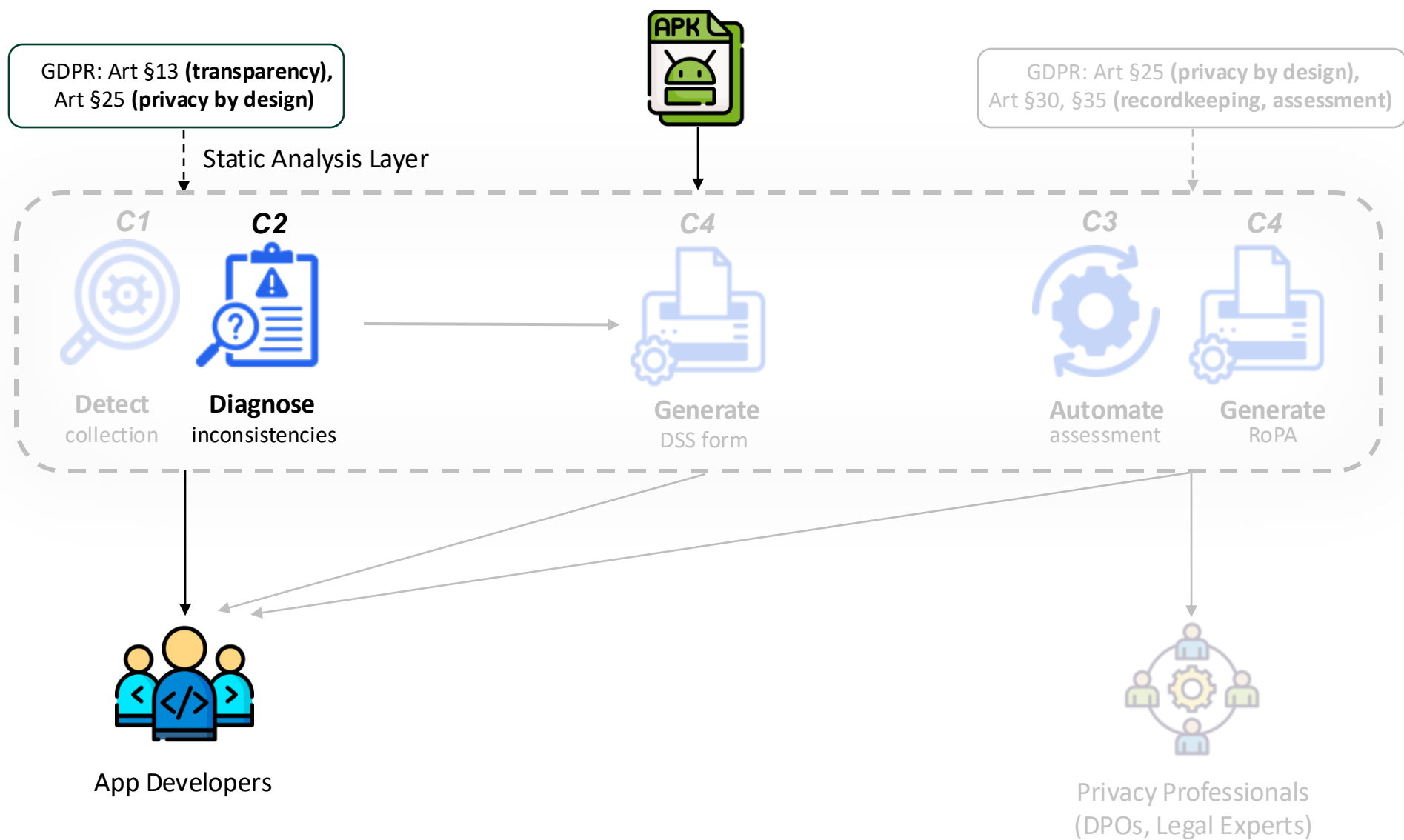
- 7 domains $\times$ 100 apps each
- Sourced via AppBrain² / AndroidRank³ / Google Play Store rankings



Findings (ASE Journal, 2026)

- UI screens collect **personal and financial information**, while system APIs collect **device, location, and browsing data**.
- **Partially identifiable personal data** is the most frequently collected data type.
- **Social media and shopping apps** collect the most personal data.
- **Sports and games apps** collect the least personal data.

Contribution 2



Reported vs. Actual Data Collection (ASE Workshop, 2024)

Data Safety Section (DSS): Google Play Store's self-declared privacy label, filled in by app developers before publishing an app.

RQ: *How does the reported data collection compare to the data collected by the source code?*

20 apps analyzed with **PRICE** and classified per DSS category as collected, reported, or both



Under-reports data collection

Collects more data (contacts, location, photos, financial info, and calendar data) than its DSS reports (personal info only).



Instagram

Over-reports data collection

DSS reports more data (all categories) than it collects.

Finding: App developers may struggle to report data collection accurately.

Empirical Study

RQ1: *What **methods** & **resources** do developers use to categorize data into DSS categories?*

RQ2: *How **confident** are developers in accurately and effectively completing DSS forms?*

RQ3: *What **challenges** do developers face when filling out DSS forms?*

Phase 1: Developer Survey

41 developers

- Recruited via broad calls on X, LinkedIn, Reddit, and direct contact (196 reached)
- Thematic coding & analysis addresses **RQ1**, **RQ2**, and **RQ3**

Phase 2: Analysis of Online Discussions

172 discussions

- Extracted from Stack Overflow, GitHub, Reddit & Discord via search engines and APIs (2,351 extracted)
- Filtered to 172 relevant discussions, covering 642 developers
- Thematic coding & analysis addresses **RQ3**

Findings (MOBILESoft, 2026)

RQ1:

- Developers either *manually categorize* the collected data or *omit categorization altogether*.
- Developers use *existing online resources* to complete the DSS form.

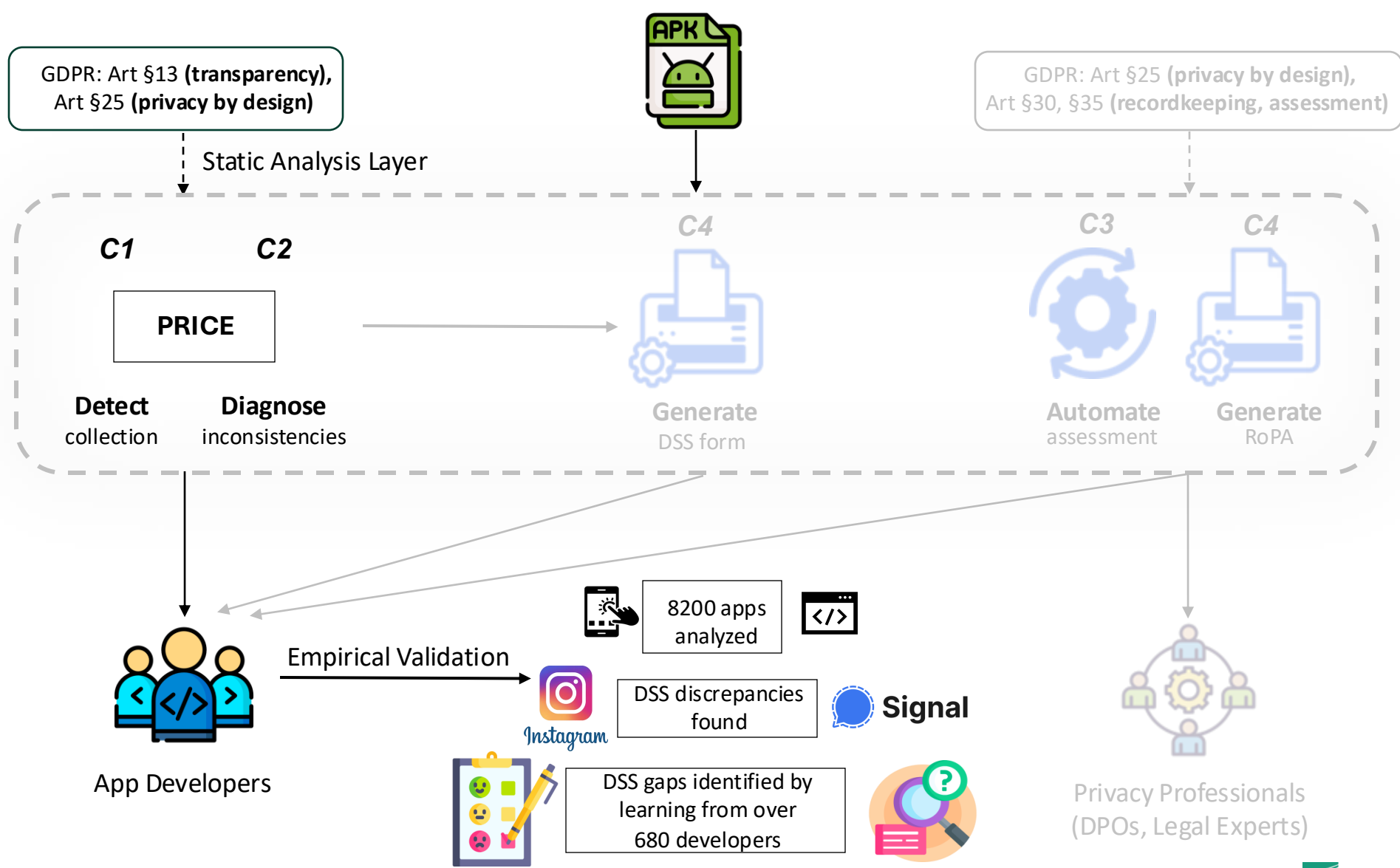
RQ2:

Developers are generally confident in identifying the data their apps collect, yet their *confidence drops when completing the DSS form*.

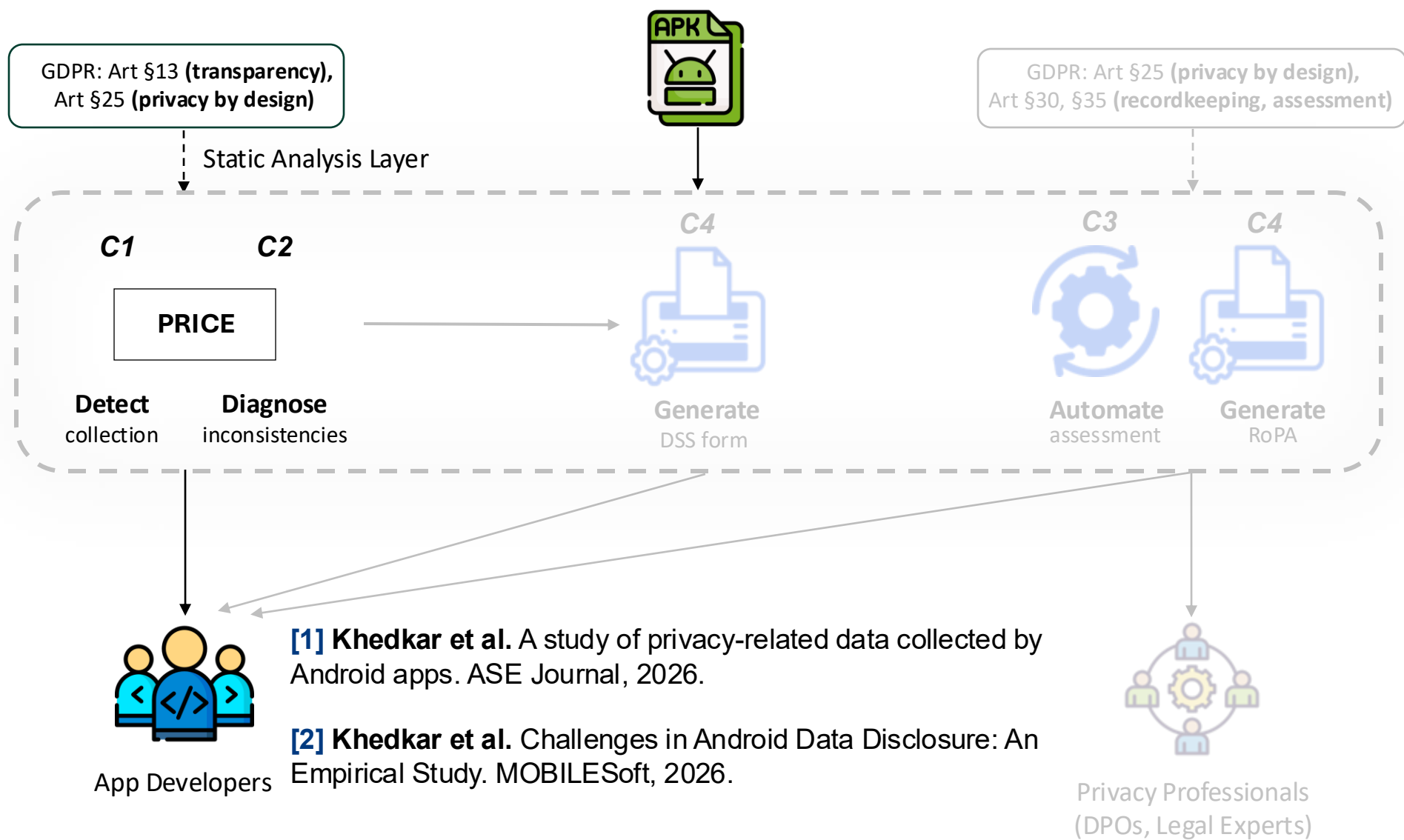
RQ3:

Developers face issues in *identifying privacy-relevant data to complete the form* and have *limited understanding* of the form.

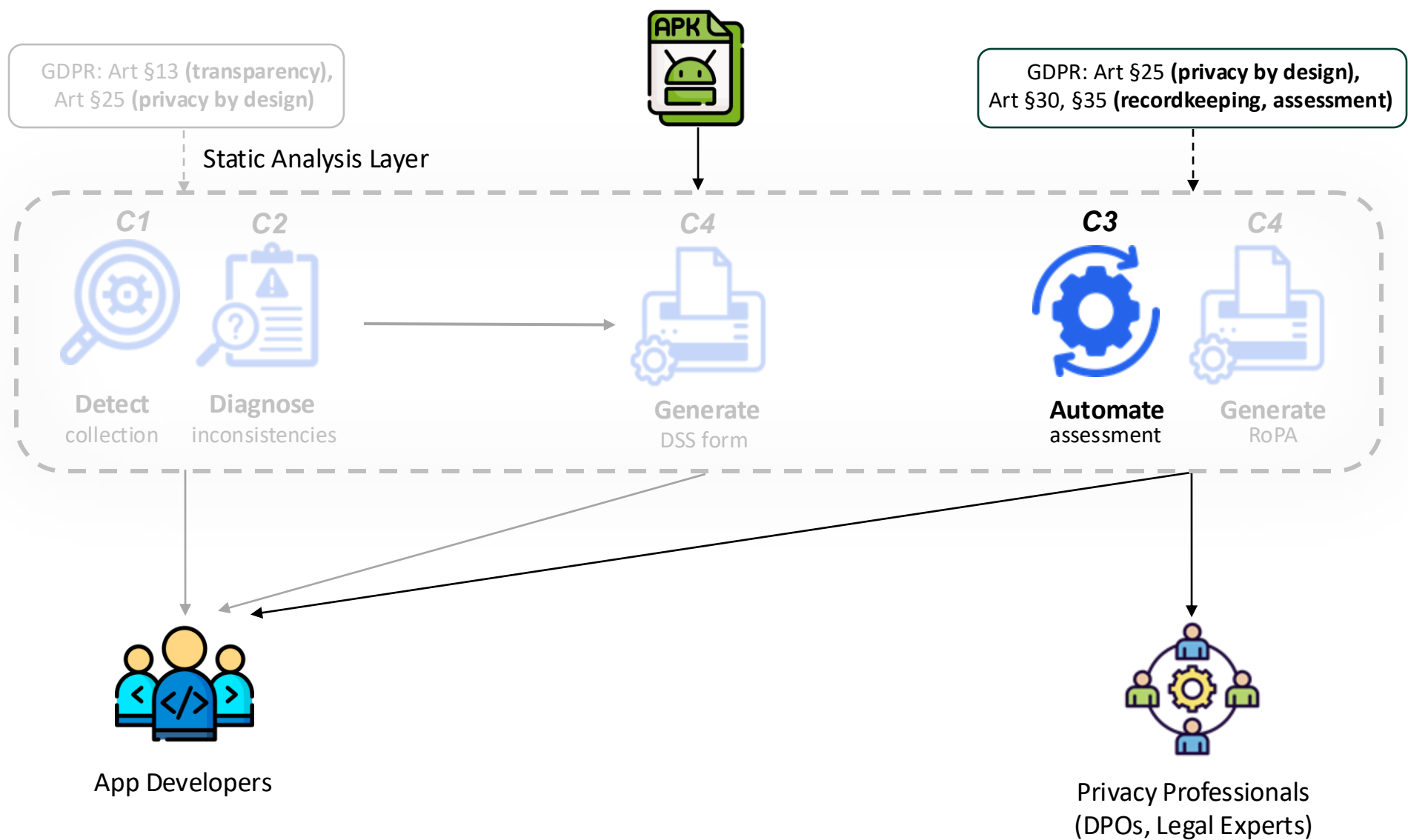
Contribution 1 and 2: Summary



Contribution 1 and 2: Summary [1, 2]



Contribution 3

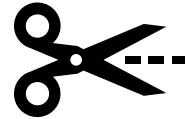


Program Slicing

An Example

Which statements are affected by the value of *x* at statement 1? ?

```
1. int x = 1;
2. int y = 0;
3. for (int i = 1; i <= 5; i++) {
4.     x = x * i;
5.     y = y + 4;
6. }
7. if (y > 4) {
8.     System.out.println(y);
9. }
10. System.out.println("Product is" + x);
```

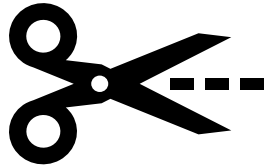


Slicing criterion: *x*

```
1. int x = 1;
2. int y = 0;
3. for (int i = 1; i <= 5; i++) {
4.     x = x * i;
5.     y = y + 4;
6. }
7. if (y > 4) {
8.     System.out.println(y);
9. }
10. System.out.println("Product is" + x);
```

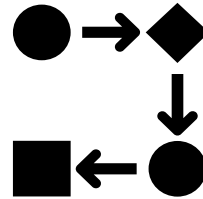
Slicing *isolates* certain parts of the source code relevant to the slicing criterion.

Our Goal



Slice

forward using personal data as a slicing criterion.



Visualize

slices for multiple stakeholders (developers, DPOs, legal experts).

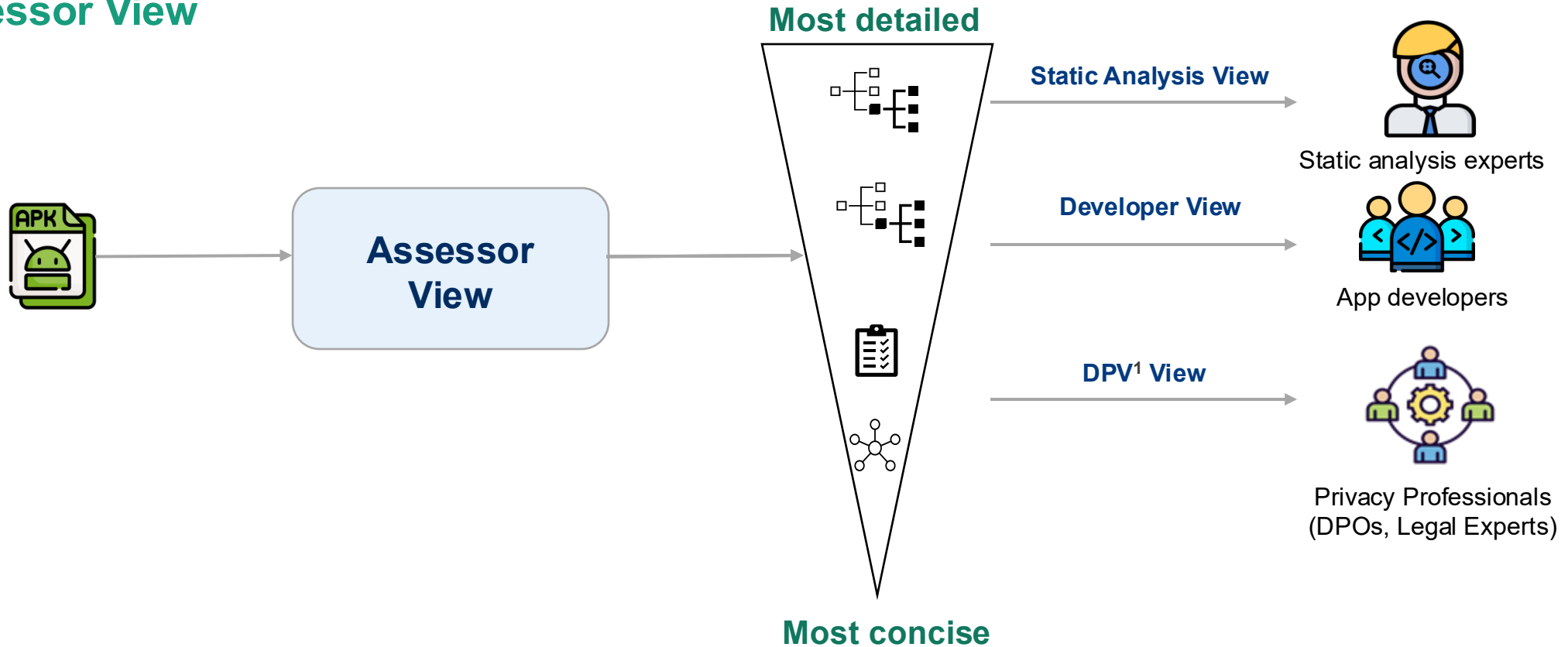


Explore

GDPR warnings, legal recommendations, and suggestions.

Our Approach

Assessor View

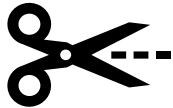


Builds on Jicer static slicing algorithm² to (forward) slice using personal data as a slicing criterion, and visualizes results for different stakeholders.

1. <https://w3c-cg.github.io/dpv/2.1/dpv/>

2. F. Pauck and H. Wehrheim, "Jicer: Simplifying Cooperative Android App Analysis Tasks," 2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM), Luxembourg, 2021, pp. 187-197, doi: 10.1109/SCAM52516.2021.00031

Technical Challenges



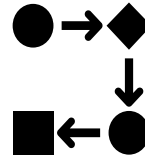
Slice

forward using personal data as a slicing criterion.



Challenge: Scalability

Reusing Jicer's static slicing algorithm to scale across large, real-world Android codebases.



Visualize

slices for multiple stakeholders (developers, DPOs, legal experts)



Challenge: Multiplicity of Abstraction

Representing the same underlying slice differently for each stakeholder, without losing meaning.



Explore

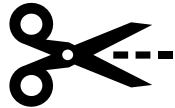
GDPR warnings, legal recommendations, and suggestions



Challenge: Legal Interpretation

Translating GDPR's ambiguous legal language into concrete, checkable rules.

Technical Challenges: How We Addressed Them

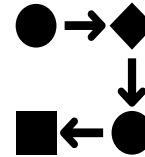


Customizable
slicing



Challenge: Scalability

Let users tune slice to exclude control dependencies and add timeouts to trade completeness for tractability on large, real-world codebases.



Map
slices onto a shared vocabulary



Challenge: Multiplicity of Abstraction

Create a mapping between DPV concepts and Developer View and Static Analysis View, so abstraction changes the representation, not the meaning.



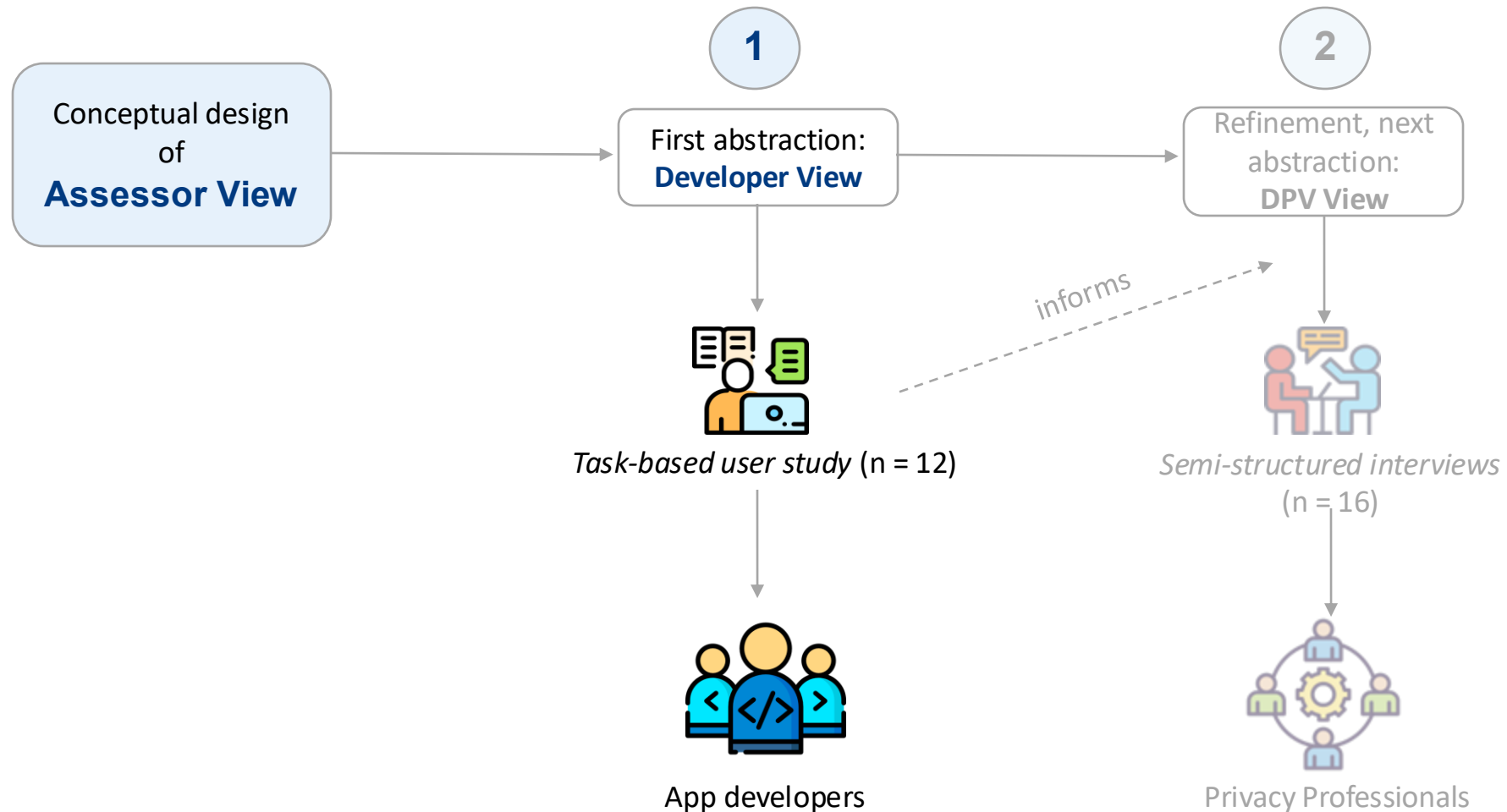
Formalize
GDPR concepts as DPV terms



Challenge: Legal Interpretation

Encode GDPR concepts as DPV vocabulary terms, turning ambiguous legal language into concrete, checkable rules.

User-Centered Design of Assessor View



Developer View: Task-Based User Study

RQ: *To what extent does the **Developer View** help developers understand data protection in Android apps?*

Methodology

12 developers

- Within-subjects study, 3 tasks after app analysis
- Task 1: identify collected data & privacy properties (DroidBench¹)
- Task 2: compare **Static Analysis View** vs. **Developer View** (usability, simplicity, relevance)
- Task 3: repeat Task 1 on a more complex app (TaintBench²)

1. <https://github.com/secure-software-engineering/DroidBench>

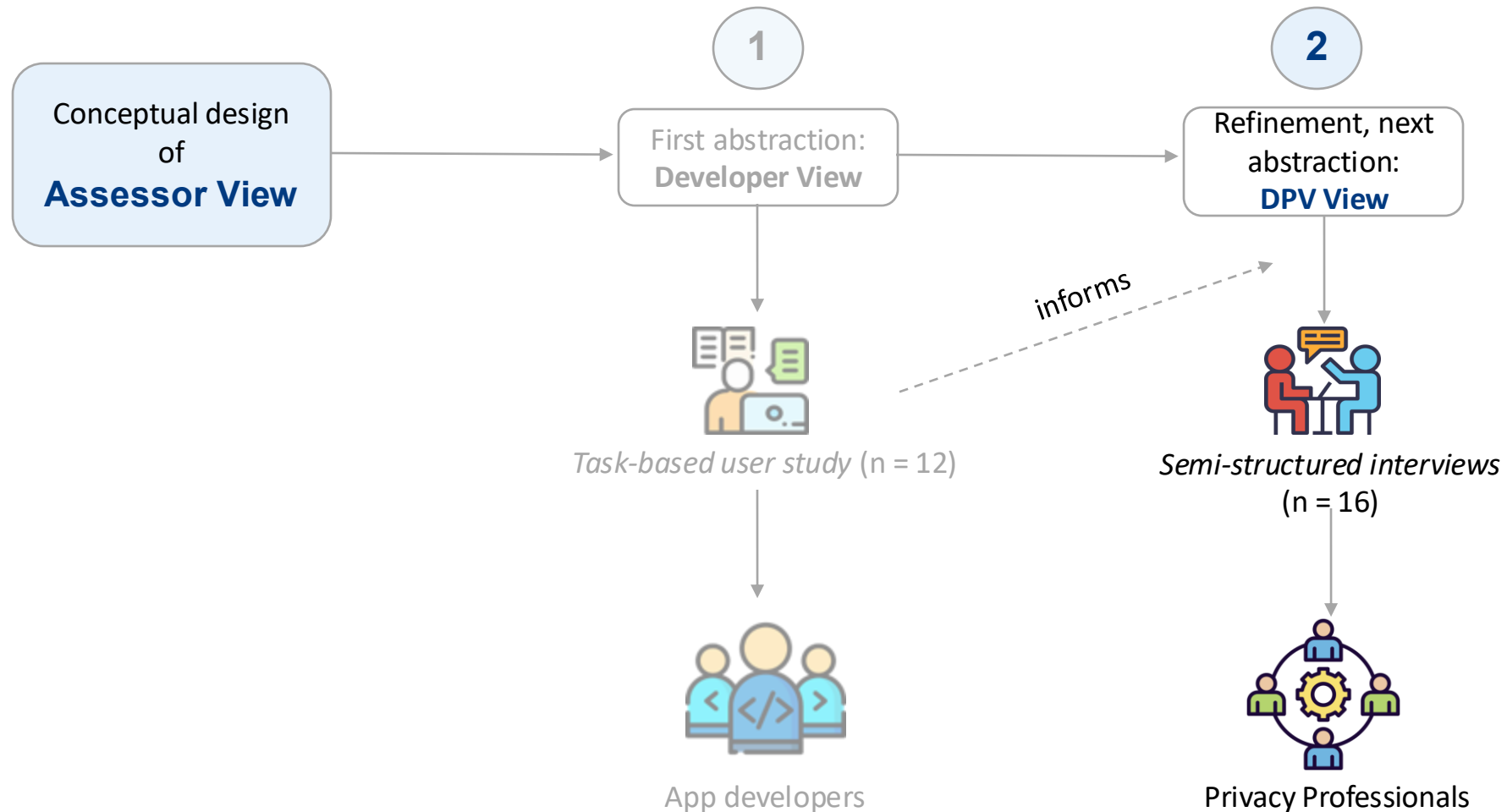
2. <https://taintbench.github.io/taintbenchSuite/>



Findings (ArXiv, 2025)

- **Developer View** is *concise and aligns with the source code*.
- It assists in identifying and observing *privacy-relevant properties* in Android apps.
- Usability is *limited to developers*.

User-Centered Design of Assessor View





DPV View: Semi-Structured Interview Study

RQ1: *How are privacy assessments conducted in a **real-world setting**?*

RQ2: *To what extent does Assessor View **support privacy assessors** in conducting privacy assessments?*

Methodology

16 assessors

- **Pre-questionnaire:** participant experience & familiarity with privacy assessments
- **Current state of the art:** processes and approaches in privacy assessments
- **Tool-based questionnaire:** GDPR compliance of an Android app (TaintBench¹)
- **Tool usability:** user experience & effectiveness for privacy assessments

1. <https://taintbench.github.io/taintbenchSuite/>

Participant Demographics

Expertise

44% DPOs, 31% privacy experts, 25% legal experts

Education

37% PhD, 31% Master, 19% Bachelor, 13% other

Experience

6% >15 yrs, 38% 10–15 yrs, 31% 6–10 yrs, 25% 1–5 yrs

Location

75% EU, 25% non-EU



RQ1: Privacy Assessments

Components of Privacy Assessments

Stakeholders

- DPO
- IT team
- Privacy team
- Project sponsors
- Business partners

Process

- Risk assessment & mitigation
- Information gathering
- Stocktaking and recording
- Regular monitoring/updates
- Interdisciplinary dialogue

Roles

- Advising stakeholders
- Overview of activities
- Document generation
- Research

Documentation

- Record of Processing Activities (RoPA)
- Privacy notice
- Agreements
- Contract
- Assessment Report

RQ1: Privacy Assessments

Selected Challenges¹



1 Knowledge gap

*“Legal team drafting DPIA would have to discuss stuff with a developer. A developer is not going to give them legal answers. There has to be some **common ground**, which doesn’t exist.”*

— P03
(Assistant Professor, Computer Science)

2 Communication gap

*“There is **no communication** between developers and lawyers, they are in two completely different worlds. This is the **biggest void in the market**.”*

— P01
(Data Protection Legal Counsel)

3 Lack of tool support

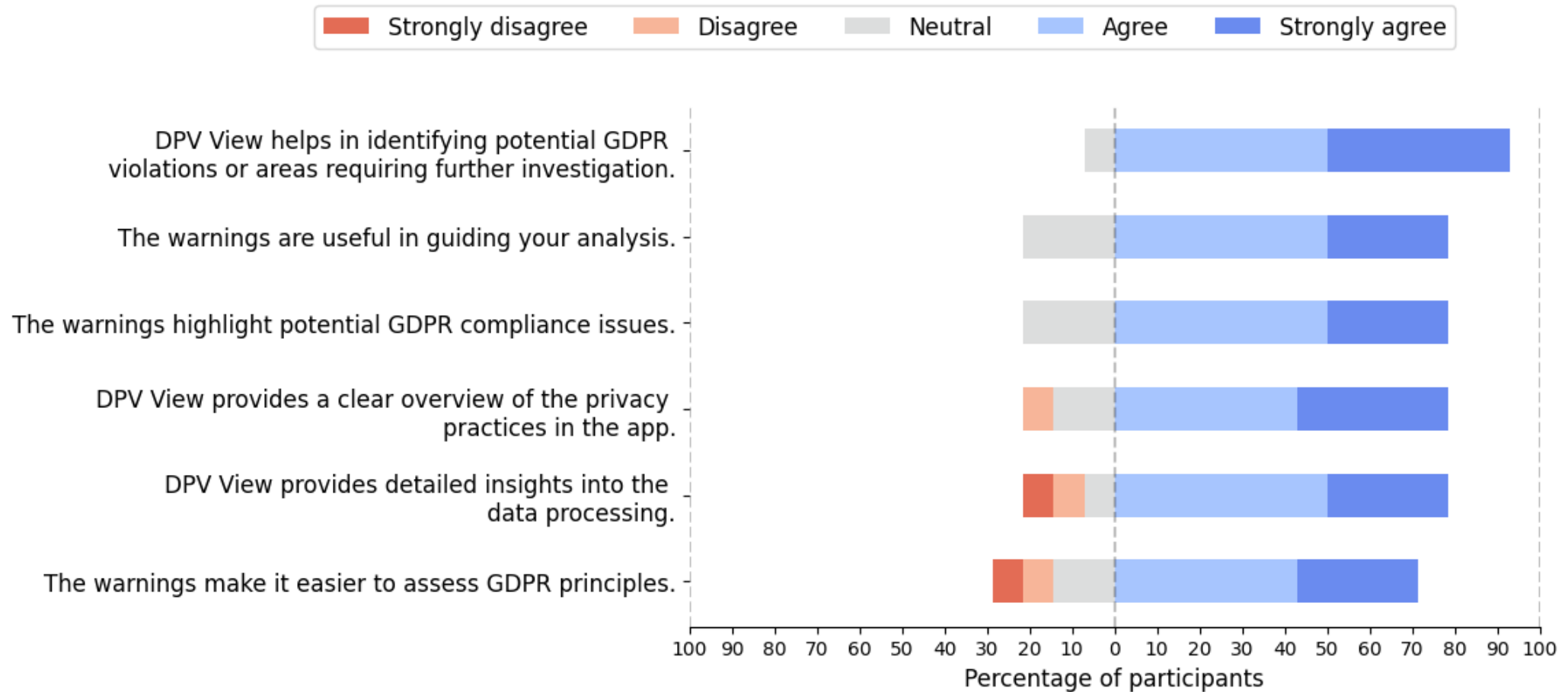
*“I have never seen **automated code scanning** from privacy point of view (so far). Most tools are more focused on **security**, not on GDPR compliance part apart from Article 32 (security of processing).”*

— P04
(Data Protection Privacy Counsel)

1. Three of several challenges identified.

RQ2: User Study

Participants' feedback about DPV View

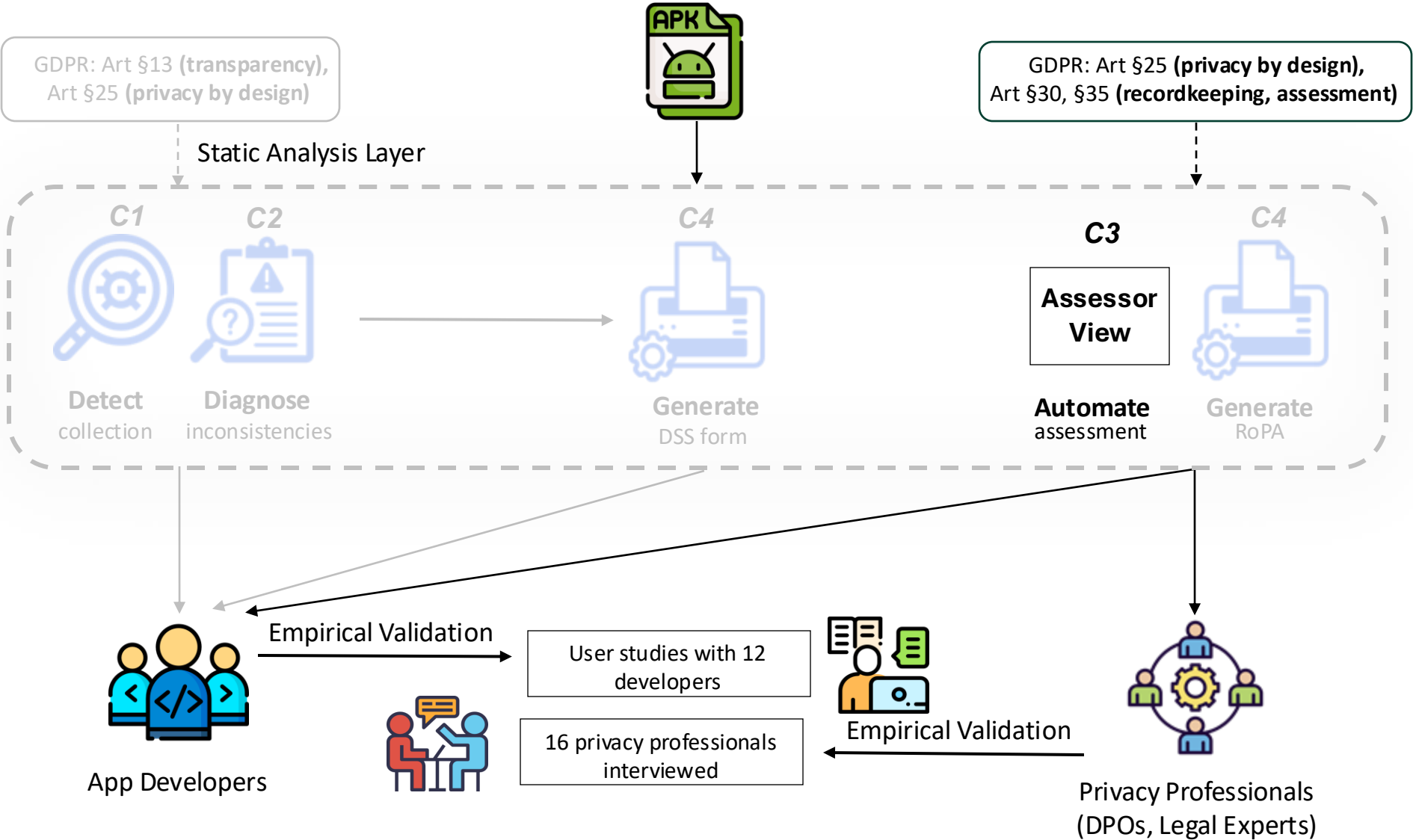




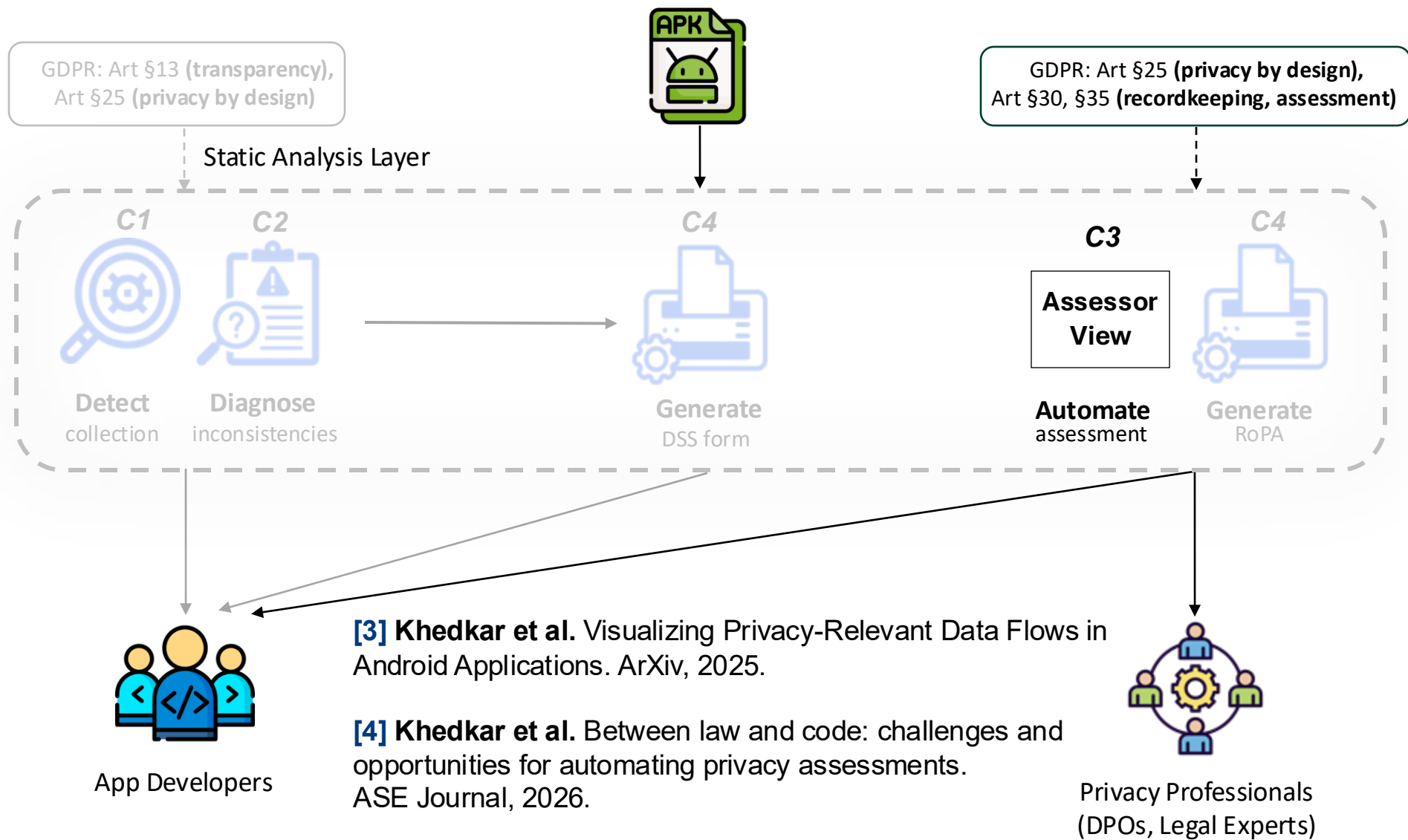
Findings (ASE Journal, 2026)

- Privacy assessments for GDPR compliance (DPIAs) are conducted **manually**.
- **Record of Processing Activities (RoPA)** is the most important document for GDPR compliance, often used as starting point for DPIAs.
- Only **partial automation of documentation** is possible, since experts prefer to manually complete part of documentation (eg., business purpose of processing data).

Contribution 3: Summary

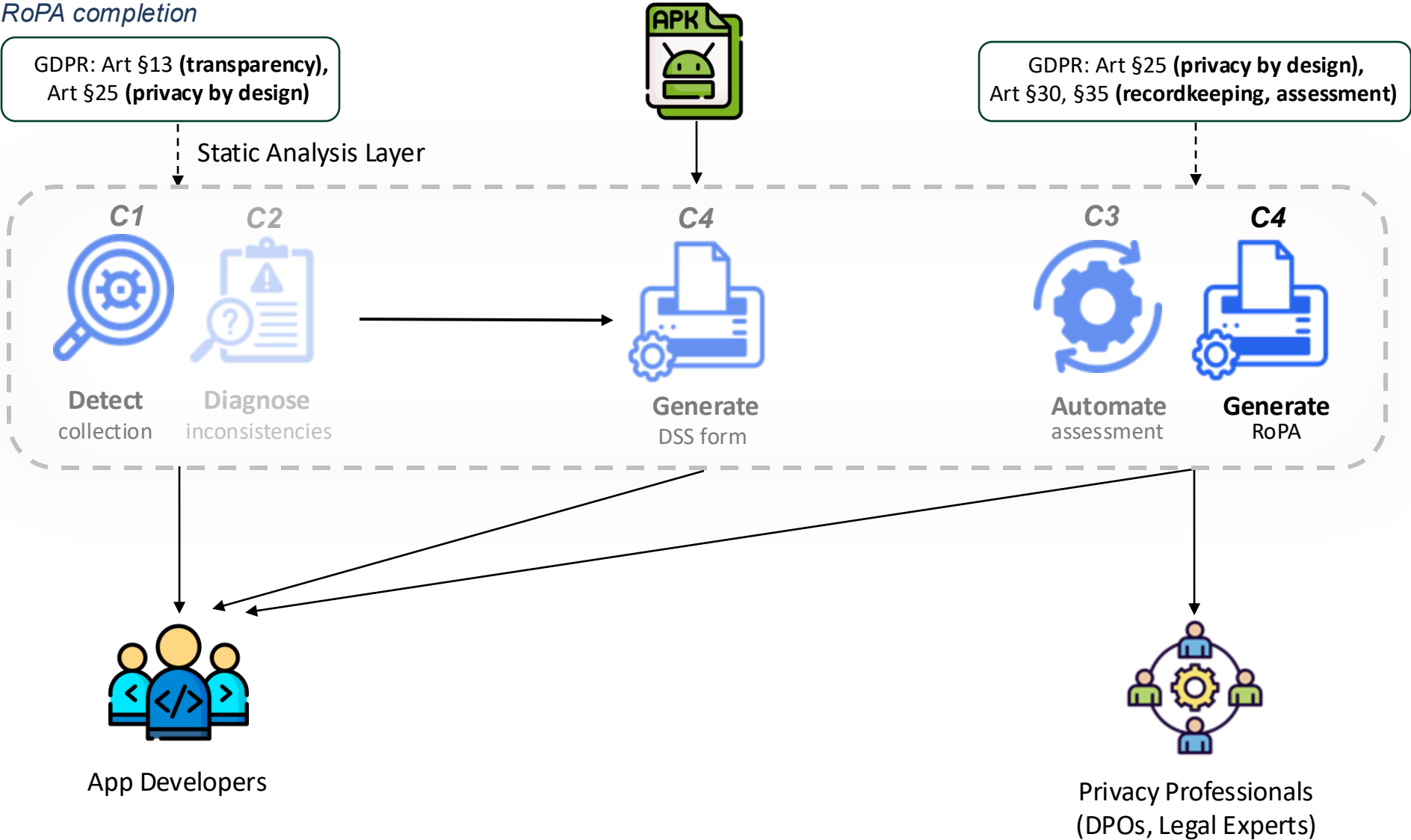


Contribution 3: Summary [3, 4]

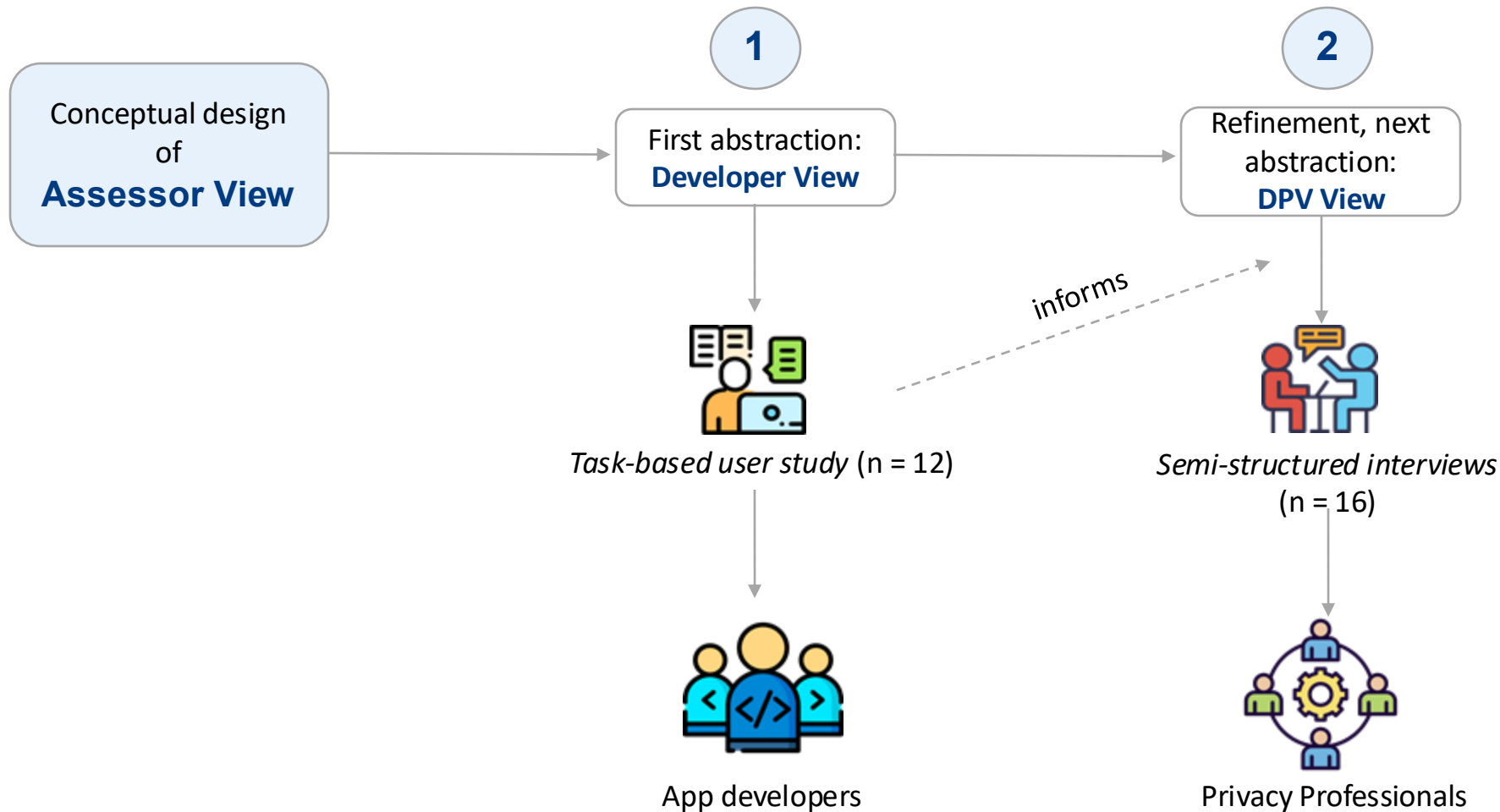


Contribution 4

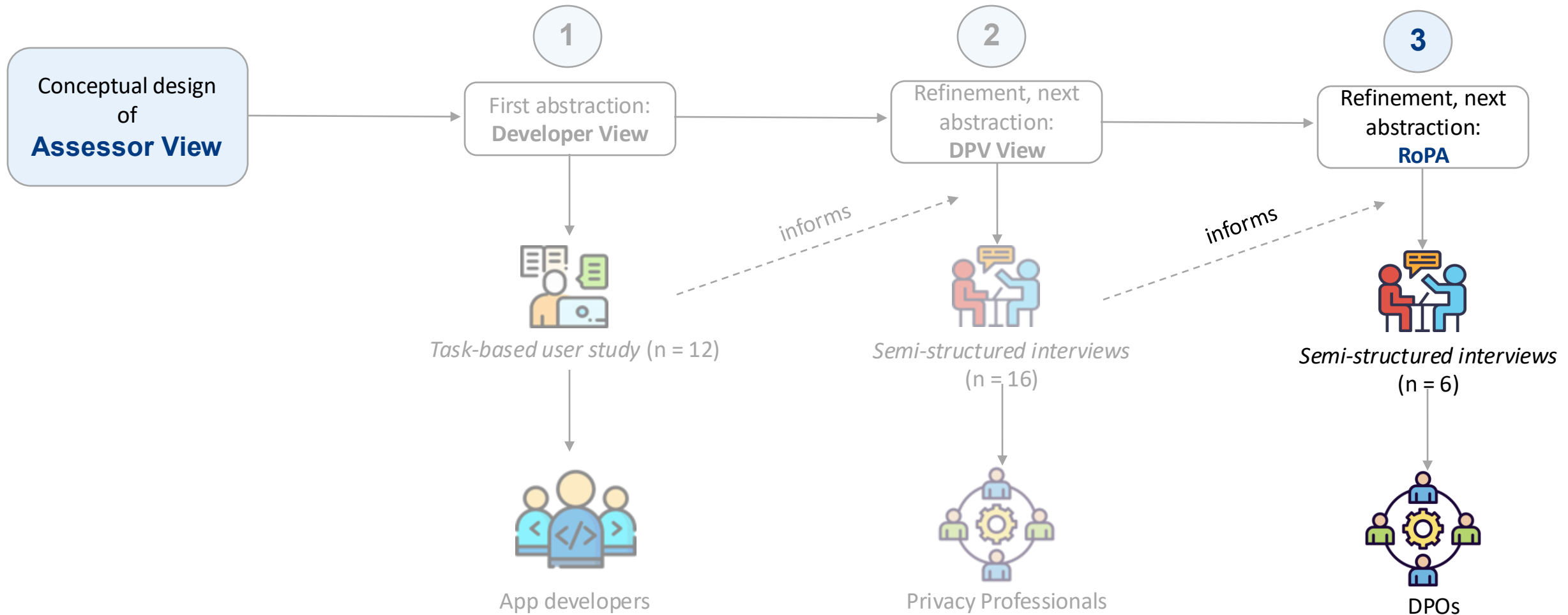
Focus of this talk: RoPA completion



User-Centered Design of Assessor View



User-Centered Design of Assessor View



RoPA: Semi-Structured Interviews

RQ: To what extent does Assessor View support DPOs in completing the Record of Processing Activities (RoPA)?

Methodology

6 Data Protection Officers

- Interview-based study
- **Current state of the art:** processes in RoPA completion
- **Assessor View-generated RoPA:** correctness and effectiveness of the generated RoPA
- **Tool usability:** user experience & effectiveness for RoPA completion

RoPA Creation (SANER Tool Demo, 2026)

Challenges

- Lack of data granularity
- Time consuming process
- Collecting necessary information
- No source code analysis support
- Yearly review

Existing Support

- Standard templates
- Stakeholder interviews
- Other documentation reviews
- Tool-guided questionnaires

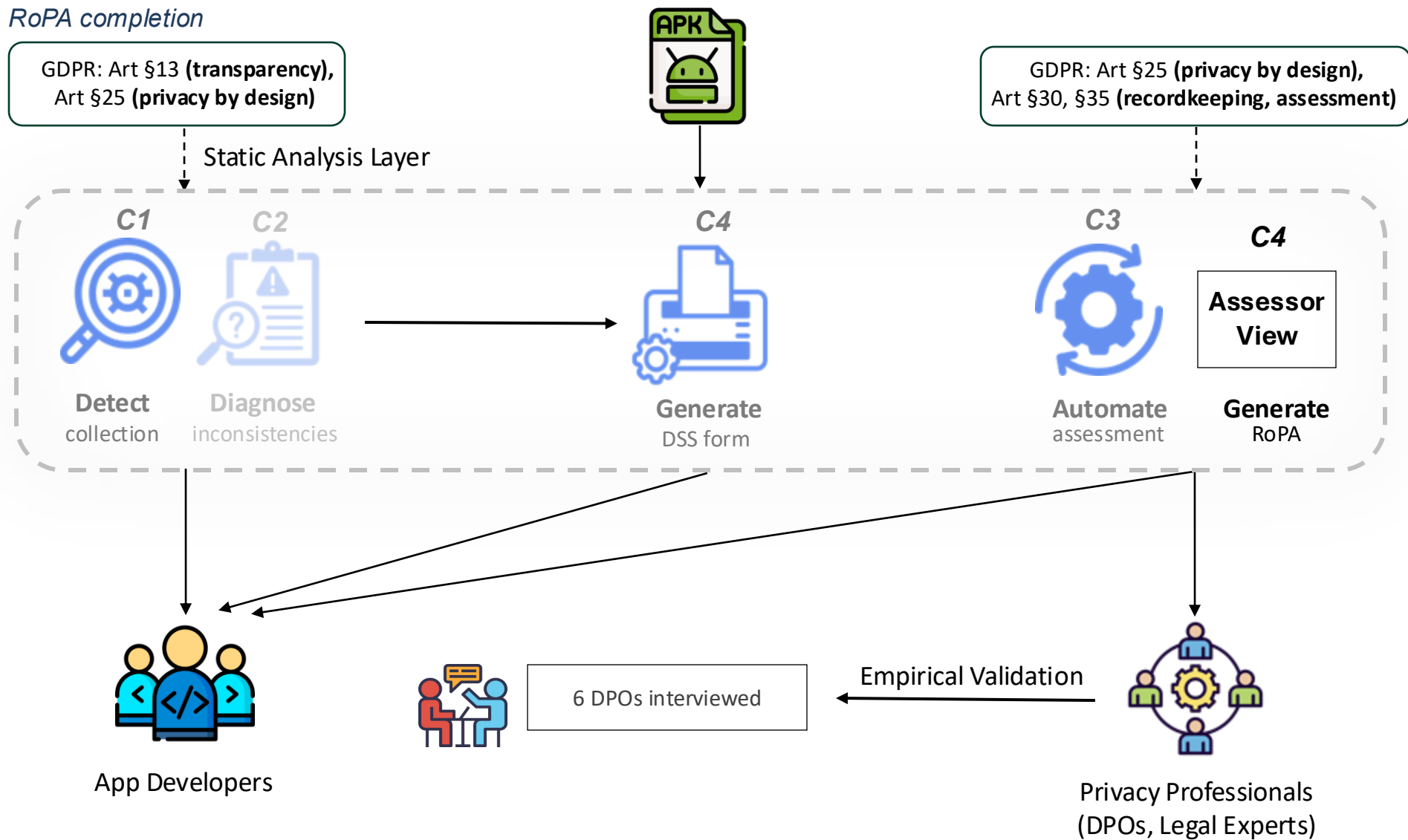
Our Solution

- Beginner friendly
- Reliable
- Enhanced inter-disciplinary communication
- Reduced manual workload
- Enhanced understanding of data processing

Finding: Assessor View-generated RoPA shows promise in improving inter-disciplinary communication among stakeholders.

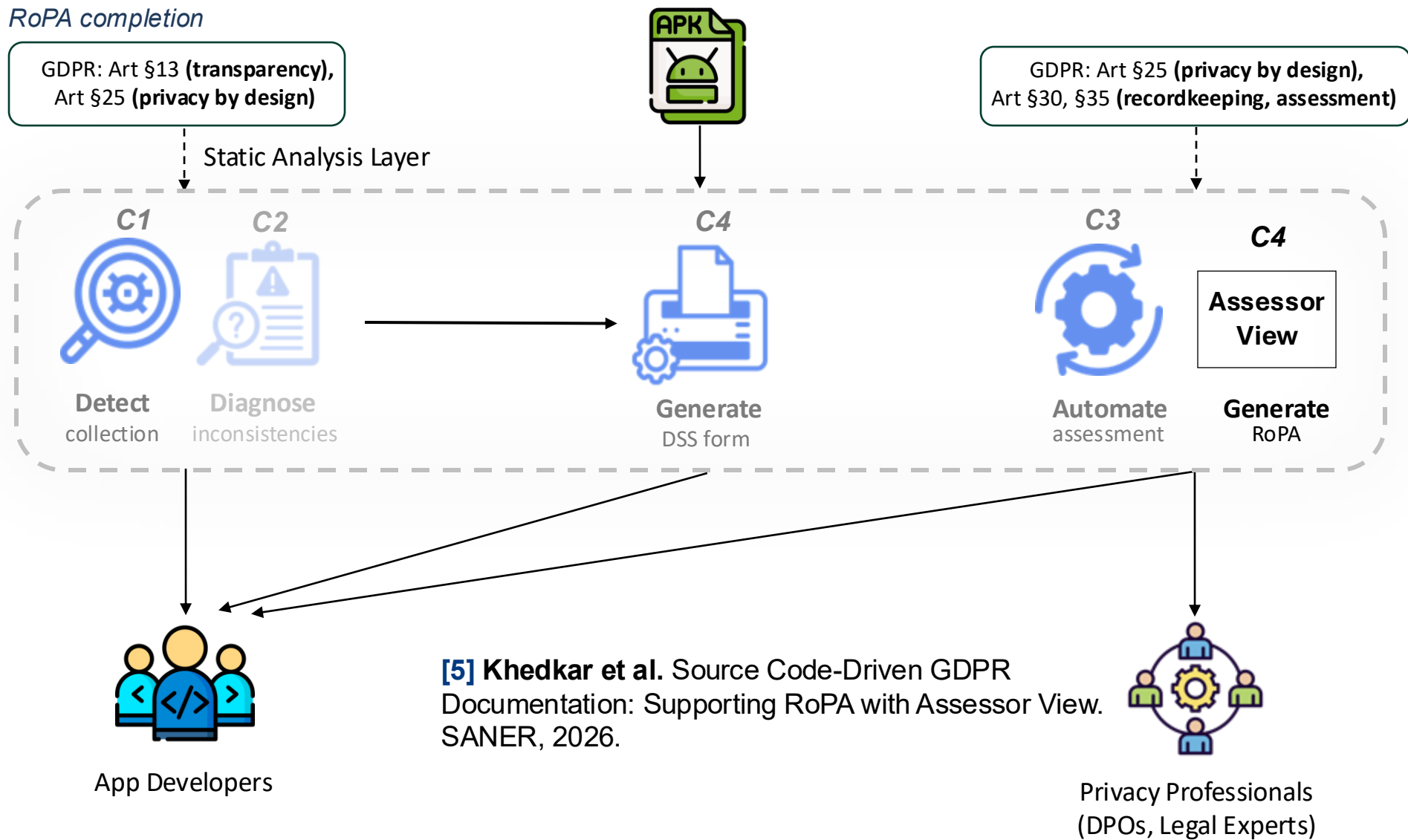
Contribution 4: Summary

Focus of this talk: RoPA completion



Contribution 4: Summary [5]

Focus of this talk: RoPA completion



[5] Khedkar et al. Source Code-Driven GDPR Documentation: Supporting RoPA with Assessor View. SANER, 2026.

Reliable, Explainable, and Accessible Compliance

Four contributions close the two gaps identified at the start of this talk:



Compliance can be validated.

- **C1** detects data collection directly from source code.
- **C2** diagnoses mismatches with self-declared developer reports.



Analysis is explainable and accessible.

- **C3** presents results at the right level of abstraction.
- **C4** automates the legal documentation GDPR requires.



THIS THESIS SHOWED:

*Static analysis of an app's source code can make GDPR compliance **reliable, explainable, and accessible** through four contributions:*



Privacy: controlling who can observe you.

Security: controlling who can enter or interfere.

Protection: reducing what an observer can learn about you.

Good protection means the observer cannot identify you.



Contact



Mrs. Mugdha Khedkar

Heinz Nixdorf Institute
Paderborn University
Fürstenallee 11
33102 Paderborn
Germany

Tel +49 5251 60-6584
Webpage <https://mugdhak30.github.io/>
Email mugdha.khedkar@upb.de



[@KhedkarMugdha](#)



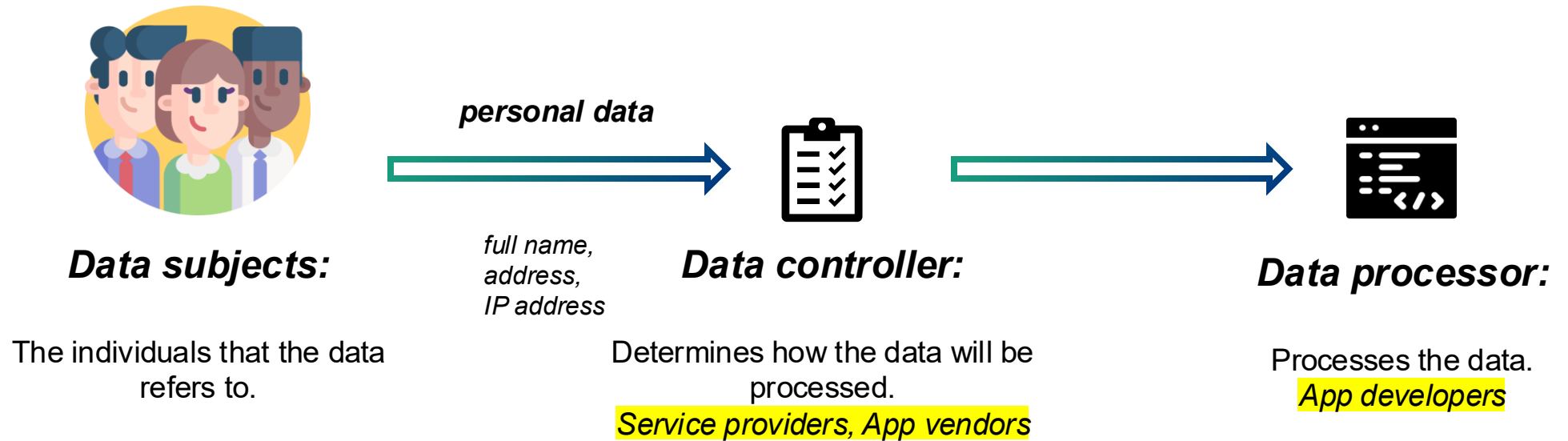
[Mugdha Khedkar](#)



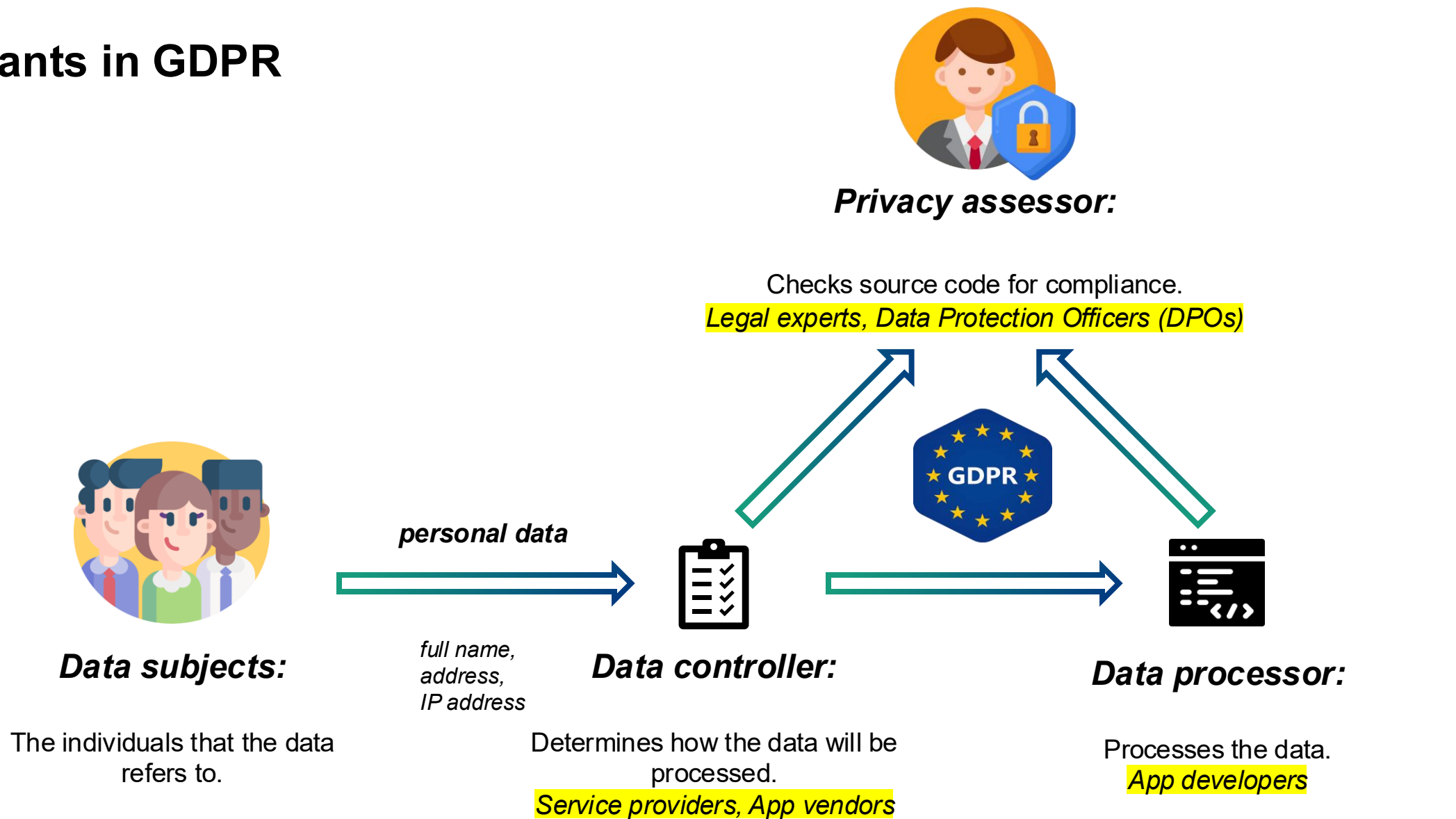
[Mugdha Khedkar](#)

BACKUP SLIDES

Participants in GDPR



Participants in GDPR



Who needs GDPR?

Any product with users residing in the EU

TECH / US & WORLD / POLICY

Major US news websites are going down in Europe as GDPR goes into effect

By [Colin Lecher](#)

May 25, 2018, 8:23 AM PDT

Los Angeles Times

Unfortunately, our website is currently unavailable in most European countries. We are engaged on the issue and committed to looking at options that support our full range of digital offerings to the EU market. We continue to identify technical compliance solutions that will provide all readers with our award-winning journalism.

Why GDPR?

The "Brussels Effect" in Global Privacy Law

172 countries now have a national privacy law -> up from 89 a decade ago¹

Directly modeled on GDPR

Brazil - LGPD (2020) - Near-identical structure: DPO requirement, lawful-basis framework, similar consent standards.

South Africa - POPIA - Explicitly GDPR-influenced data protection framework.

Sri Lanka - PDPA - Directly modeled on GDPR; fully enforceable since March 2025.

India <3 DPDP Act - Newest major regime; rules finalized 2025, phasing in through 2027.

GDPR-influenced

China - PIPL - Called "China's GDPR," but goes further: adds data localization and cross-border security assessments.

US states - CCPA / CPA / CTDPA - Colorado draws on both CCPA and GDPR; overall US approach stays state-driven, not unified.

UK - UK GDPR - GDPR retained post-Brexit, alongside the UK's own Data Protection Act 2018.

Gulf states & African economies - Many have adopted GDPR-influenced laws since 2018, each with its own regulator.

1. <https://privacyterms.io/privacy-laws-by-country-2026>

Personal Data



increasing identifiability of data



Partially identifiable data

* POSTAL CODE

* NAME

Directly identifiable data

* CREDIT CARD NUMBER

* EMAIL

GDPR Articles and Analysis Requirements

Article 13

Information to be provided to data subjects¹

→ *Analysis requirement: enumerate collected identifiers so data subjects can be told what is actually collected.*



Article 25

Privacy by default and design²

→ *Analysis requirement: flag data collection with no apparent UI/functional purpose (minimization check).*



Article 30

Maintaining Record of Processing Activities³

→ *Analysis requirement: enumerate data flows per declared purpose, to pre-fill RoPA fields.*



Article 32

Security of processing⁴

→ *Analysis requirement: detect whether collected identifiers are encrypted/hashed before storage or transmission.*



Article 35

Data Protection Impact Assessment⁵

→ *Analysis requirement: risk-categorize identified data types and surface high-risk collection for DPO review.*



1. <https://gdpr-info.eu/art-13-gdpr/>

2. <https://gdpr-info.eu/art-25-gdpr/>

3. <https://gdpr-info.eu/art-30-gdpr/>

4. <https://gdpr-info.eu/art-32-gdpr/>

5. <https://gdpr-info.eu/art-35-gdpr/>

GDPR Principles (Art. 5) Mapped to Contributions

GDPR concept	Contribution	Coverage
Lawfulness, fairness, transparency	C2 (diagnose inconsistencies), C4 (accurate report generation)	● Addressed
Purpose limitation	C4 (partially completed RoPA)	● Partial
Accuracy	Not addressed, concerns correctness of stored data values, not derivable statically	● Out of scope
Data minimization	C3 (interactive dashboard)	● Addressed
Storage limitation	C3, C4 (interactive dashboard), retention duration is policy, not code-derivable	● Partial
Integrity and Confidentiality	Delegated to security measures in existing static analysis tools	● Out of scope
Accountability	C2 (diagnose inconsistencies), C4 (accurate report generation)	● Addressed

Static analysis of source code can verify structural properties (what data is collected, where it flows, whether it matches declarations) but not runtime or organizational properties (data value correctness, actual retention practice).

Technical Measures and Psuedonymization

Design goals a pseudonymization technique must satisfy under GDPR¹

D1 Re-identification Pseudonyms should not allow easy re-identification by any third party outside the specific processing context.

D2 Reproduction It should not be trivial for a third party to reproduce the pseudonyms, preventing reuse across different processing domains.

Strong techniques (satisfy D1 and D2)

Encryption

RECOMMENDED

Currently the most robust pseudonymization technique - without the decryption key, recovering the original identifier is very difficult.

Hashing with key or salt

RECOMMENDED

Output depends on both the input and a secret key/salt. Different pseudonyms can be generated for the same input, preventing identification or reproduction.

Weak techniques (satisfy neither D1 nor D2)

Cryptographic hash function

NOT RECOMMENDED

Creates only one-way pseudonyms, but is vulnerable to brute-force and dictionary attacks.

Masking

NOT RECOMMENDED

Hiding part of an identifier with random characters. Poorly designed masking can assign the same pseudonym to different users (collisions).

Scrambling

NOT RECOMMENDED

Mixing/rearranging letters (e.g. 017655762298 → 982756571026). Simple rearrangement can be reversed to recover the identifier.

1. <https://www.enisa.europa.eu/sites/default/files/publications/WP2018%20O.2.2.5%20-%20Recomendations%20on%20shaping%20technology%20according%20to%20GDPR%20provisions%20-%20Part%201.pdf>

Data Analysis

Coding Approach across Studies



Developer Survey + Online Discussions

- Iterative open coding¹ → thematic analysis² of open-ended responses.
- Author inductively coded; compiled into codebook.
- 2nd researcher independently reviewed annotations; disagreements discussed & resolved.

Outcome: 5/12 subthemes refined; 1/24 codes re-aligned



Privacy Professional Interviews

- Audio recorded, transcribed (NoScribe³), reviewed for errors.
- Iterative open coding¹ → thematic analysis² of all transcripts.
- 2nd researcher independently reviewed codebook; disagreements discussed & resolved.

Outcome: Full agreement on all 10 sub-themes; 10/95 codes renamed



RoPA Follow-Up Interviews

- Recorded, transcribed (NoScribe³), reviewed for errors.
- Author used iterative open coding¹ to develop codebook.
- 2nd researcher double-checked the codes.

Outcome: Lighter-weight check - exploratory follow-up study

1. Juliet Corbin and Anselm Strauss. In: Zeitschrift fuer Soziologie 19.6 (1990), pp. 418–427. doi:10.1515/zfsoz-1990-0602

2. Victoria Clarke and Virginia Braun. "Thematic Analysis". In: Encyclopedia of Critical Psychology, 2014, pp. 1947–1952. DOI : 10.1007/978-1-4614-5583-7_311

3. <https://github.com/kaixxx/noScribe>

SUS and NPS Formulas

System Usability Scale (SUS)

10-item questionnaire, 5-point Likert scale (1 = strongly disagree, 5 = strongly agree)

Per-item score contribution:

Odd items (1, 3, 5, 7, 9):

$$x_i = \text{response}_i - 1$$

Even items (2, 4, 6, 8, 10):

$$x_i = 5 - \text{response}_i$$

Overall SUS score:

$$\text{SUS} = 2.5 \times \sum_{i=1}^{10} x_i$$

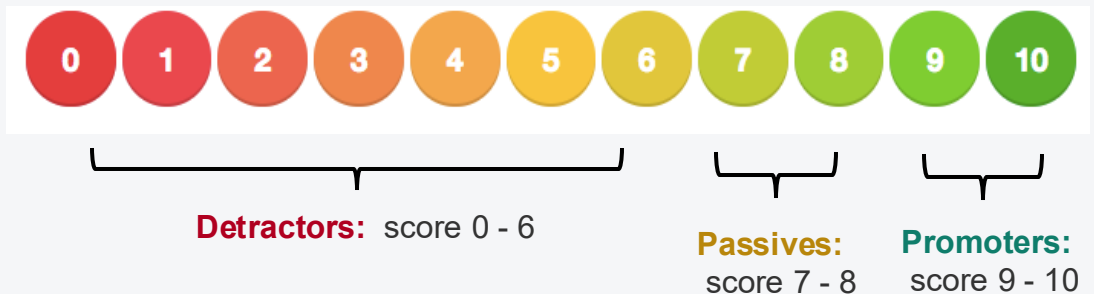
Range: 0–100 (higher = more usable). A score above 68 is considered above average.

Used as a rough indicator: Assessor View (C3), AutoPRICE (C4)

Net Promoter Score (NPS)

Single item: “How likely are you to recommend this tool to a colleague?” (0–10 scale)

Respondent categories:



Overall NPS:

$$\text{NPS} = \% \text{Promoters} - \% \text{Detractors}$$

Range: –100 to +100 (higher = stronger willingness to recommend). Passives excluded from the calculation.

Used as a rough indicator: Assessor View (C3), AutoPRICE (C4)

Practitioner View: Where Do LLMs Fit in Compliance Tooling?

Two independent sources: ① *DPO building internal AI/RoPA tooling (informal conversation).*

② *Privacy manager at a big 4 consulting firm (informal conversation).*

1 LLMs alone don't replace static analysis.

- Feeding all decompiled code to an LLM is expensive and non-deterministic.
- The practical pattern: use static analysis to reduce a large code pool to a small relevant one, then apply an LLM. ①
- LLM-generated analysis evidence is not permissible in court. I would always use static analysis for that. ②
- If I want a reliable analysis, I will never use an LLM! ②

2 The industry trend is “LLM-first, then deterministic.”

- Use a model for an initial pass, then convert its output into deterministic, checkable rules.
- Tooling is expected to become the more durable layer over time. ①

3 Pointing LLMs at private code introduces a new compliance risk.

Using LLMs directly on non-public decompiled code (commercial use) raises the question of what data is being fed to the model, and whether that itself leaks personal data. ①

Ties back to Contribution 3: deterministic, source-code-traceable evidence is what makes a compliance claim defensible - the gap purely LLM-based approaches don't close.

Practitioner View: Where Do LLMs Fit in RoPA Creation?

Source: *Invited workshop, European Privacy KnowledgeNet 2025*

“If you have a hammer, not everything in front of you is a nail.”

12% of SMEs use AI - compliance fear is cited as the top blocker

When business units draft RoPA with AI unsupervised, roughly half the entries didn't reflect actual practice.

AI is not the solution for RoPA.

Contribution 1: Detect Android Data Collection

C1



Detect Android data collection

C2



Diagnose reporting inconsistencies

C3



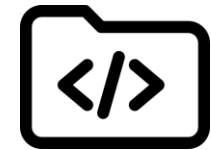
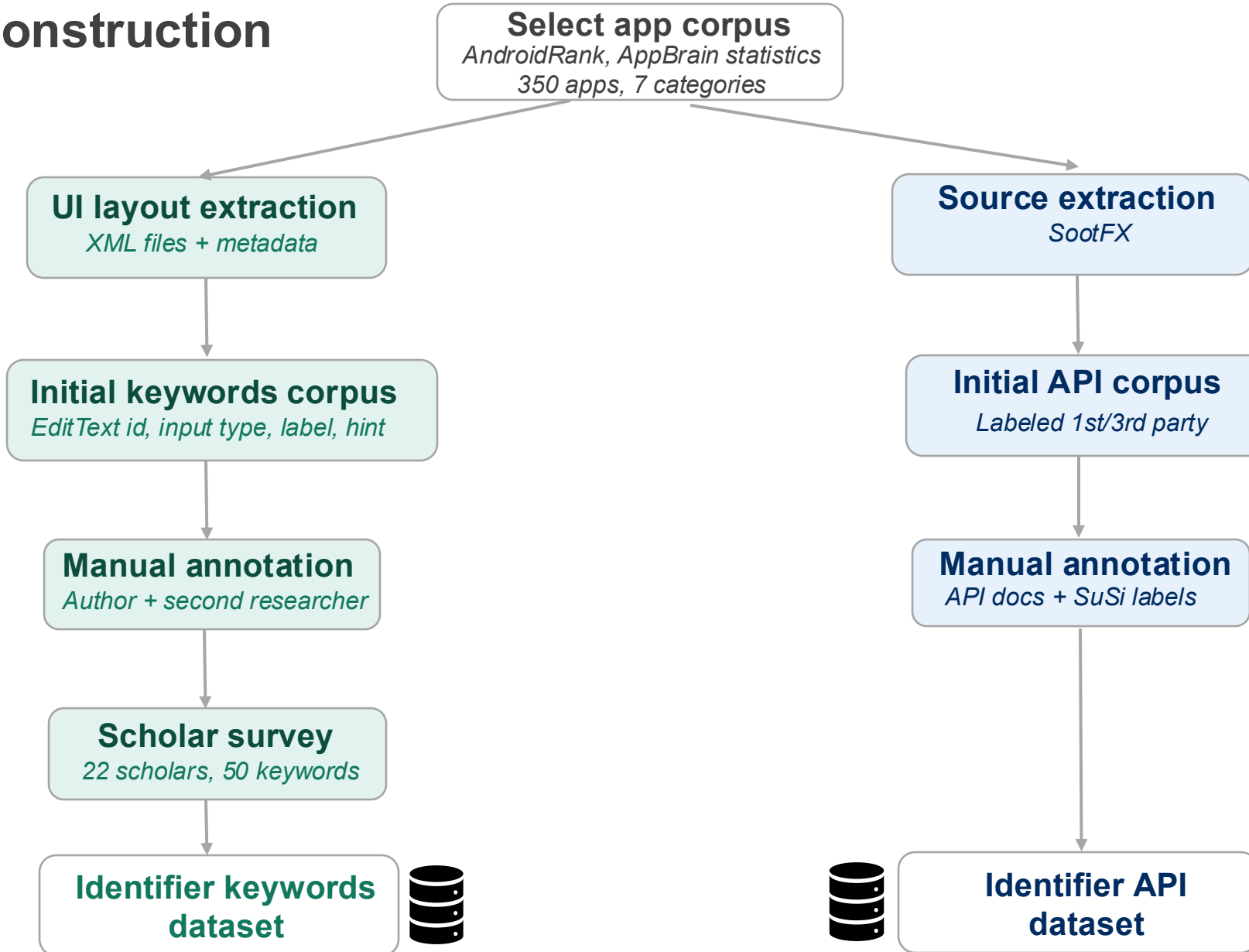
Automate privacy assessments

C4



Generate reporting documents

Dataset Construction





Validating Ambiguous Keywords

Setup

- Author + 2nd researcher selected 50 keywords flagged as ambiguous / subjective to judgement.
- Session with 22 CS research scholars at the university.
- Introduced the data classification scheme, then surveyed agreement per keyword.

Results

- Unanimous agreement on 45 of 50 keywords.
- 2 keywords reclassified based on feedback:
- “first name” & “family name”: directly identifiable → partially identifiable personal info

Outcome

- Feedback surfaced a gap: some items didn't fit existing directly-identifiable categories.
- New category introduced: directly identifiable – other data.
- Covers signatures, biometric data, images.

22

research scholars

50

keywords reviewed

45/50

unanimous agreement

2

reclassified

+1

new category added



Third-party libraries

List compiled in 2024

Category	Number of libraries	Examples
Analytics	23	Google, Firebase, Moat, TalkingData
Advertisements	22	Applovin, Adcolony, Mopub
Authentication	5	Apache, Google, Firebase
Analytics & Advertisements	5	Crashlytics, AppsFlyer, Adjust
Data serialization	1	Google protobuf
Input/ output	4	Apache, Timber
Network	1	Apache HTTP
Email	1	Apache James
Image Processing	1	Google zxing
Others	5	Baidu, Google i18n, GMS, Tencent
Total	68	

Customized Datasets

Identifier keywords dataset

Keyword(s)	Privacy label -> Identifier	
IBAN, Account number	Risk 1 financial info	-> Account
First name, Family name	Risk 2 personal info	-> Name
PIN, TAN	Risk 3 authentication	-> Password
Chat	Risk 4	-> Message



Identifier API dataset



Method call	Privacy label -> Identifier	
android.new.IpPrefix: java.net.InetAddress getAddress()	Risk 1 device or other IDs	-> IP Address
android.location.Location: double getLatitude()	Risk 2 location	-> Approximate location
com.google.gms.auth.api.identity.SignInPassword: java.lang.String getPassword()	Risk 3 authentication	-> Password
android.app.Activity: android.view.View findViewById(int)	Risk 4	-> Text

Labelling Collected Data

Privacy-Relevant Input Classification Engine (PRICE)

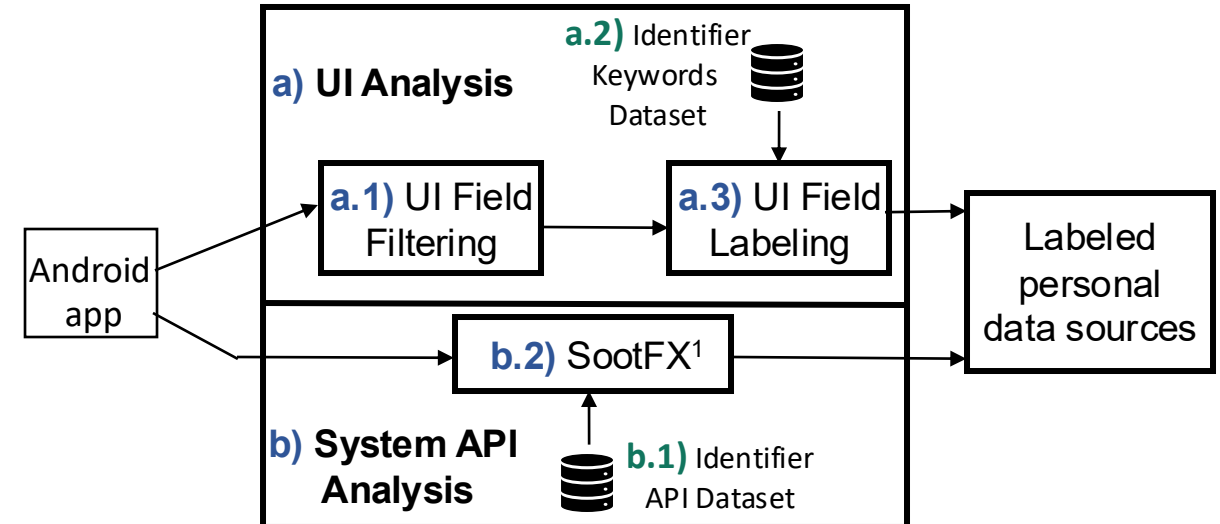
- Labels static sources of personal data in the user interface (**a**) and source code (**b**) of an Android app

- Uses customized datasets (**a.2**, **b.1**) to detect and label:

- data collected by UI screens



- data collected by system API calls



1. K. Karakaya and E. Bodden, "SootFX: A Static Code Feature Extraction Tool for Java and Android," *2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Luxembourg, 2021, pp. 181-186, doi: 10.1109/SCAM52516.2021.00030.

Labelling Collected Data

Privacy-Relevant Input Classification Engine (PRICE)

- Labels static source code data in the user interface (a) of an Android app

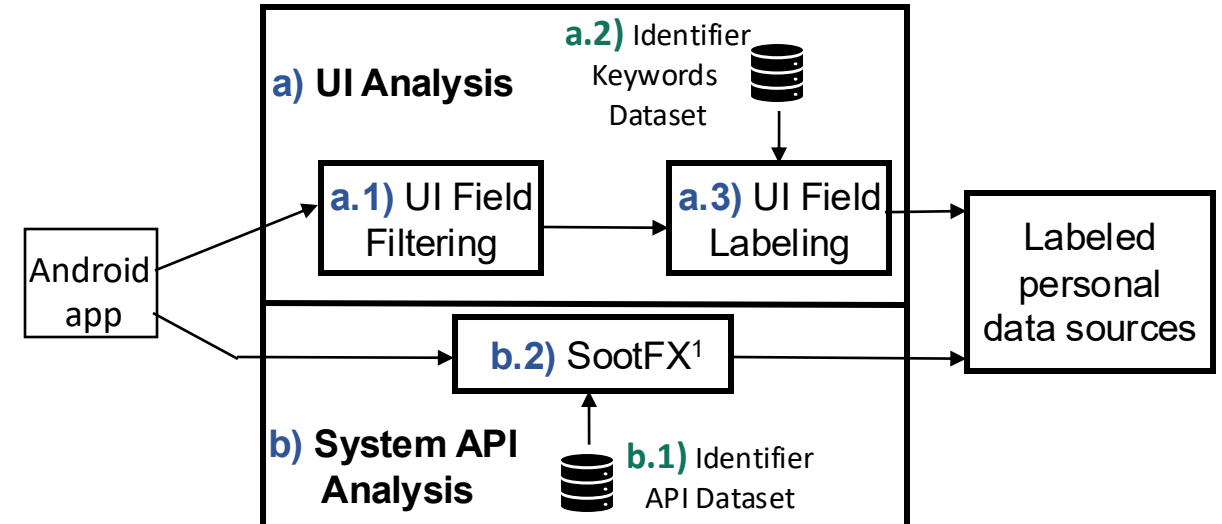


- Uses customized datasets (a.2, b.1) to detect and label:

- data collected by UI screens



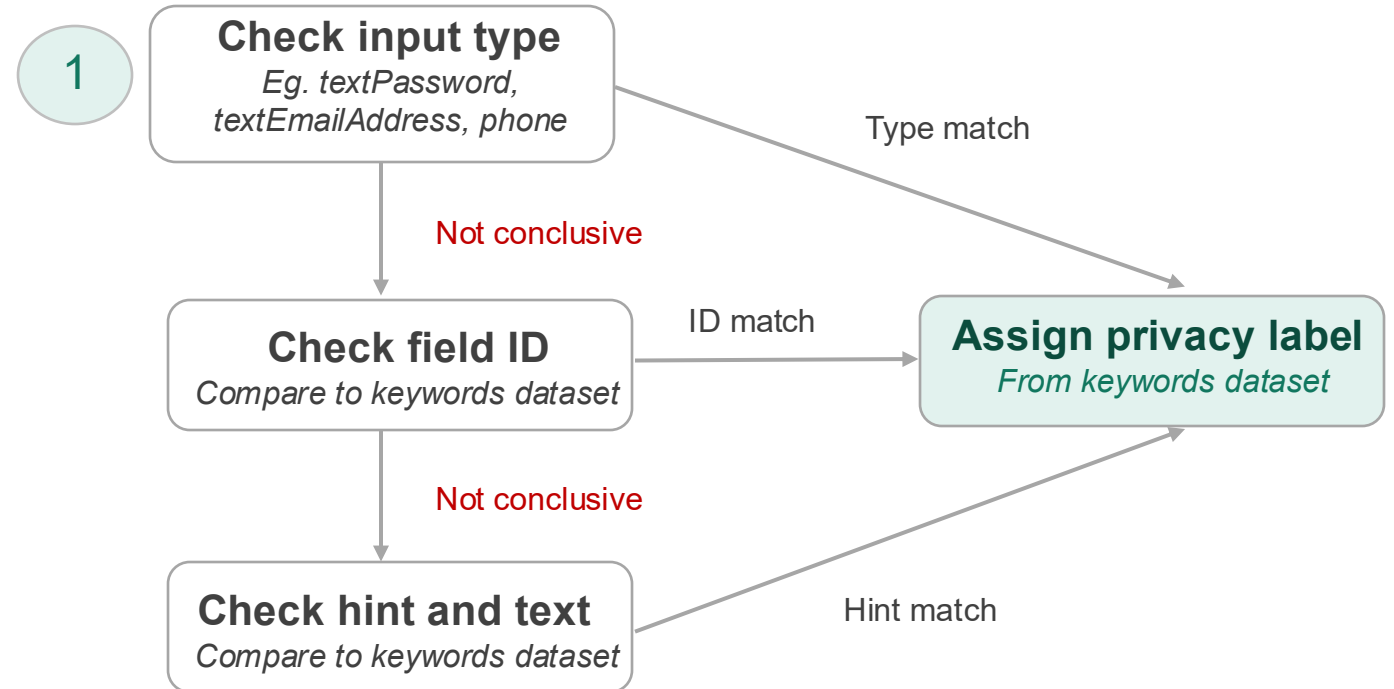
- data collected by system API calls



1. K. Karakaya and E. Bodden, "SootFX: A Static Code Feature Extraction Tool for Java and Android," *2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Luxembourg, 2021, pp. 181-186, doi: 10.1109/SCAM52516.2021.00030.

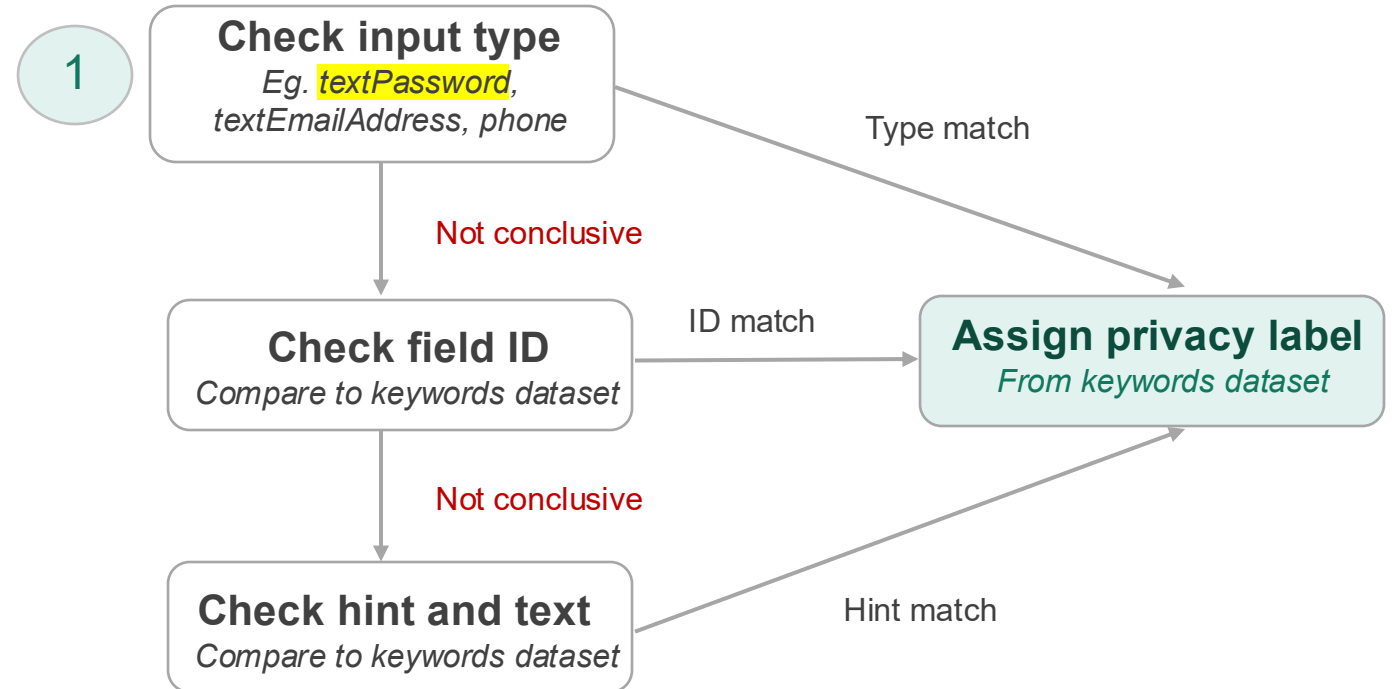
UI Analysis: Labeling Algorithm

```
<EditText  
    android:id="@+id/password_field"  
    android:inputType="textPassword"  
    android:hint="Enter password"  
>
```



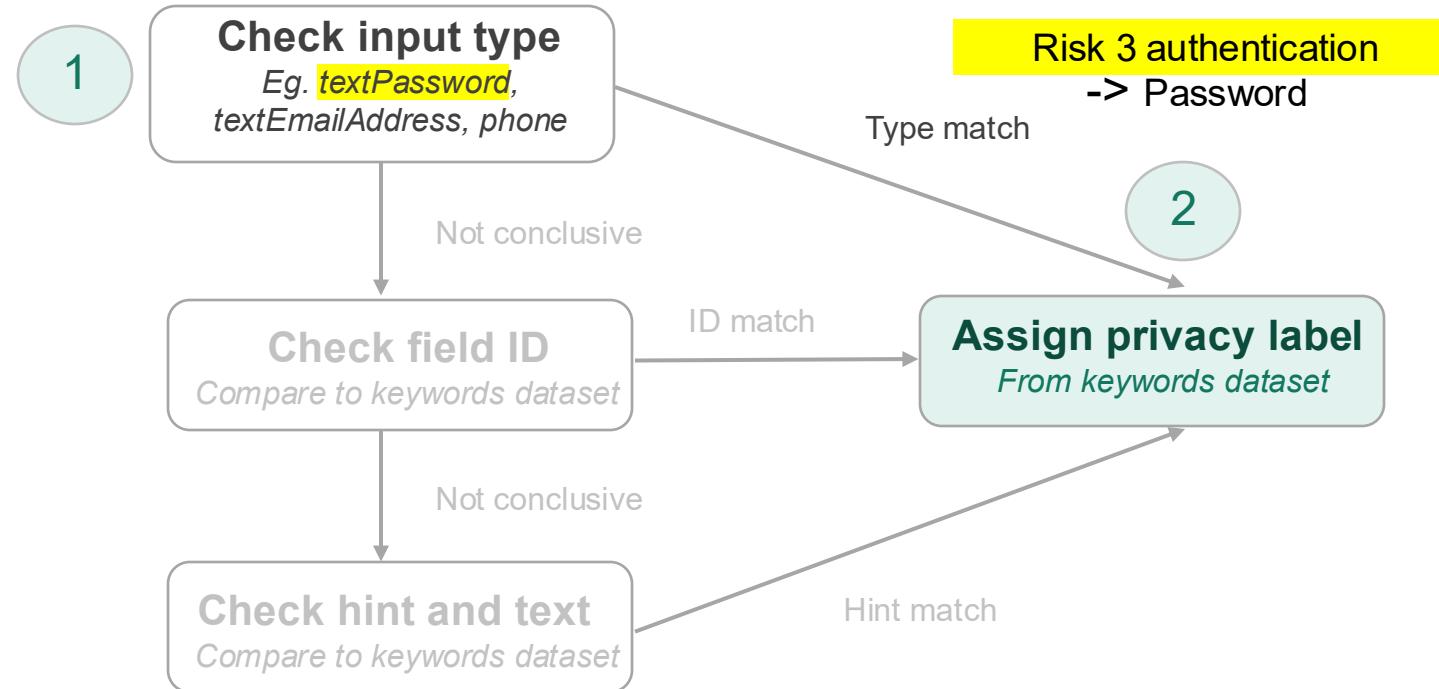
UI Analysis: Labeling Algorithm

```
<EditText  
  android:id="@+id/password_field"  
  android:inputType="textPassword"  
  android:hint="Enter password"  
>
```



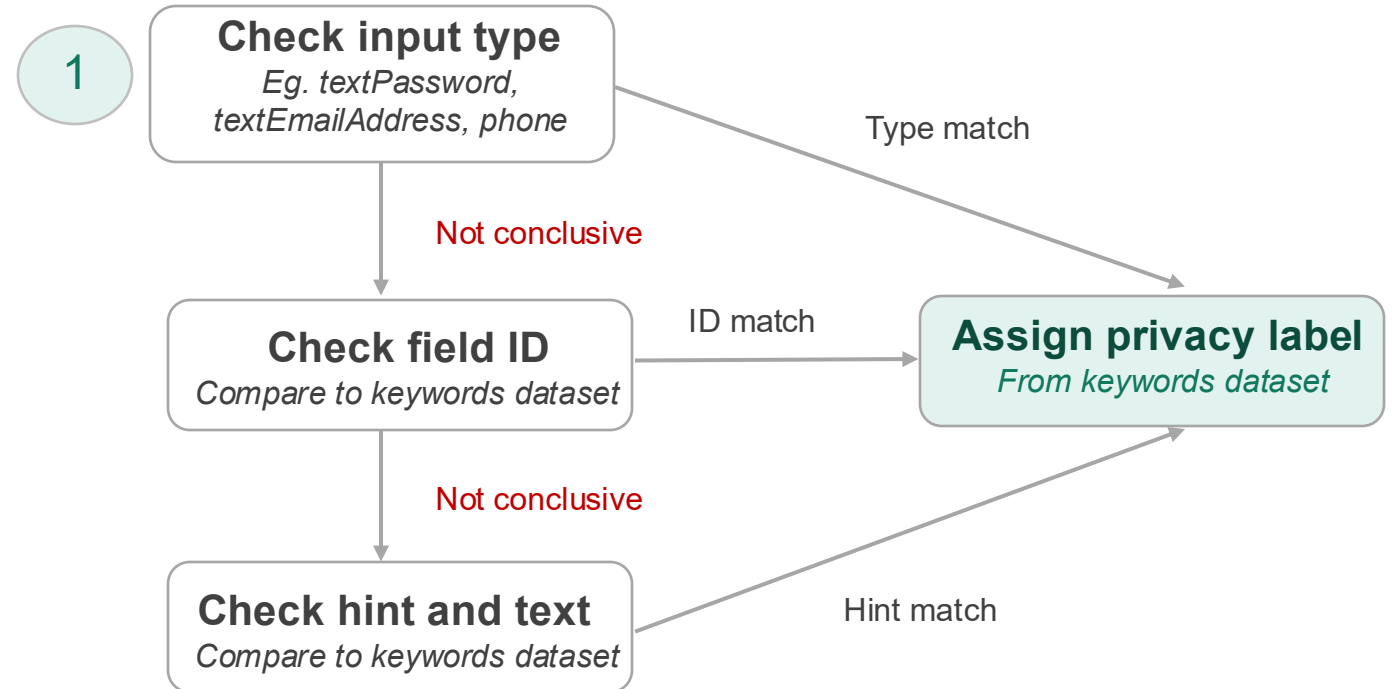
UI Analysis: Labeling Algorithm

```
<EditText
  android:id="@+id/password_field"
  android:inputType="textPassword"
  android:hint="Enter password"
/>
```



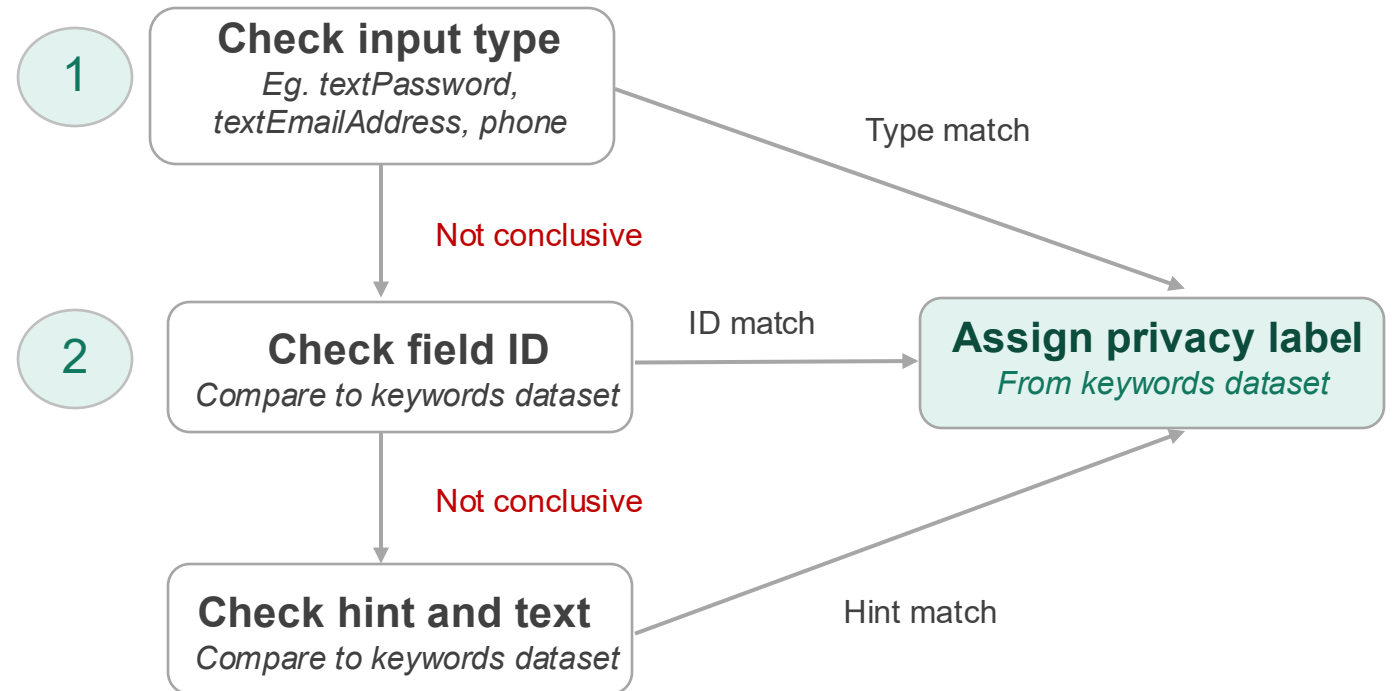
UI Analysis: Labeling Algorithm

```
<EditText  
    android:id="@+id/first_name_input"  
    android:inputType="text"  
    android:hint="First name"  
>
```



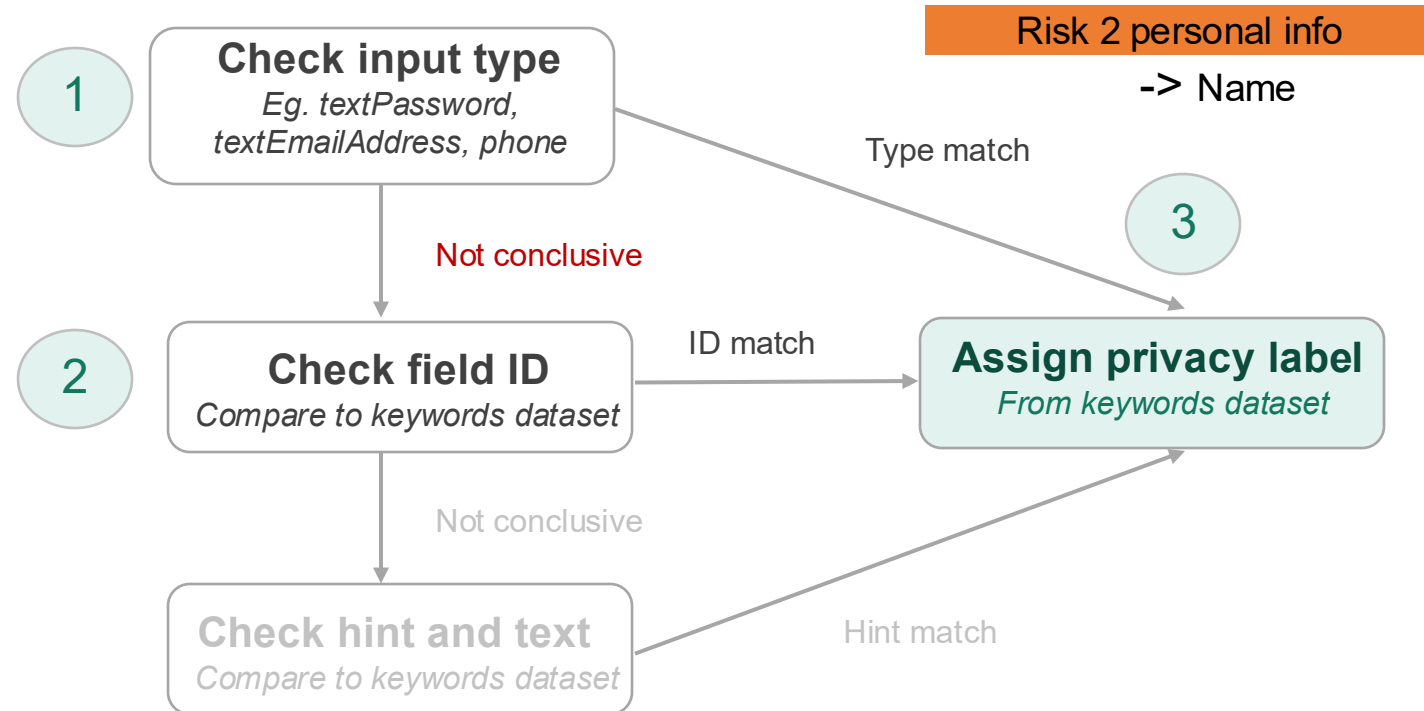
UI Analysis: Labeling Algorithm

```
<EditText  
    android:id="@+id/first_name_input"  
    android:inputType="text"  
    android:hint="First name"  
>
```



UI Analysis: Labeling Algorithm

```
<EditText  
    android:id="@+id/first_name_input"  
    android:inputType="text"  
    android:hint="First name"  
>
```





UI Labeling: Sanity Checks

Manual verification on 25 apps (536 records)

0.926

Precision

0.928

Recall

0.927

F1-score

12.18s

Avg. time / app

Confusion matrix (n = 536)

	Pred. +	Pred. -
Actual +	379 True positives	29 False negatives
Actual -	30 False positives	98 True negatives

Error analysis

False negatives (29)

Keywords not present in the keywords dataset
e.g. temperature, OS version, app version

***Fix:** Extend the dataset with these terms*

False positives (30)

Substrings of longer words matching sensitive keywords
e.g. "zip" → "ip", "outside" → "id"

***Fix:** Replace substring matching with LLM / NLP-based matching (this analysis predates that tooling, 2023)*

Limitations of PRICE

1 Dataset construction

Results depend on how precisely the keyword and API datasets are curated. Missing, ambiguous, or misclassified entries affect accuracy, and identifiability judgments involve human subjectivity. Analysis targets GDPR but can be adapted to other regimes by modifying the datasets.

2 Annotation subjectivity

Two annotators disagreed on 50 keywords. Rather than a formal agreement metric, feedback was sought from 22 domain-adjacent researchers, refining classifications and adding a category — though subjectivity and generalizability remain limited.

3 Context-dependent false positives

Keywords like “body” and “height” were initially mislabeled as health data because risk-2 labeling was prioritized before risk-4 (context-dependent) labeling. Reordering precedence levels reduced false positives by 0.5%; remaining cases are considered insignificant.

4 Library and UI coverage

The Identifier API Dataset may miss third-party libraries despite the selection process used. UI analysis covers only textual Android layout elements and does not trace input fields to their source-code variables.

5 Obfuscation

Keyword-based API matching¹ fails on renamed third-party libraries without keep rules, though Android framework/SDK signatures stay intact. UI analysis complements this gap. Only 24.92% of 1.7M Play Store apps were found obfuscated², limiting real-world impact.

1. K. Karakaya and E. Bodden, “SootFX: A Static Code Feature Extraction Tool for Java and Android,” *2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Luxembourg, 2021, pp. 181-186, doi: 10.1109/SCAM52516.2021.00030.
2. Dominik Wermke, Nicolas Huaman, Yasemin Acar, et al. “A Large Scale Investigation of Obfuscation Use in Google Play”. In: Proceedings of the 34th Annual Computer Security Applications Conference. ACSAC '18. DOI :10.1145/3274694.3274726

Experiment 1: Random Apps

Heatmap of the percentage of Android apps that collect personal data



UI screens analyzed:
2182 apps



Source code analyzed:
7150 apps

Personal data collection

Directly identifiable	Personal info	29
	Device or other IDs	11
	Financial info	6
Partially identifiable	Personal info	35
	Financial info	35
	Location data	16
	Health and fitness	8
	Calendar data	7

Personal data collection

Directly identifiable	Device or other IDs	100
	Personal info	21.69
Partially identifiable	Personal info	100
	Location and browsing data	100
	Device info	45.59
	Audio data	24.49
	Session data	3.62
	App activity	3.54

Experiment 2: Domain-Specific UI Analysis

Heatmap of the percentage of apps that collect privacy-related data



UI screens analyzed:
512 apps



Shopping



Social media



Banking



Health



Tech & Edu



Entertainment



Sports



Directly identifiable
Partially identifiable
Access
Context-dependent

71	84	58	67	52	56	39
83	92	76	81	78	66	55
56	60	55	48	42	33	29
98	97	96	97	93	92	84

Experiment 2: Domain-Specific UI Analysis

Heatmap of the percentage of apps that collect personal data



UI screens analyzed:
512 apps



Shopping



Social
media



Banking



Health



Tech &
Edu



Entertainment

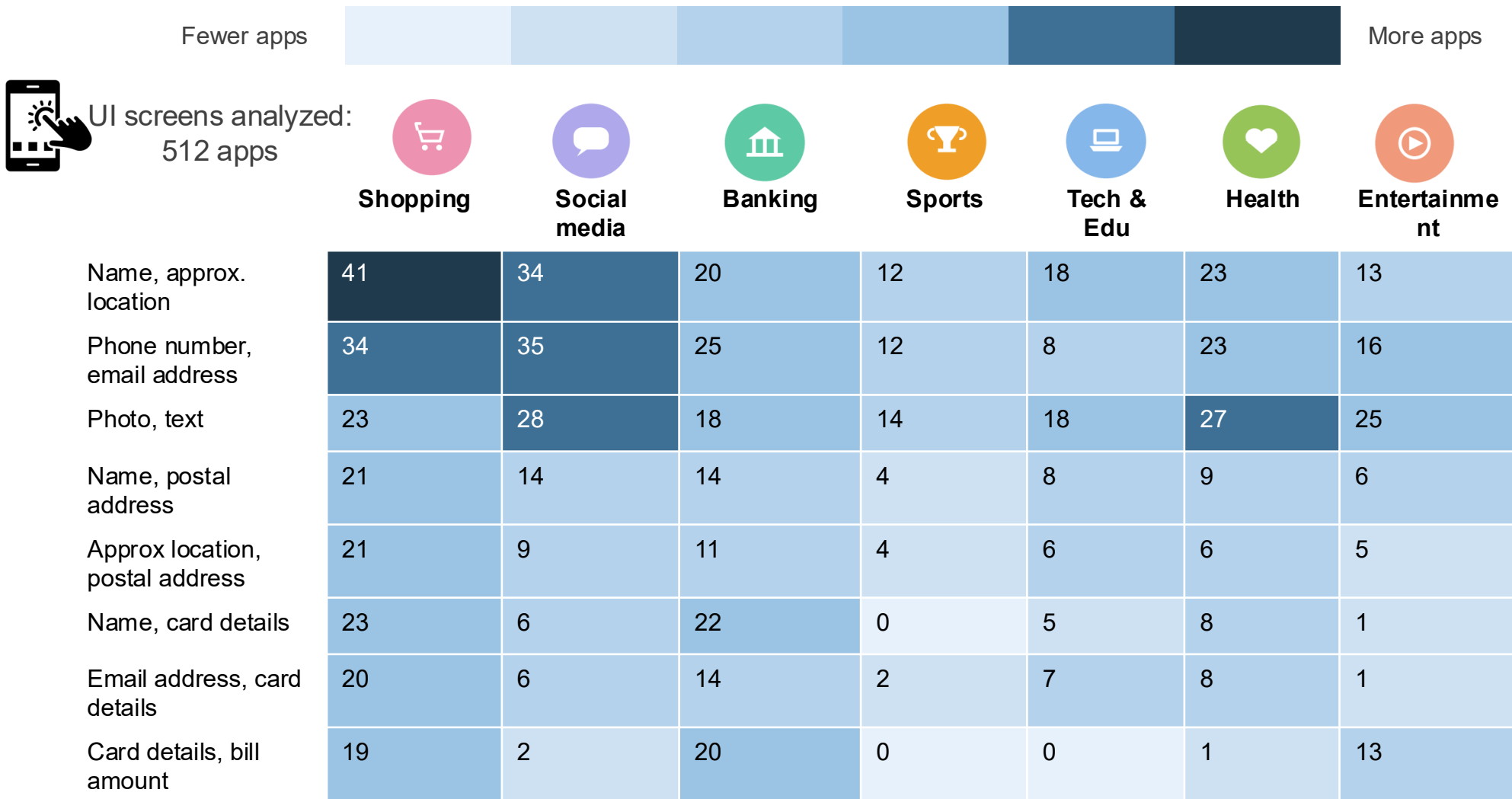


Sports

Directly identifiable	Personal info	66	73	46	54	42	46	33
	Financial info	34	25	26	18	16	8	4
	Device or other IDs	36	54	28	37	25	24	16
Partially identifiable	Personal info	66	77	53	65	64	55	41
	Location data	61	48	34	28	22	21	18
	Personal info	34	14	45	23	7	4	0
	Calendar data	19	13	20	22	10	6	0
	Health and fitness	3	7	3	18	3	5	2

Experiment 2: Domain-Specific UI Analysis

Heatmap of the identifier combinations collected by most downloaded apps



Data Collection: Random vs. Domain-Specific Apps

Heatmap of the percentage of apps that collect privacy-related data



UI screens analyzed:

2182 apps

512 apps

Random apps

Popular apps



Directly identifiable personal data

Partially identifiable personal data

Access data

Context-dependent data

32	62
50	77
27	47
45	94



Related Work

Privacy-Related Data Detection

UI-Based Detection

- Prior work analyzes UI text/layout to detect privacy violations and malicious behavior¹.
- SUPOR² and UIPicker³ identify sensitive data in Android UIs proprietary, not GDPR-aligned.
- UiRef⁴ detects sensitive UI inputs, needs adaptation to post-GDPR definitions.

1. Wan et al.'18 (GUILeak); Hu et al.'14 (AsDroid)
2. Huang et al.'15 (SUPOR)
3. Nan et al.'15 (UIPicker)
4. Andow et al.'17 (UiRef)

Taint Analysis & Source Classification

- Traditional taint analysis relies on predefined source lists⁵.
- Later work applies ML to automatically classify/categorize API methods as sources⁶.

5. Arzt et al.'14; (FlowDroid) TØ '22; Li et al.'15 (lccTA)
6. Rasthofer et al.'14; Pandita et al.'19; Piskachev et al.'20 (SWANAssist); Samhi et al.'23

Closest to Our Work

- Kober et al. (2023)⁷ define sensitive data grounded in legal frameworks (incl. GDPR).
- Publish an Android sensitive-source list, used directly in our work.

7. Kober et al.'23

Gap: No systematic labeling of all collected data into GDPR-aligned privacy categories - addressed by the **Identifier Dataset + PRICE**.

Contribution 2: Diagnose Reporting Inconsistencies

C1



Detect Android data
collection

C2



Diagnose reporting
inconsistencies

C3



Automate privacy
assessments

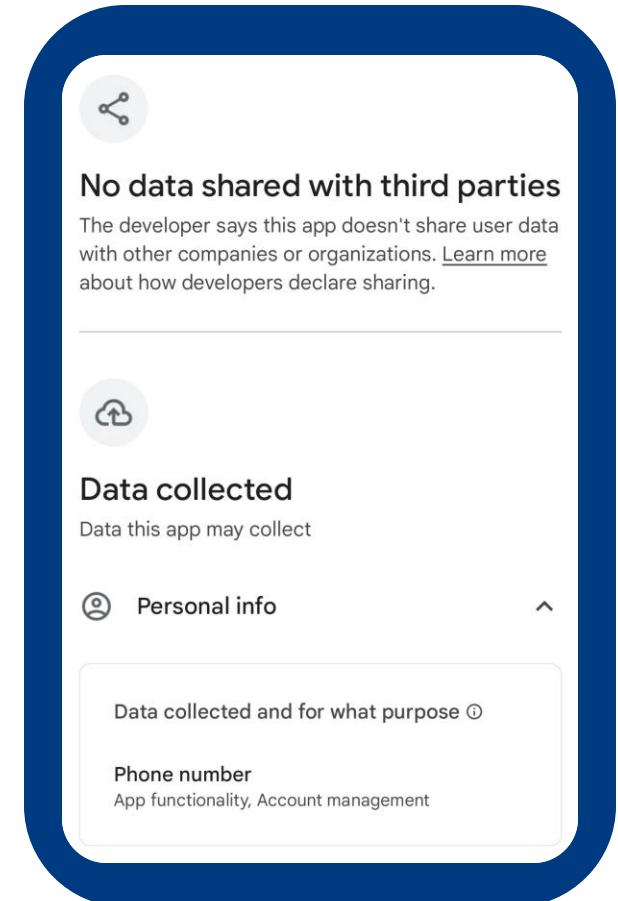
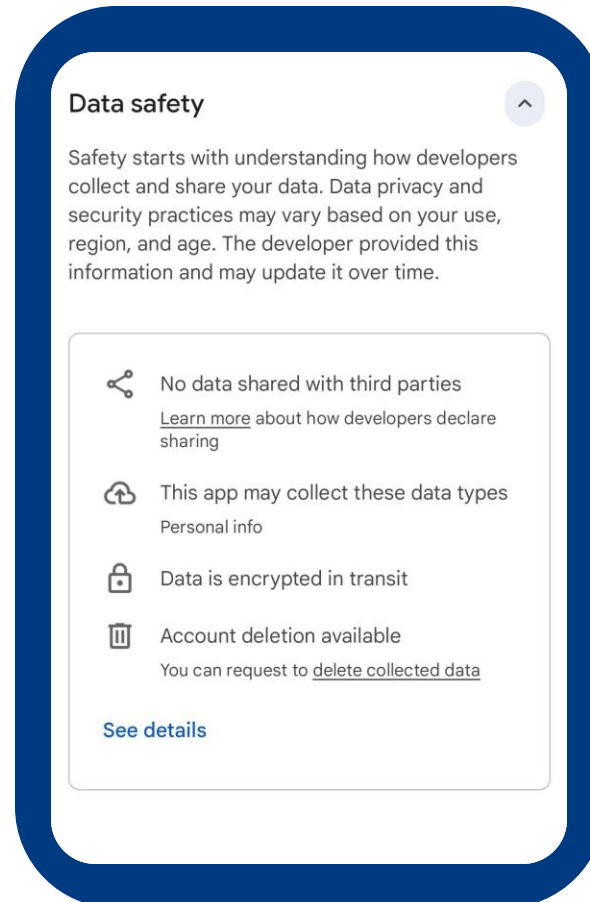
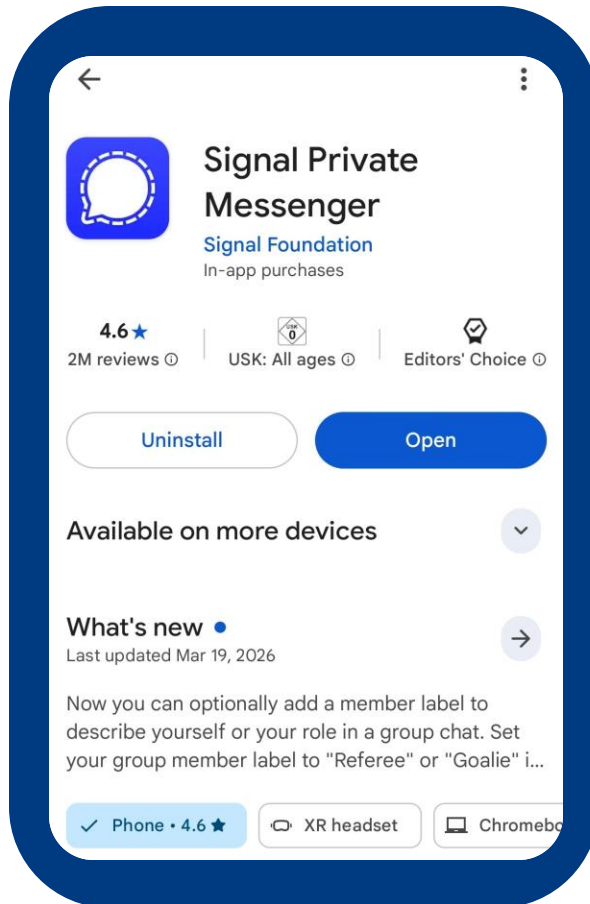
C4



Generate reporting
documents

Data Safety Section (DSS)

Mandatory user-facing disclosures on Play Store listing of every Android app





Data Safety Section (DSS)

Data categories and types

Data Category	Data types
Location	Approximate location, Precise location
Personal info	Name, Email address, User IDs, Address, Phone number, Race and ethnicity, Political or religious beliefs, Sexual orientation, Other info
Financial Info	Payment info, Purchase history, Credit score, Other financial info
Health & Fitness	Health info, Fitness info
Messages	Emails, SMS/MMS, Other in-app or chat messages
Photos & Videos	Photos, Videos
Audio Files	Voice or sound recordings, Music files, Other audio files
Files & Docs	Files and documents
Calendar	Calendar events
Contacts	Contacts
App Activity	App interactions, In-app search history, Installed apps, Other user-generated content, Other actions
Web Browsing	Web browsing history
App Info & Performance	Crash logs, Diagnostics, Other performance data
Device or Other IDs	Device or Other IDs



Data Safety Section (DSS)

Purposes

Data Purpose	Description
App functionality	Used for features that are available in the app.
Analytics	Used to collect data about how users use the app.
Developer communications	Used to send news or notifications about the app or the developer.
Advertising or marketing	Used to display or target ads or marketing communications.
Fraud prevention, security, and compliance	Used for fraud prevention, security, and legal compliance.
Personalization	Used to customize the app, such as showing recommended content.
Account management	Used for the setup or management of a user's account.

DSS Form

Email address

Is this data collected, shared, or both?

1.

Select all that apply. Some types of data collection and sharing are exempt.
[View definitions and exemptions](#)

☒ Collected
This data is transmitted off the user's device, either to you (the developer) or a third party. This includes data that is processed ephemeraly, or stored for longer.

☐ Shared
This data is transferred to a third party, either on or off the user's device

Is this data processed ephemeraly?

2.

Processing data "ephemeraly" means accessing and using data while it is only stored in memory, and is retained for no longer than necessary to service the specific request in real-time.

Data collected in this way must still be disclosed, but will not be shown to users on your store listing. [Learn more](#)

☐ Yes, this collected data is processed ephemeraly

☒ No, this collected data is not processed ephemeraly

Is this data required for your app, or can users choose whether it's collected?

3.

[Learn more](#)

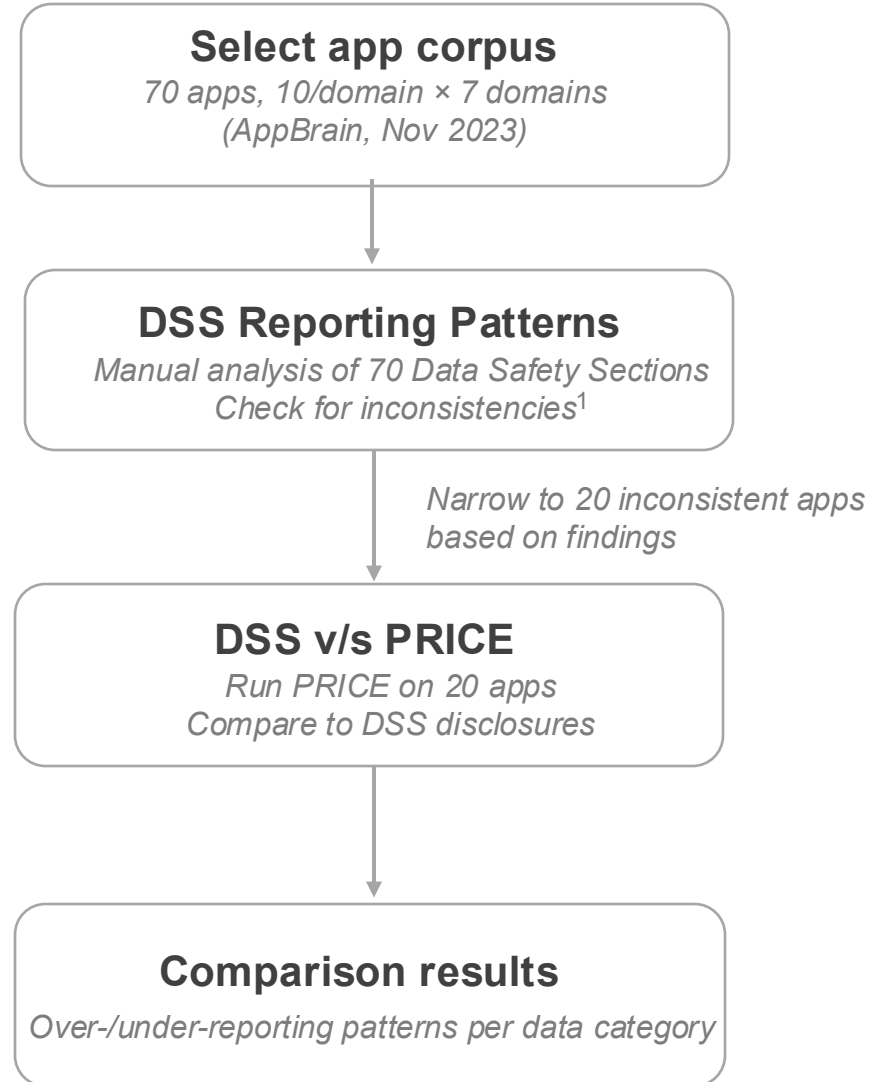
☐ Data collection is required (users can't turn off this data collection)

☒ Users can choose whether this data is collected
Data will be shown as optional on your store listing

1. data collection and/or sharing
2. ephemeral processing, and
3. optional data collection

An example from <https://developer.tuya.com/en/docs/iot/Google-release-datasafety?id=Kbmh43wsn5kyr>

App Selection and Experimental Design



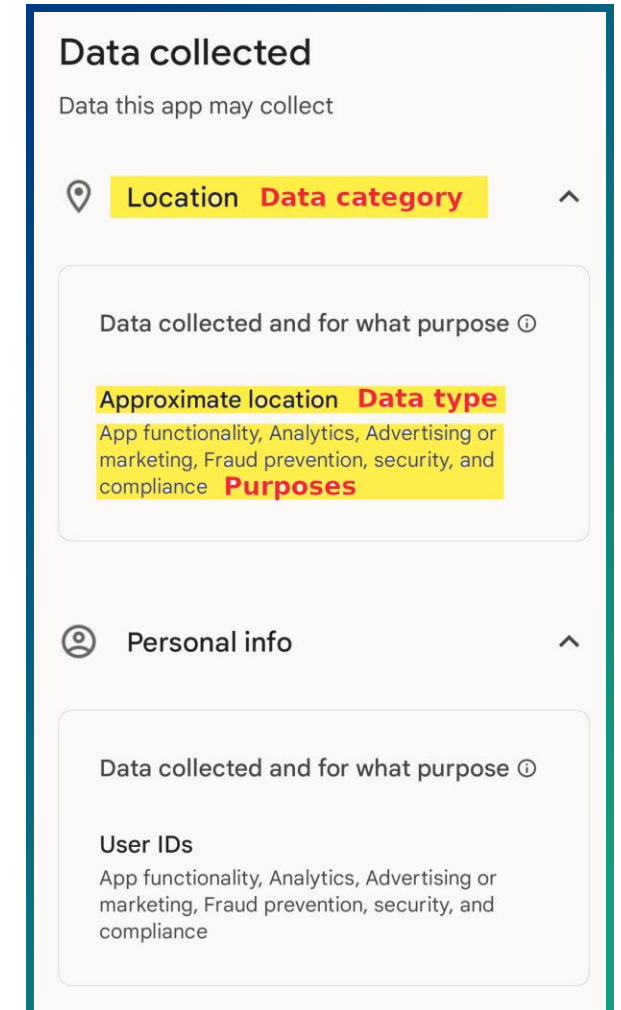
1. Rishabh Khandelwal, Asmit Nayak, Paul Chung, and Kassem Fawaz. Unpacking Privacy Labels: A Measurement and Developer Perspective on Google's Data Safety Section. 2023. arXiv: 2306.08111 [cs.CY]

Reporting via DSS

We manually study data safety sections of 70 popular Android apps and observe:

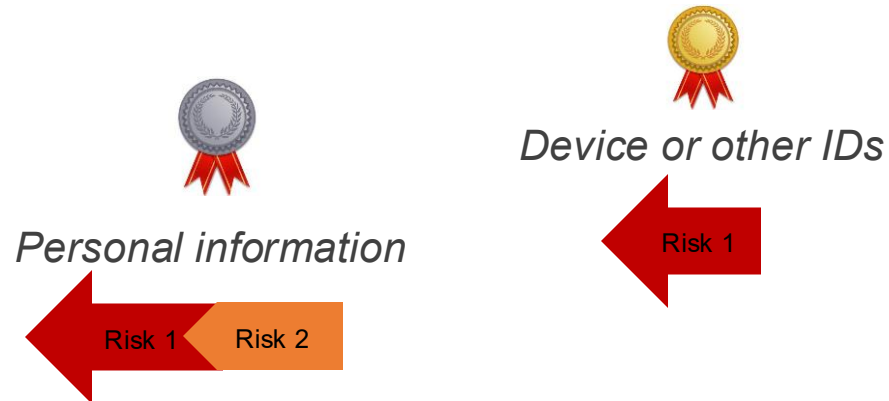
- 11% of the apps **over-report** the data collection
- 13% of the apps **under-report** the data collection

The most frequently reported data categories are



General observations

The most **accurately** reported data categories are:



The most **inaccurately** reported data categories are:



DSS Categories Covered by PRICE

Google Play's Data Safety Section defines 14 data categories. PRICE currently detects 10 of them.

Data Category	PRICE	Data Category	PRICE
Location	Detected	Calendar	Detected
Personal info	Detected	Contacts	Detected
Financial info	Detected	Device or other IDs	Detected
Health and fitness	Detected	Files and docs	Not detected
Messages	Detected	App activity	Not detected
Photos and videos	Detected	Web browsing	Not detected
Audio files	Detected	App info and performance	Not detected

Why the remaining 4 categories are out of scope

- Files and docs, App activity, Web browsing, and App info and performance describe runtime behavior (what the app does while executing), not what a static artifact declares.
- Detecting them reliably needs dynamic analysis: observing network traffic, file I/O, and API calls at runtime rather than parsing manifests, code, or permission declarations.
- Our ongoing project on traffic analysis aims to extend coverage to these categories through runtime observation.

Collected Data vs. DSS

An experiment on 20 apps

	Categories in the Data Safety Section									
	Device or other IDs	Personal info	Audio	Contacts	Location	Photos and videos	Financial info	Messages	Health and fitness	Calendar
	★: collected, ○: reported, ⊛: collected and reported									
Signal	★	⊛	★	★	★	★		★		★
SkyMap	★	★			★					
Western Union	★	★	★	★	★	★				
Yazio	⊛	⊛			★	⊛			★	
Temu	⊛	⊛			★	⊛	⊛			
DuckDuckGo	★	★	★		★	★				
Covpass	★	★			★					
Trust	⊛	⊛			★		★	○		
Paytm	★	⊛	★	⊛	★	★	★			★
Instagram	⊛	⊛	⊛	⊛	⊛	⊛	⊛	○	○	○
Gmail	⊛	⊛	⊛	⊛	⊛	⊛	○	⊛		⊛
Discord	⊛	○	⊛	⊛	⊛	⊛		○		
Youtube	⊛	⊛	⊛	○	⊛	⊛	⊛	⊛	★	
Flo	⊛	⊛			⊛	○	⊛	○	○	
Candy Crush Saga	⊛	⊛			⊛	★	○	○		
Babbel	⊛	○	⊛		⊛	★	○			
Google Maps	⊛	⊛	⊛	⊛	⊛	⊛		⊛	★	
Netflix	⊛	○	⊛		⊛	★				
Fitbit	⊛	⊛	★	⊛	⊛	★	⊛	⊛	⊛	★
Amazon	⊛	⊛	⊛	★	⊛	⊛	○	○	⊛	

Collected Data vs. DSS

An experiment on 20 apps



under-reports
data collection

- No data shared with third parties
[Learn more](#) about how developers declare sharing
- This app may collect these data types
Personal info
- Data is encrypted in transit
- Account deletion available
You can request to [delete collected data](#)

[See details](#)

	Categories in the Data Safety Section									
	Device or other IDs	Personal info	Audio	Contacts	Location	Photos and videos	Financial info	Messages	Health and fitness	Calendar
★: collected, ○: reported, ⊛: collected and reported										
Signal	★	⊛	★	★	★	★		★		★
SkyMap	★	★			★					
Western Union	★	★	★	★	★	★				
Yazio	⊛	⊛			★	⊛			★	
Temu	⊛	⊛			★	⊛	⊛			
DuckDuckGo	★	★	★		★	★				
Covpass	★	★			★					
Trust	⊛	⊛			★		★	○		
Paytm	★	⊛	★	⊛	★	★	★			★
Instagram	⊛	⊛	⊛	⊛	⊛	⊛	⊛	○	○	○
Gmail	⊛	⊛	⊛	⊛	⊛	⊛	○	⊛		⊛
Discord	⊛	○	⊛	⊛	⊛	⊛		○		
Youtube	⊛	⊛	⊛	○	⊛	⊛	⊛	⊛	★	
Flo	⊛	⊛			⊛	○	⊛	○	○	
Candy Crush	⊛	⊛			⊛	★	○	○		
Saga					⊛	★	○	○		
Babbel	⊛	○	⊛		⊛	★	○			
Google Maps	⊛	⊛	⊛	⊛	⊛	⊛		⊛	★	
Netflix	⊛	○	⊛		⊛	★				
Fitbit	⊛	⊛	★	⊛	⊛	★	⊛	⊛	⊛	★
Amazon	⊛	⊛	⊛	★	⊛	⊛	○	○	⊛	



Instagram

over-reports
data collection

- This app may share these data types with third parties
Personal info and Device or other IDs
- This app may collect these data types
Location, Personal info and 12 others
- Data is encrypted in transit
- Account deletion available
You can request to [delete collected data](#)

[See details](#)

Reasons for Data Reporting Discrepancies

Google's definition of collected data

Our research also reveals major shortcomings in Google's Data Safety Form itself:

The form includes significant loopholes, like failing to require the apps to report data sharing with “service providers.”

Google uses **narrow definitions** for data “collection” and “sharing,” making it easier for app developers to mislead users.

Google also exempts “anonymized” data from its disclosure requirements, which is problematic due to [questions about whether true anonymization is even possible.](#)

Mozilla's findings¹

Not in scope for data collection

The following use cases do not need to be disclosed as collected:

- **On-device access/processing:** User data accessed by your app that is only processed locally on the user's device and not sent off device does **not** need to be disclosed.
- **End-to-end encryption:** User data that is sent off device, but that is unreadable by you or anyone other than the sender and recipient as a result of end-to-end encryption does **not** need to be disclosed.
 - The encrypted data must not be readable by any intermediary entity, including the developer, and only sender and recipient may have necessary keys.

Google's data collection exemptions²

1. https://assets.mofoprod.net/network/documents/PNI_Google_Play_Store_Research_Report_2023.pdf
2. Google's definition of data collection: <https://support.google.com/googleplay/android-developer/answer/10787469?hl=en#zippy=%2Cdata-collection%2Cdata-sharing%2Cwhat-kinds-of-techniques-can-be-used-to-make-data-anonymous>

Conclusion

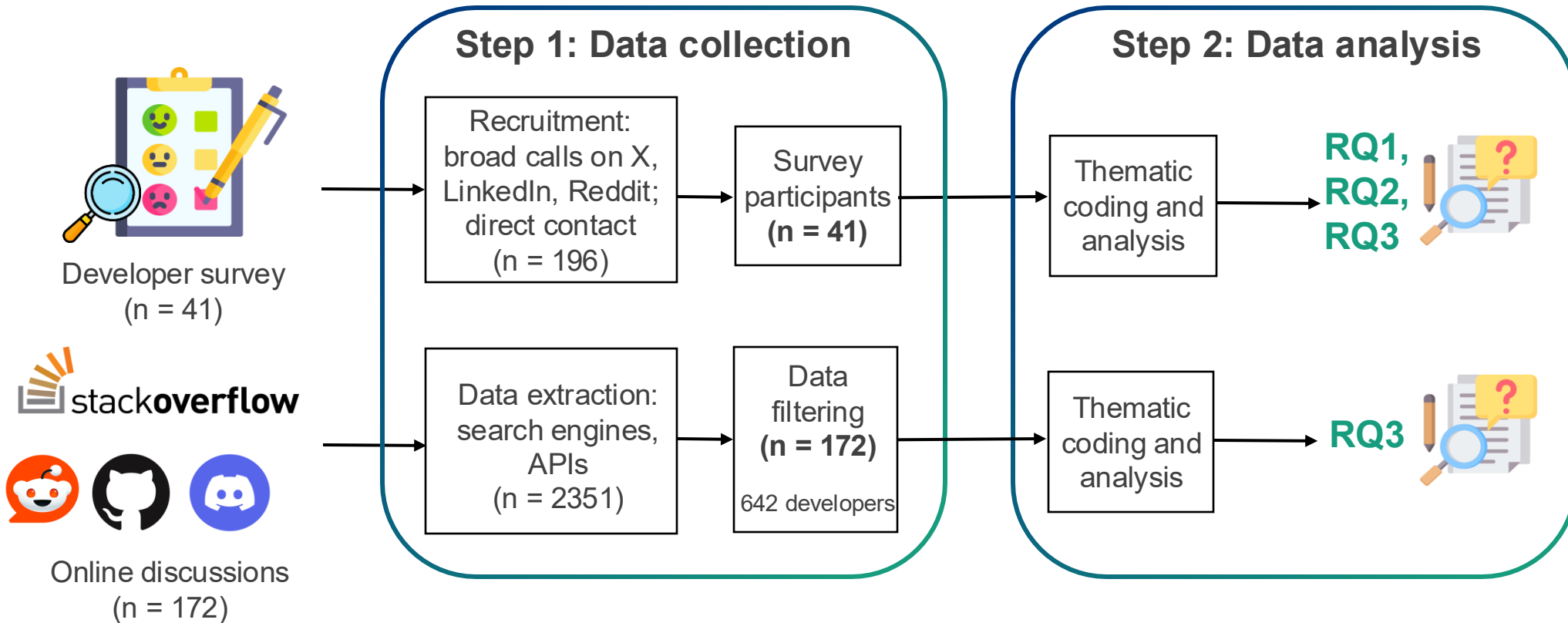
App developers struggle to accurately report data collection



Contributing factors include:

- Suboptimal design of Google's data safety form
- Lack of standardized reporting guidelines
- Insufficient tool support for data safety disclosures

Empirical Study Methodology



Phase 1: Developer Survey



- Participant Recruitment (n = 41):

- Broad calls on social media

- n = 19



- Direct contact with over 150 randomly selected Android developers

- n = 15



- Re-distributed survey to developers engaged in discussions about Android and the DSS

- n = 7



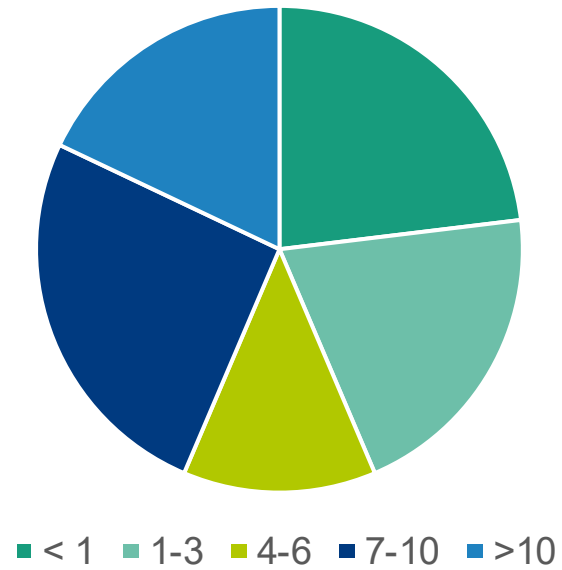


Survey Questions

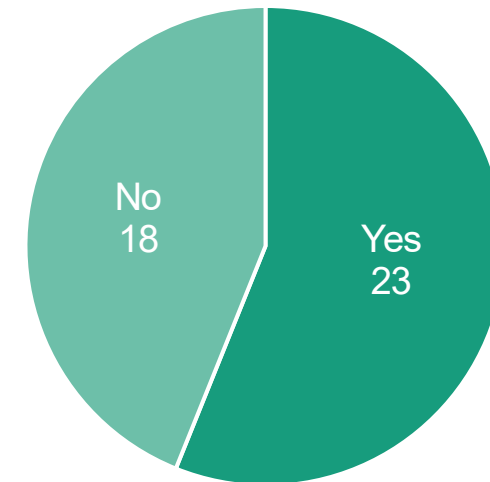
RQ	Survey Question
RQ1: methods and resources	How do you categorize the privacy-related data collected by your app for the DSS?
	What resources do you use to help you understand and complete the DSS?
RQ2: confidence levels	How well do you understand the privacy-related data your app collects (e.g., location, personal, financial) that must be disclosed in the DSS?
	How familiar are you with GDPR?
	How confident are you that your app's data collection in the DSS aligns with GDPR requirements?
	How well do you understand Google's definitions and categorizations of data types within the DSS?
	How challenging is it to fill out the Data Collection part of the DSS?
RQ3: challenges	Which aspects of the DSS do you find challenging?
	What specific challenges have you faced while filling out the DSS?
	Describe any technical or general issues you have encountered during the submission of the DSS.
	Have you ever had an app rejected due to issues with the DSS? If yes, please describe the situation.

Participant Demographics

Experience (in years)



Published app in EU



Phase 2: Analysis of online discussions



Data collection:

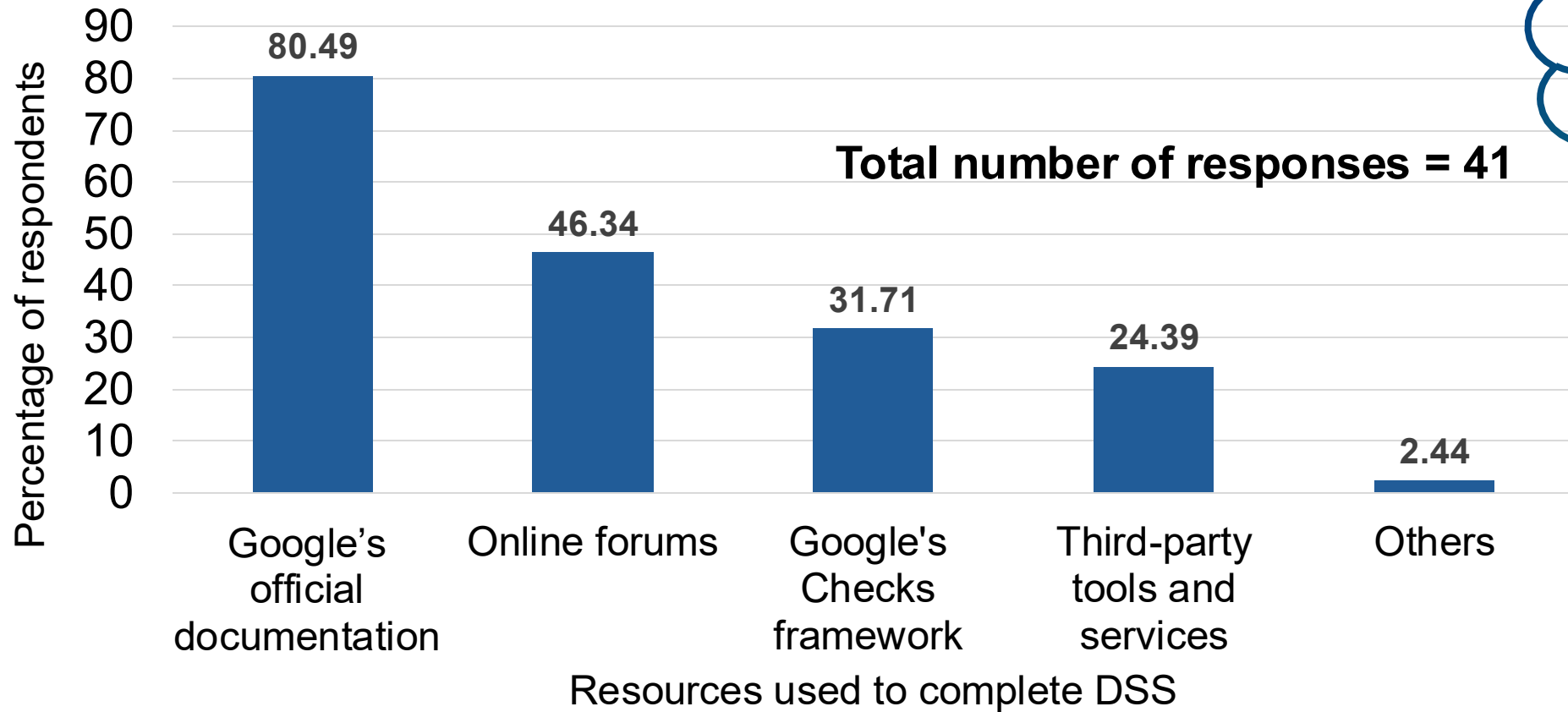
- Stack Exchange API¹ and targeted searches
- Example query:
(DSS OR “data safety section” OR “data safety form”)
- Manual filtering

Platform	Discussions	Unique developers
Stack Overflow	56	268
Reddit	65	283
Discord	28	31
GitHub	16	48
Hacker News	1	12
Total	172	642

1. Stack Exchange API: <https://api.stackexchange.com/>

Results

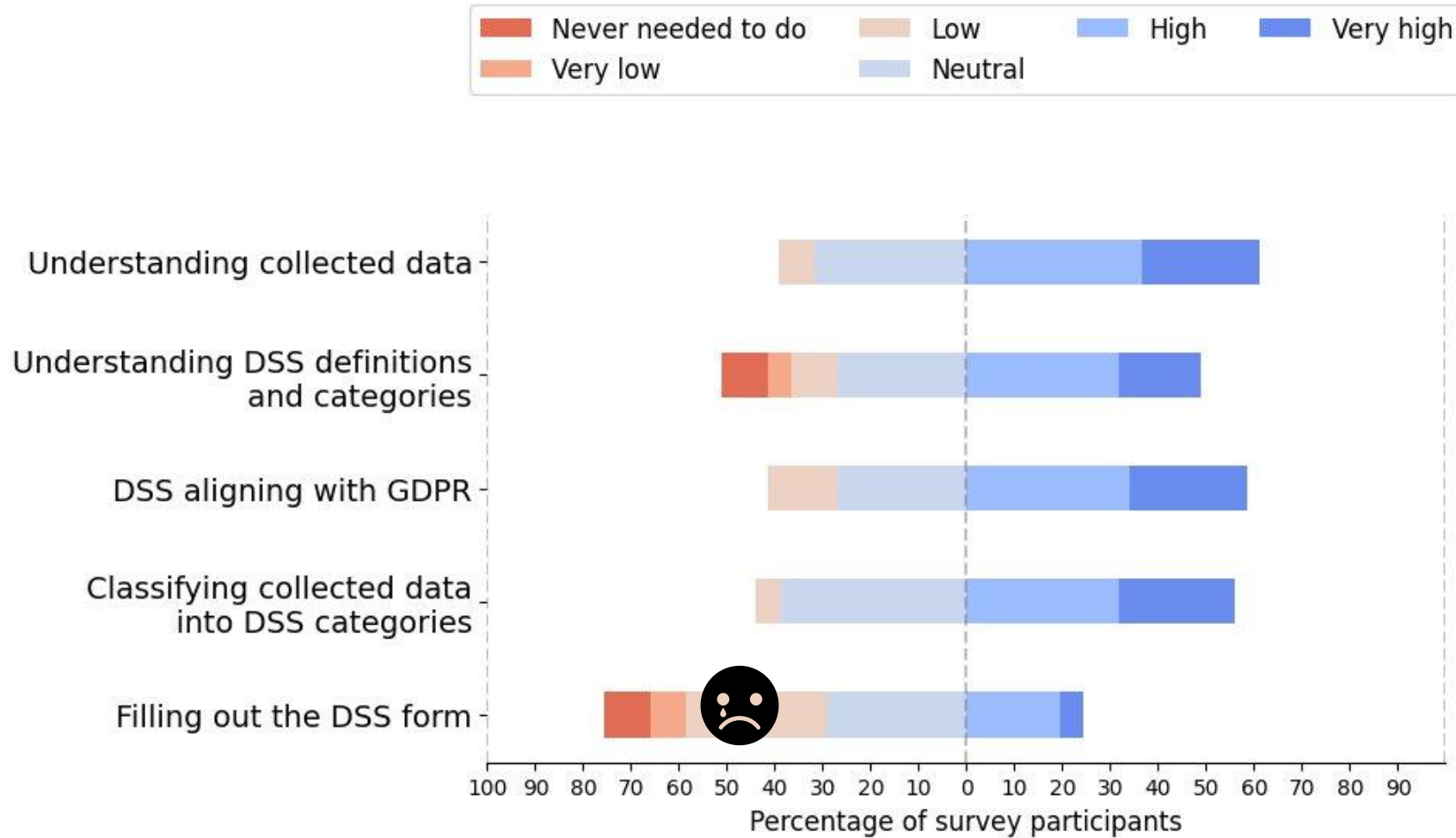
RQ1: Methods and Resources used by Developers



Developers use **existing online resources** to complete the DSS form.

Results

RQ2: Confidence Levels of Developers



Developers **lack confidence** in completing the DSS form.

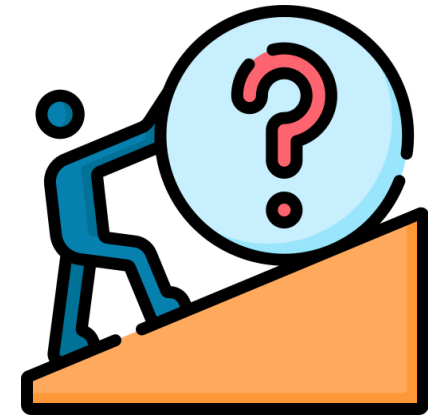
Results

RQ3: Challenges

Challenge 1: Identifying usage of privacy-relevant data to complete DSS form.

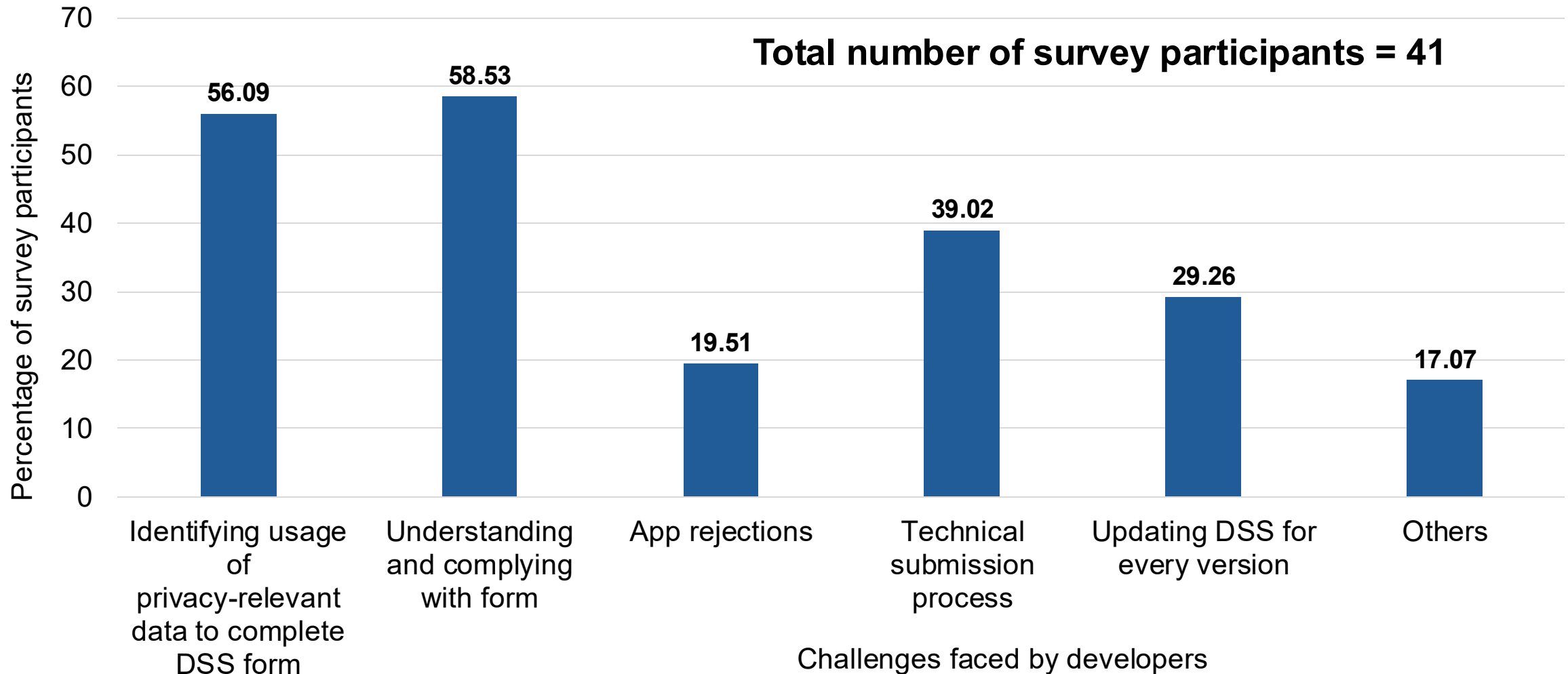
Challenge 2: Understanding and complying with DSS form.

Challenge 3: Understanding app rejections.



Results

RQ3: Challenges (Survey)



Results

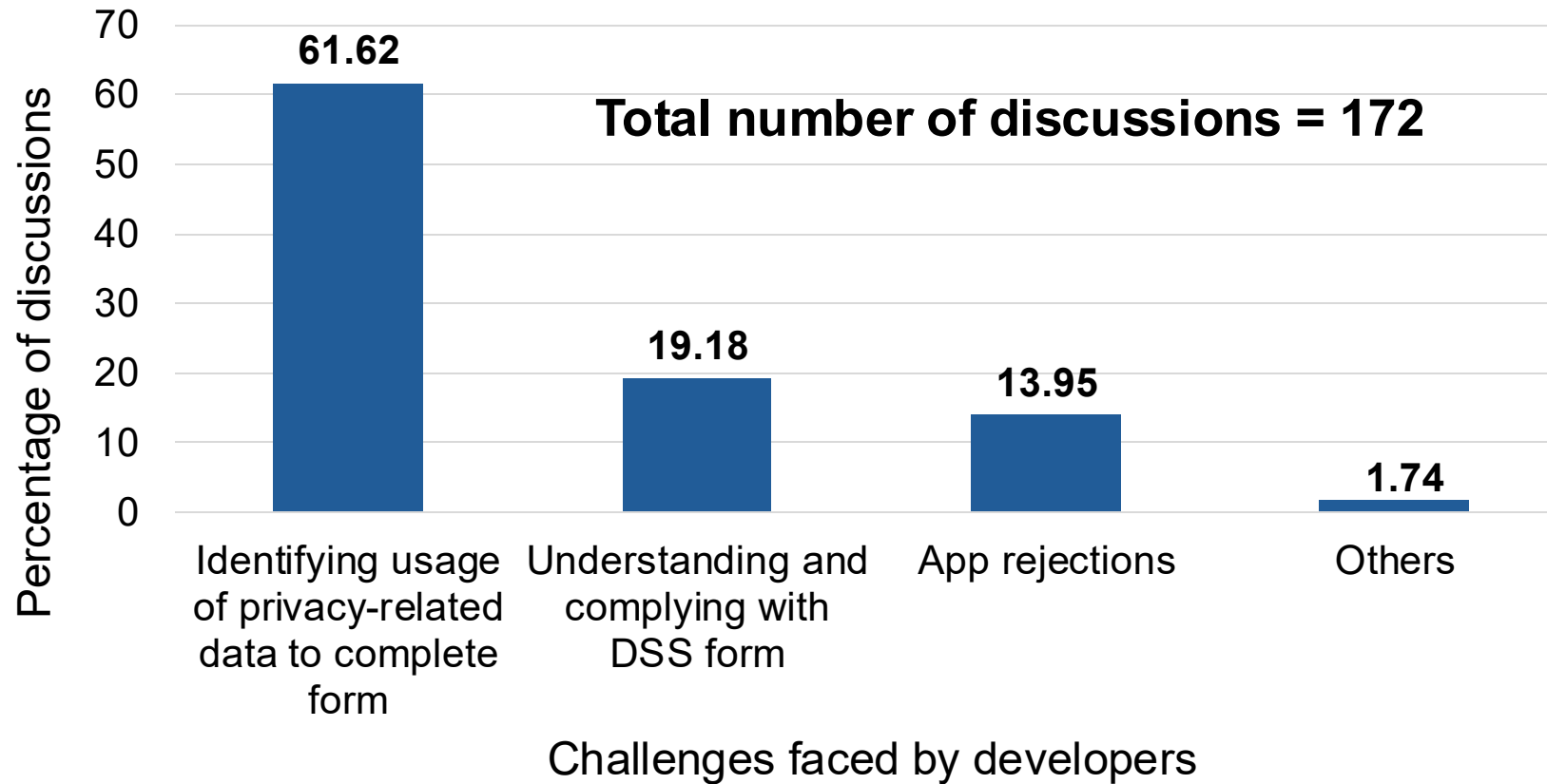
RQ3: Challenges (Online discussions)



Data Sources	Challenge 1: Identifying usage of privacy-relevant data to complete DSS form			Challenge 2: Understanding and complying with DSS form				Challenge 3: Understanding app rejections	Other challenges
	a) TPL data collection	b) Data collection	c) Data sharing	a) Confusing terminologies	b) Data deletion	c) Encryption declaration	d) Legal compliance		
Stack Overflow	15	21	0	1	0	4	0	14	1
Reddit	28	11	3	10	9	1	0	3	0
Discord	11	8	0	4	1	0	0	4	0
GitHub	11	1	3	2	1	0	0	2	2
Hacker News	0	0	0	0	0	0	0	1	0
Total across platforms (n=172)	65	41	6	17	11	5	0	24	3
Percentage (out of 172)	37.79%	23.83%	3.48%	9.88%	6.39%	2.9%	0%	13.95%	1.74%

Results

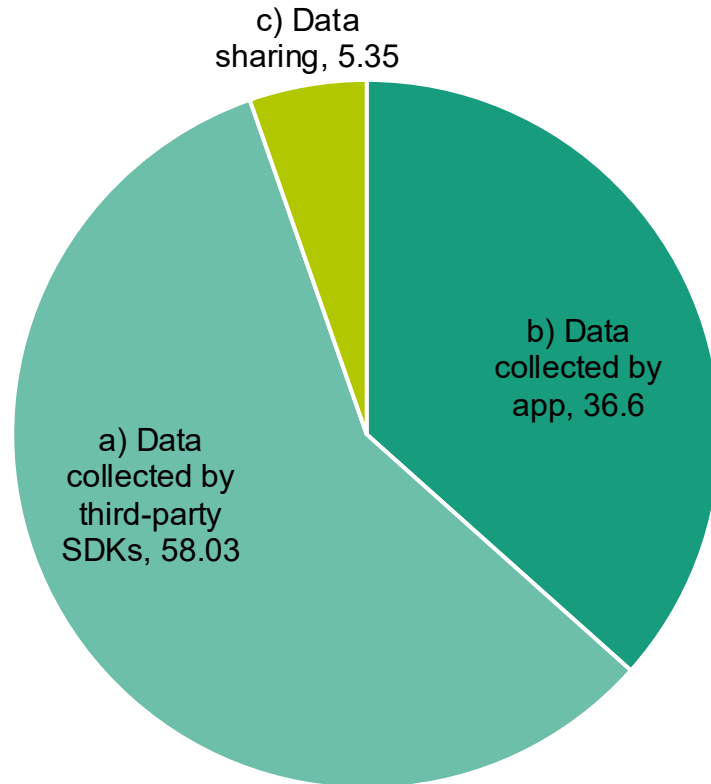
RQ3: Challenges (Online discussions)



Challenges

Identifying usage of privacy-relevant data to complete DSS form

P27: "When I use third-party libraries, I don't have full control over what's collected."



r/androiddev • 1 yr. ago
lostje89
...

A question about Google's Play Data Safety and Firebase services

How to fill in Google Play Data Safety form taking into account Firebase Analytics and Firebase Crashlytics libraries?

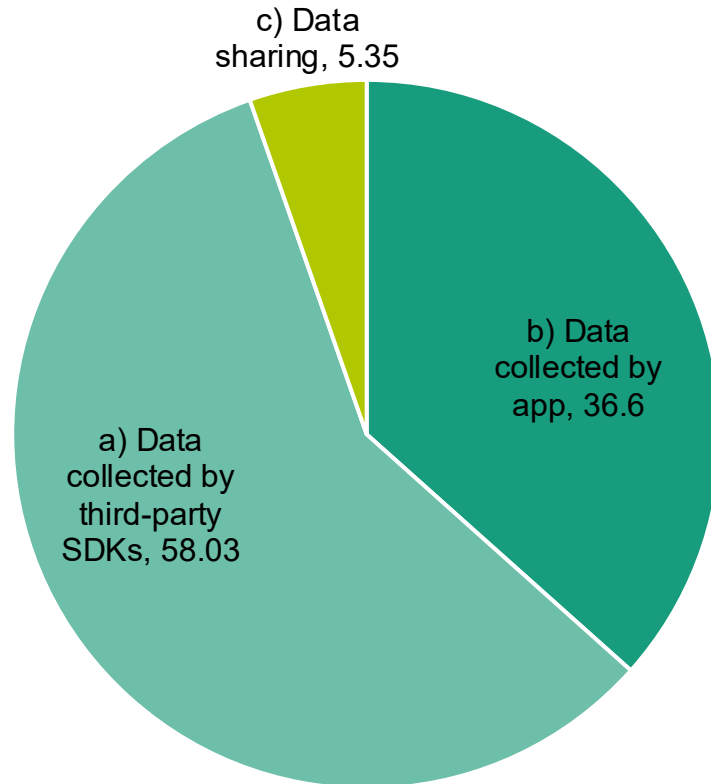
Asked 3 years, 10 months ago Modified 1 year ago Viewed 4k times Part of Google Cloud Collective

Do I need to disclose use of Google Play billing library in the data safety form?

Asked 3 years, 11 months ago Modified 3 years, 4 months ago Viewed 9k times Part of Mobile Development Collective

Challenges

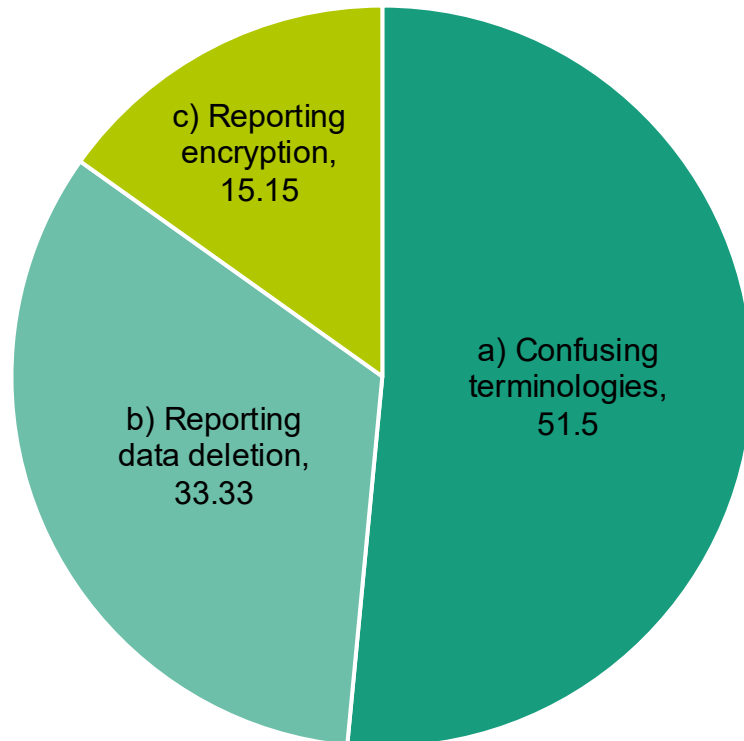
Identifying usage of privacy-relevant data to complete DSS form



	Status: Approved with Issues - Further Action Required We found issues with your app. You need to review and take action as described below, so that your app is not impacted in the future.
	Issue found: Invalid Data safety form We reviewed your app's Data safety form in Play Console and found discrepancies between it and how the app collects and shares user data. All apps are required to complete an accurate Data safety form that discloses their data collection and sharing practices - this is required even if your app does not collect any user data. We detected user data transmitted off device that you have not disclosed in your app's Data safety form as user data collected. Issue details We found an issue in the following area(s): SPLIT_BUNDLE 12: Policy Declaration - Data Safety Section: Location Data Type - Precise Location SPLIT_BUNDLE 28: Policy Declaration - Data Safety Section: Location Data Type - Precise Location About the Data safety section in Google Play User Data policy

Challenges

Understanding and complying with DSS form



r/androiddev • 4 yr. ago
Jejsung
...

Data Safety required and optional data collection

If some data collection is required only when users use certain features, then is it required data collection or optional data collection?

3
 1

 Share
 Report

r/legaladviceofftopic • 1 yr. ago
ookachuca2
...

Google Play Store "Data Safety" Documentation Interpretation

I tried posting this over on the Google Play subreddit and haven't gotten a lot of traction. Maybe what I'm asking would be better interpreted by someone who understands this kind of language? I'm only looking to understand if my understanding of what I'm reading is in the right ball park, or if I'm over analyzing. See link for associated doc.

I've reached out to Google Play support about this before but they never seem to understand my question or answer it in a way that's indirect or unrelated. Apologies for the long question and explanation of what I'm after.

r/androiddev • 4 yr. ago
another-dave
...

Another Data Safety question – Photos & Videos

Working on an app that allows users to record photos/video in-app – the photos get saved into the app's data directory.

I'm not sure if Data Safety form on Play considers this as part of "Photo" or "Video" usage, or if those options are meant purely to disclose that an app accesses your Gallery (i.e. media on your device that the app doesn't "own" itself).

Challenges

Understanding app rejections

P24: "(I was) getting threatened with having my app removed for not providing a data removal procedure, even though there is no data to be removed."

P34: "A feature that we added a long time ago to our app (in 2016) and that we forgot to mention in the DSS (caused the rejection)."


r/androiddev • 5y ago


AwkwardShake

Before filling your Data Safety form, make sure to update ALL your tracks to the latest version of your app!

Discussion

I just filled out my data safety form, and received a rejection for more than a year old APK.

	Status: App Content Approved with Issues There are issues with information you provided about your app that you'll need to look at soon. Check Play Console for the latest status of your app submission.
	Issue: Invalid Data safety section We reviewed your app's Data safety section in Play Console and found discrepancies between it and how the app collects and shares user data. All apps are required to complete an accurate Data safety section that discloses their data collection and sharing practices - this is a requirement even if your app does not collect any user data.

Triangulation reveals complementary gaps



Challenge	Survey (self-report)	Online discussions
Reporting data sharing		6 discussions (3.5%)
Reporting data deletion		11 discussions (6.4%)
Declaring encryption		5 discussions (3%)
Legal compliance	20 participants (48.8%)	

Public developer forum discussion skews toward feature feedback; legal compliance concerns surfaced only in private channels.



Related Work

DSS Reporting

DSS Accuracy

- Recent studies examine DSS submission accuracy¹.
- Mozilla² found discrepancies between DSS and privacy policies across 40 apps.
- Khandelwal et al.³ studied developer engagement via form snapshots + 3,500+ developer contacts.
- Girish et al.⁴ found many apps collect identifiers undisclosed in safety labels.

1. Rodriguez et al.'23
2. Mozilla'23
3. Khandelwal et al.'23
4. Girish et al.'25

Analyzing Online Discussions

- Prior work⁵ studies Stack Overflow / Reddit for software development practices.
- No prior work uses these communities to study DSS-reporting challenges specifically.

5. Antoniadis et al.'23; TVS'20; Li et al.'21; SSM'25

DSS-Support Tools

- Earlier accuracy studies⁶ predate mature DSS-assistive tooling.
- Since then: Google Checks⁷ (paid), Matcha⁸ (code-based label suggestions), Privado.ai⁹ (CLI DSS generation).
- Adoption, effectiveness, and remaining limitations of these tools remain largely unknown.

6. Khandelwal et al.'23; Mozilla'23
7. Google Checks'22
8. Li et al.'24 (Matcha)
9. Privado.ai

Gap: No prior work examines **how developers report** data collection, their **confidence**, or real-world **DSS-tool adoption**.

Contribution 3: Automate Privacy Assessments

C1



Detect Android data
collection

C2



Diagnose reporting
inconsistencies

C3



Automate privacy
assessments

C4



Generate reporting
documents

Evolution of Slicing Techniques

Ottenstein (1984) — Intraprocedural Slicing

Program Dependence Graph (PDG)

- Slicing using graph reachability in the PDG



adds procedure calls — summary edges give context-sensitivity

Horwitz, Reps & Binkley (1990) — Interprocedural Slicing

System Dependence Graph (SDG): per-procedure PDGs linked across calls

- Summary edges precisely model which formal-in parameters affect which formal-out parameters at a call site
- Two-pass graph traversal keeps matching calls and returns aligned (context-sensitive)



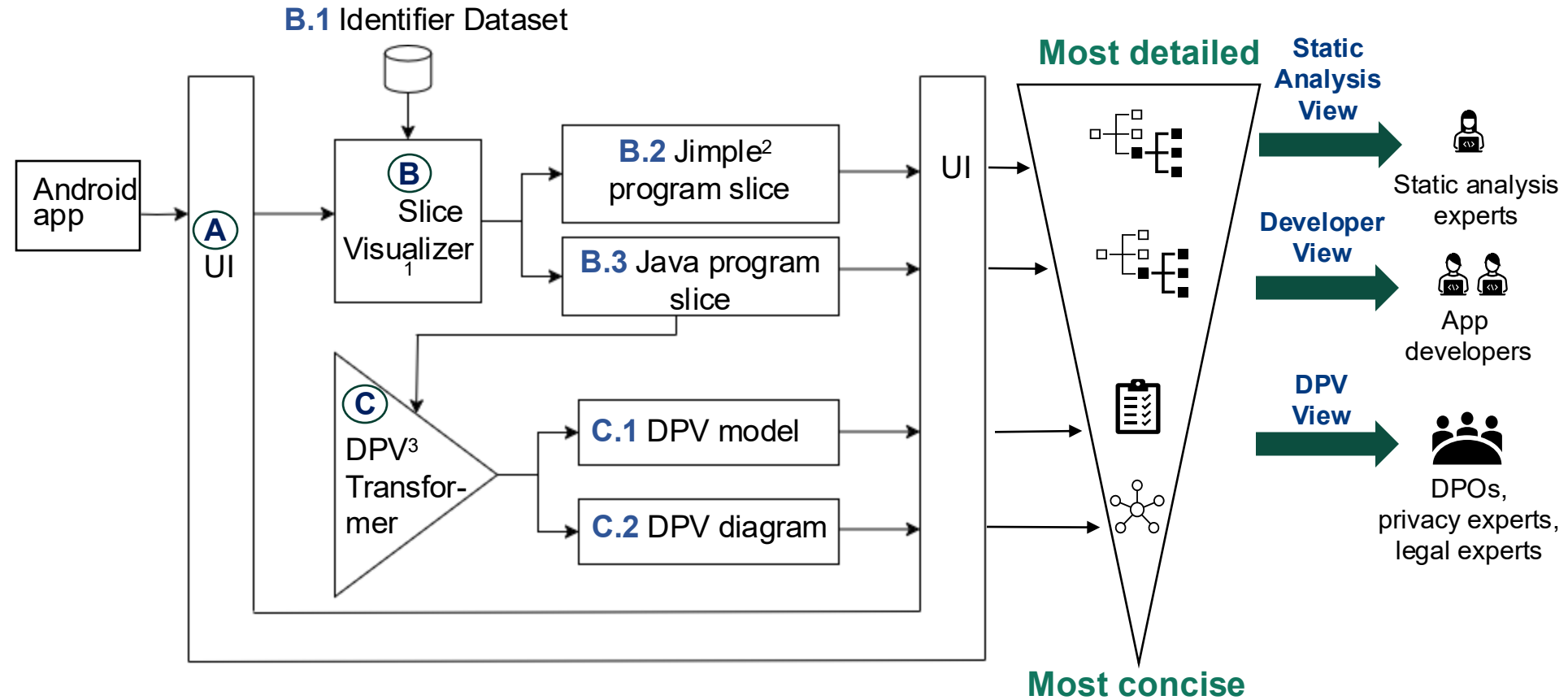
adds the Android application model — lifecycle, ICC, callbacks

Jicer (Pauck & Wehrheim, 2021) — Android-Specific Slicing

Application Dependence Graph (ADG): SDG extended for Android semantics

- Call graph: FlowDroid, enhanced for Android + Java features (lifecycle callbacks, ICC/IAC, reflection, no explicit main)
- Control dependence: Soot post-dominator analysis
- Data dependence: Soot reaching-definitions analysis
- Slicing still runs HRB's two-pass algorithm, now over the ADG

Assessor View

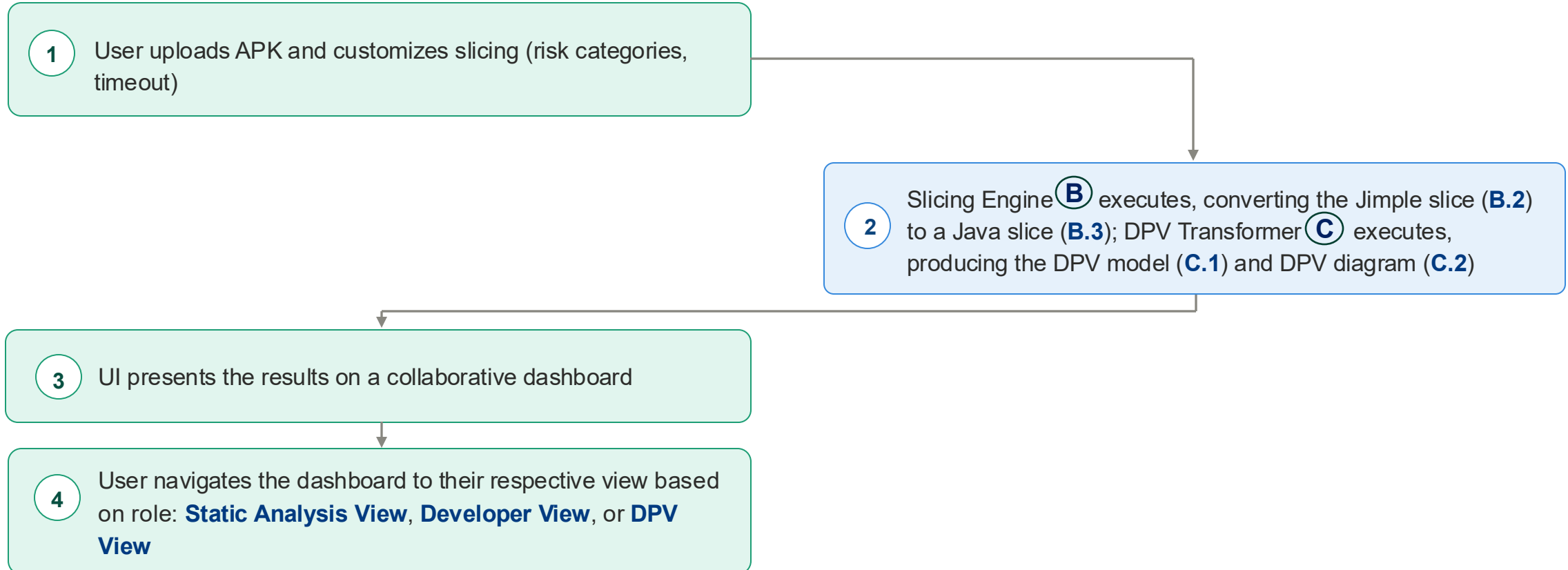


1. F. Pauck and H. Wehrheim, *Jicer: Simplifying Cooperative Android App Analysis Tasks*, 2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM), Luxembourg, 2021, pp. 187-197, doi: 10.1109/SCAM52516.2021.00031
2. Raja Vallée-Rai, Phong Co, Etienne Gagnon, Laurie Hendren, Patrick Lam, and Vijay Sundaresan. 1999. *Soot - a Java bytecode optimization framework*. In Proceedings of the 1999 Conference of the Centre for Advanced Studies on Collaborative Research (Mississauga, Ontario, Canada) (CASCON '99). IBM Press, 13.
3. Data Privacy Vocabulary: <https://w3c.github.io/dpv/2.1/dpv/>

Assessor View Workflow

Frontend **(A)**

Backend **(B)** **(C)**





Why Slicing, not Taint Analysis

Traditional Taint Analysis

e.g., FlowDroid-based tools^{1,2,3}

- Requires a predefined pair: a source AND a sink
- Answers a fixed question: *does data reach this known sink?*
- Effective for known, direct leaks to well-known sinks
- Cannot proceed without predefined sinks
- Treating every program point as a sink is not scalable in practice

Our Source-Centric Slicing

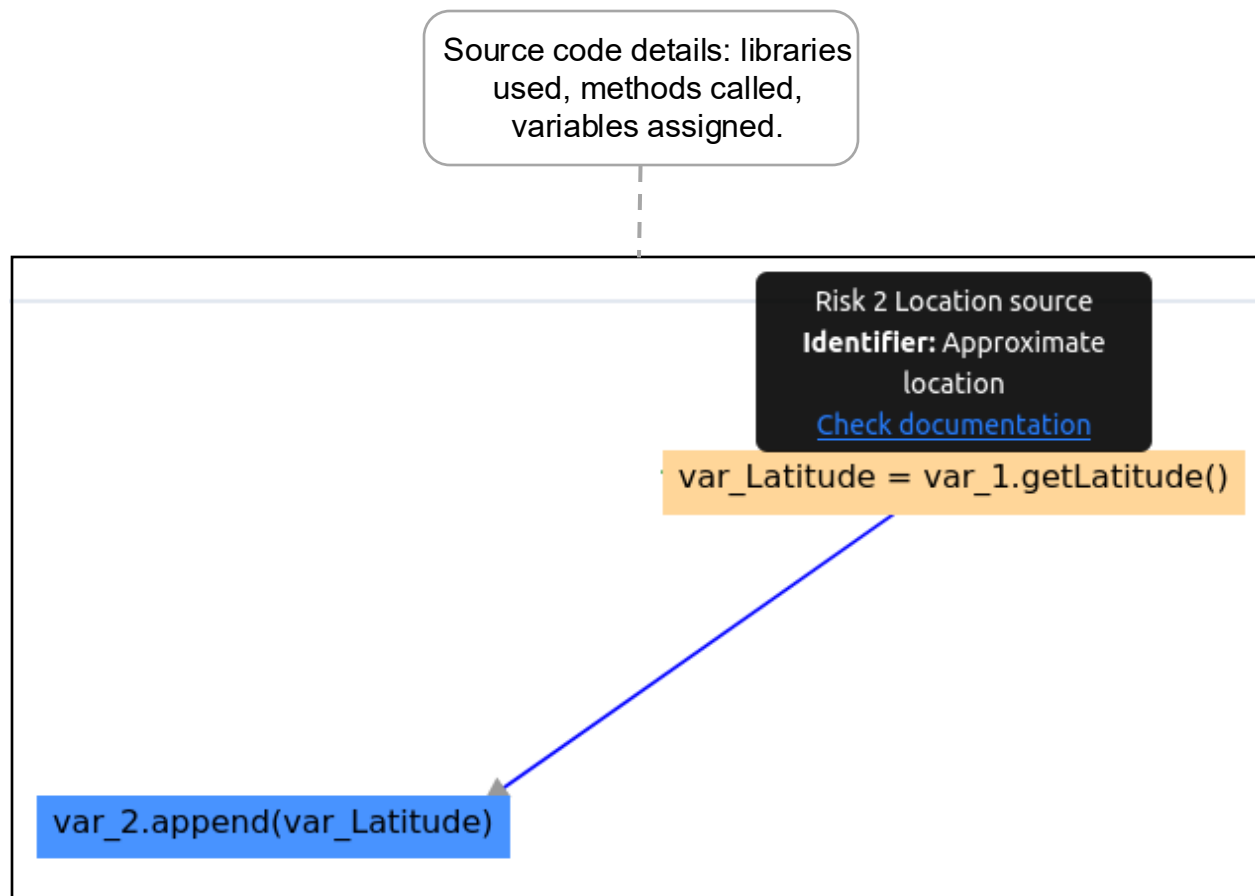
Forward slicing from known privacy-relevant sources

- Requires only a known source, no predefined sink needed
- Answers an open question: *where can this data end up?*
- Sinks are discovered as output, not given as input
- Supports broader coverage across the app's data flows
- Enables risk-based, nuanced assessment of personal data handling
- Warns about data minimization: reveals whether collected data is actually used

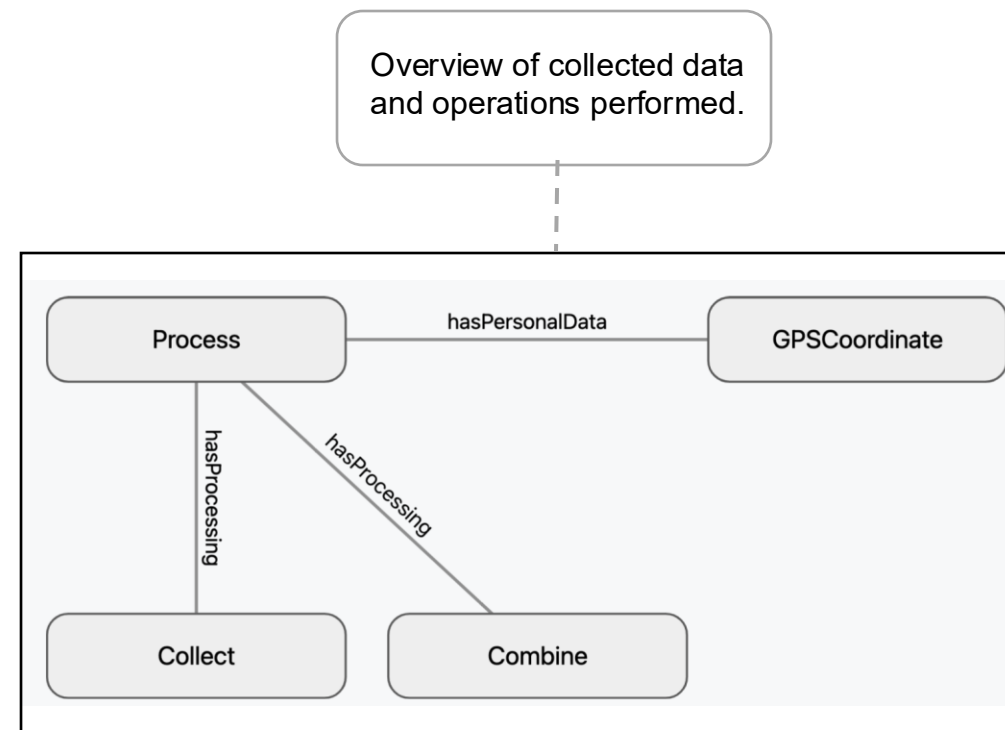
Taint analysis asks: “does data reach this sink?” Slicing asks: “where does data from this source go?”

1. Ke Mao, Cons Ahs, Sopot Cela, Dino Distefano, Nick Gardner, Radu Grigore, Per Gustafsson, Ákos Hajdu, Timotej Kapus, Matteo Marescotti, Gabriela Cunha Sampaio, and Thibault Suzanne. 2024. PrivacyCAT: Privacy-Aware Code Analysis at Scale. In Proceedings of the 46th International Conference on Software Engineering: Software Engineering in Practice (Lisbon, Portugal) (ICSE-SEIP '24), 106–117. <https://doi.org/10.1145/3639477.3639742>
2. Zeya Tan and Wei Song. 2023. PTPDroid: Detecting Violated User Privacy Disclosures to Third-Parties of Android Apps. In 2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE). 473–485. <https://doi.org/10.1109/ICSE48619.2023.00050>
3. Kaifu Zhao, Xian Zhan, Le Yu, Shiyao Zhou, Hao Zhou, Xiapu Luo, Haoyu Wang, and Yepang Liu. 2023. Demystifying Privacy Policy of Third-Party Libraries in Mobile Apps. <https://doi.org/10.48550/ARXIV.2301.12348>

Views



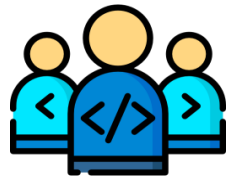
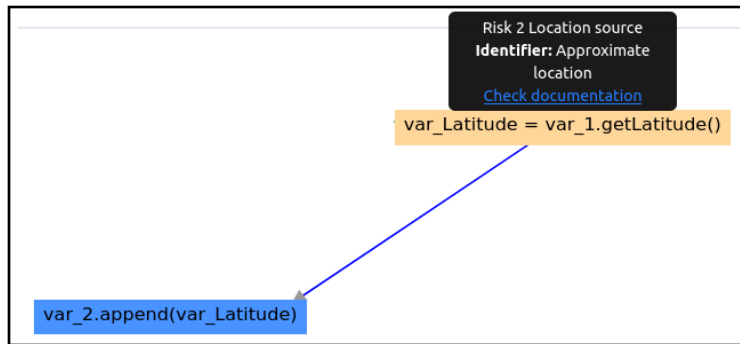
Developer View: Java program slice



DPV View: DPV diagram (most concise)

Automating Privacy Assessments with Assessor View

Developer View

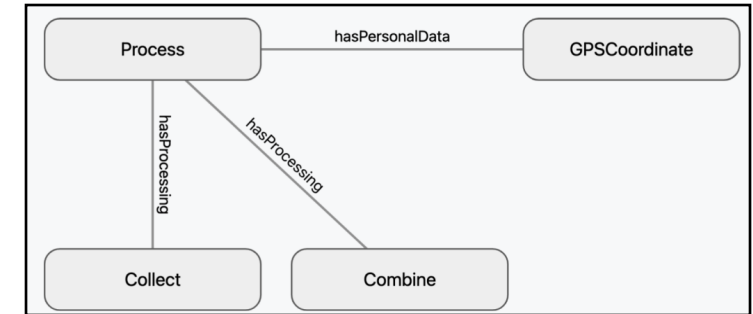


App developers

Do not need to manually explain code

1. **ap:** Droid **dpv:** Process ;
2. **dpv:hasPersonalData** *pd: Tracking, pd: Location, pd: GPSCoordinate*
3. **dpv: hasProcessing** 1. *dpv:Collect* ; 2. *dpv:Combine* ;

DPV View

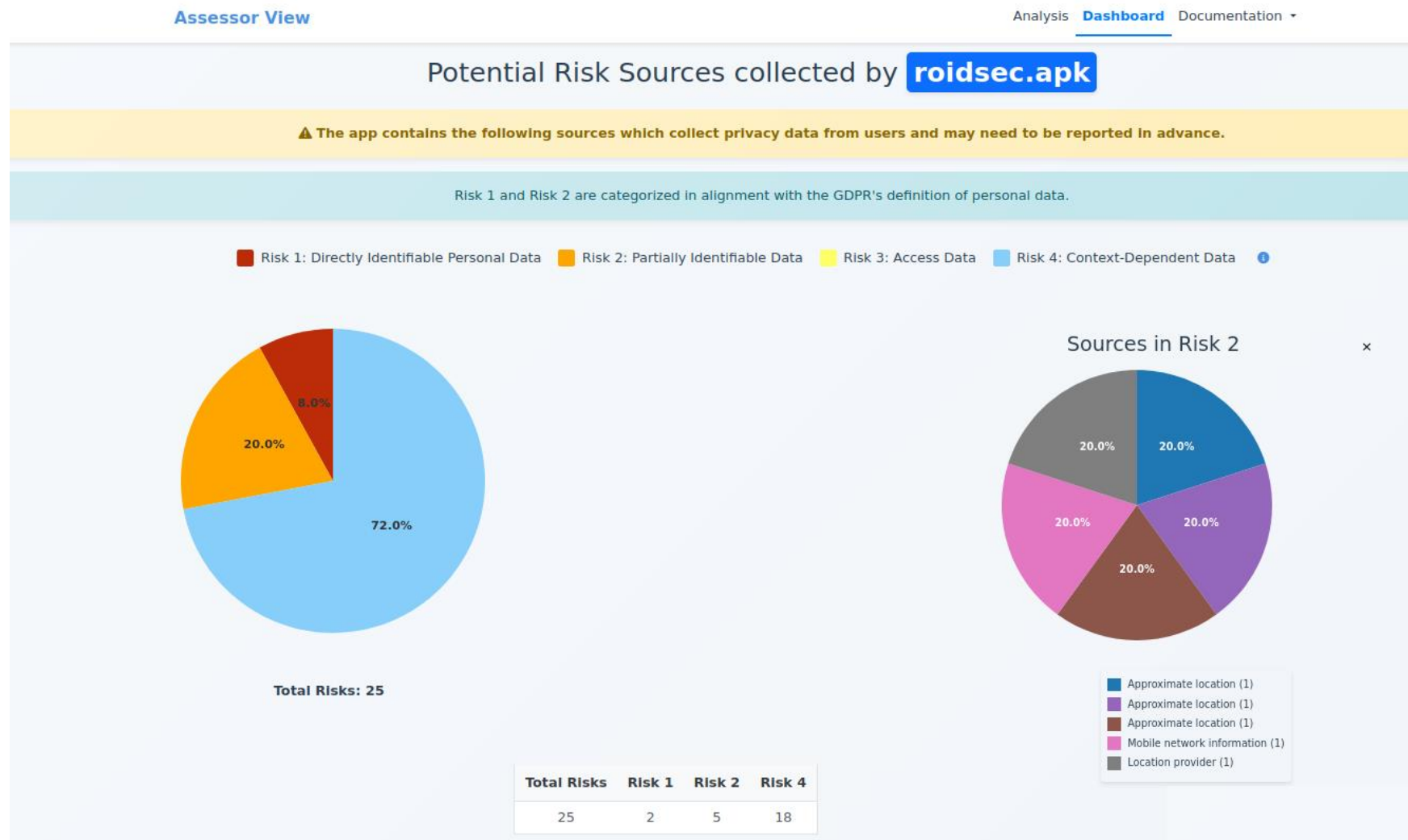


Can switch between different views to ask specific questions



Privacy professionals (DPOs, legal experts)

Assessor View Dashboard



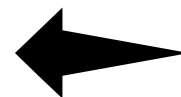
Assessor View Dashboard

Risk 1

Source ⓘ	Warning Scale ⓘ↕	Graph Views ⓘ	GDPR Warning ⓘ	Assessment Flag
Device ID	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Phone number	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼

Risk 2

Source ⓘ	Warning Scale ⓘ↕	Graph Views ⓘ	GDPR Warning ⓘ	Assessment Flag
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼
Approximate location	A B C D E F	DPV View Developer View Static Analysis View	No Technical Measures	Not Assigned ▼





Jimple-to-Java-like Conversion: Current Coverage

Assessor View transforms key Jimple statements into Java-like representations. These are the statement types most commonly involved in data flows, and hardest to interpret in raw Jimple.

Invoke statements

Assignment statements

If statements

Return statements

Binary expressions

Invoke expressions

Array variables

Why these statements

Recent research¹ shows function calls, expression statements, if-statements, and declaration statements implement the privacy behaviors of Android apps - exactly the categories this translation targets.

1. Chia-Yi Su, Aakash Bansal, Vijayanta Jain, et al. Which Code Statements Implement Privacy Behaviors in Android Applications? 2025. arXiv: 2503.02091 [cs.SE]

Ongoing work: actively expanding the Jimple ↔ Java mapping to improve Developer View coverage and reduce failure cases.



Implementation: Mapping between Source Code and DPV Concepts

Developer View DPV View	
Source code statement	Mapped DPV concepts
API methods from the Identifier Dataset	dpv:HasPersonalData → <pd:identifier> dpv:HasProcessing dpv:Collect
Pseudonymization method	dpv:hasTechnicalMeasure <encryption OR others>
Assignment statement	dpv:HasProcessing dpv:Copy
Input output retrieval method	dpv:HasProcessing dpv:Retrieve
String manipulation method (eg., append(), concat())	dpv:HasProcessing dpv:Combine
Input output access method	dpv:HasProcessing dpv:Access
Database traversal method	dpv:HasProcessing dpv:Query
String replacement method (eg., replace())	dpv:HasProcessing dpv:Modify

Implementation: Mapping between Source Code and DPV Concepts



Mapping between Developer and DPV View

Hide

Developer View Node	Privacy Relevance	Mapped DPV Concepts
argVar_1 = var_3.getLatitude()	Risk 2 Location source	dpv:Collect
var_2.append(argVar_1)	String manipulation method	dpv:Combine

</> Take me to the Developer View



Implementation: Warning Scale

For developers

Level	Color	Risk	Program Slice Property	Legal Implication
A	Green	Very low risk	Data collection, but no processing operations.	Possibility of data <i>minimization</i> (GDPR Article §4 ¹)
B	Green	Low risk	Data collection and string manipulations, but no other processing operations.	Possibility of data <i>minimization</i> (GDPR Article §4 ¹)
C	Yellow	Moderate privacy risk	At least one data storage or processing operation.	• Ensure data protection (GDPR Article §25²) • Document data <i>usage</i> (GDPR Article §13³)
D	Yellow	Significant privacy risk	Multiple data storage or processing operations.	• Ensure data protection (GDPR Article §25²) • Document data <i>usage</i> (GDPR Article §13³)
E	Red	High privacy risk	Data shared with third-party APIs at least once.	• Ensure data protection (GDPR Article §25²) • Document data <i>sharing</i> (GDPR Article §13³)
F	Red	Very high privacy risk	Data shared with third-party APIs multiple times.	• Ensure data protection (GDPR Article §25²) • Document data <i>sharing</i> (GDPR Article §13³)

1. <https://gdpr-info.eu/art-4-gdpr/>
2. <https://gdpr-info.eu/art-25-gdpr/>
3. <https://gdpr-info.eu/art-13-gdpr/>



Implementation: GDPR rules and Warnings

For privacy assessors

Rule	Program Slice Property	Warning	Legal Recommendation
1	Data collection	• App code collects data. • Ensure transparency by reporting this data collection through privacy policy and Google Play Store's Data Safety Section.	Check reporting documents to adhere to GDPR Article §13 ¹ .
2	Data collection but no processing operations	• App code collects data but may not be processing it. • Ensure that data collection is necessary.	Potential violation of GDPR Article §5 ² .
3	Processing of data in the absence of technical measures	App code collects and processes data, in the absence of technical measures (pseudonymization).	Potential violation of GDPR Article §25 ³ .
4	Processing of data after implementing technical measures	App code collects and processes data, but only after implementing technical measures (pseudonymization).	Potential adherence to GDPR Article §25.
5	Processing of data before implementing technical measures	App code collects and processes data, before the implementation of technical measures (pseudonymization).	Potential violation of GDPR Article §25.

1. <https://gdpr-info.eu/art-13-gdpr/>

2. <https://gdpr-info.eu/art-5-gdpr/>

3. <https://gdpr-info.eu/art-25-gdpr/>

Implementation: GDPR rules and Warnings

1. Data collection

⚠ This part of the app code is collecting data. Please ensure transparency by reporting this data collection through the privacy policy and Google Play Store's data safety section.

Legal Recommendation: Check reporting documents to decide adherence to Article 13 (GDPR).

Severity: Medium

[Read more on GDPR \(Article 13\)](#)

3. Processing of data in the absence of technical measures

⚠ This part of the app code is collecting and processing data, in the absence of technical measures (pseudonymization).

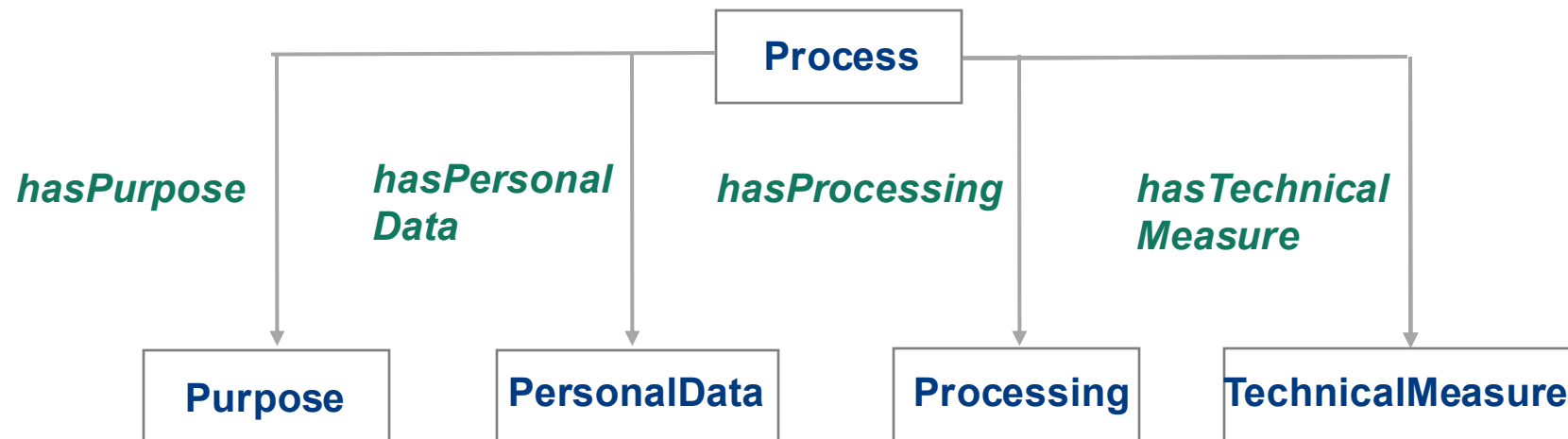
Legal Recommendation: Violation of Article 25 (GDPR).

Severity: High

[Read more on GDPR \(Article 25\)](#)

Data Privacy Vocabulary

- Vocabulary developed by World Wide Web Consortium's Data Privacy Vocabularies and Controls Group¹.
- Uses a set of top-level core concepts to specify a use case.
- Child concepts provide refinements.
- Relationship between **concepts** represented by *predicates*.
- The concept **Process** represents how multiple core concepts are combined and applied within a particular use case.
- Example core concepts:



1. <https://w3c-cg.github.io/dpv/>

Choice of DPV for Assessor View

- Assessor View currently supports DPV 2.0¹.
- DPV was chosen since it is one of the most well-maintained standard vocabularies.
- DPVCG releases new versions every 6 months:
*"In applying DPV to resources, you want the latest legal implications and interpretations, and that is only possible if you advance the vocabulary. So we plan to release a **new version approximately every 6 months**. Any fixes or such will get adopted into that version." - P03 (member of DPVCG²)*
- On the choice of DPV:
*"I wouldn't rely on it (DPV) to be the perfect dictionary, but it's a very good start, and **I don't know of any better (standard vocabulary) at the moment.**" - P07 (Privacy researcher)*

1. <https://w3c-cg.github.io/dpv/2.0/>
2. <https://w3c-cg.github.io/dpv/>

Examples of DPV Models

```
1. ex:App dpv:Process ;
2. dpv:hasPersonalData pd:Phone ;
3. dpv:hasProcessing 1.dpv:Collect ;
4. dpv:hasTechnicalMeasure
   dpv:2.HashFunction .
```

- Phone number collected and hashed.
- Uses a technical measure before processing data.
- Adheres to GDPR Article 25¹.



1. <https://gdpr-info.eu/art-25-gdpr/>
2. <https://gdpr-info.eu/art-5-gdpr/>

```
1. ex:App dpv:Process ;
2. dpv:hasPersonalData pd:Email ;
3. Dpv:hasDataSource dpv:ThirdParty ;
4. dpv:hasProcessing 1.dpv:Collect,
   2.dpv:Store ;
```

- Email address collected by Google Play Services (third party library) and written to Google storage.
- No technical measure before processing data.
- Violates GDPR Article 25¹.
- Third party collection should adhere to GDPR Article 5².



DPV: Real-World App Examples

Stellarium - Star Map

Noctua Software

In-app purchases

4.8★

329K reviews ⓘ

10M+

Downloads



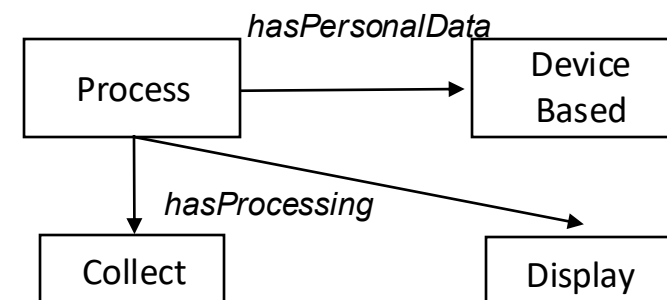
Editors' Choice



DPV Model

1. ex:Stellarium dpv:Process ;
2. dpv:hasPersonalData
- pd:DeviceBased ;
3. dpv:hasProcessing 1.dpv:Collect,
- 2.dpv: Display .

DPV Diagram



No technical measure before processing data.



DPV: Real-World App Examples

Steam

Valve Corporation

3.1★
1.08M reviews ⓘ

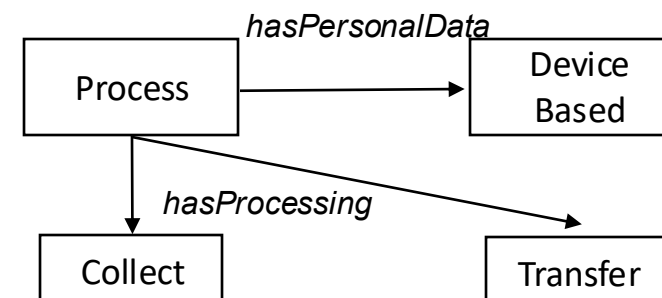
100M+
Downloads



DPV Model

1. ex:Steam dpv:Process ;
2. dpv:hasPersonalData
pd:DeviceBased ;
3. dpv:hasProcessing 1.dpv:Collect,
2.dpv: Transfer .

DPV Diagram



No technical measure before processing data.





Early Experiments: Control Dependencies

App	LOC	With control dependencies			Without control dependencies		
		Avg nodes in ADG	Time taken (in s)		Avg nodes in ADG	Time taken (in s)	
			Building ADG	Slicing ADG		Building ADG	Slicing ADG
Roidsec	745	1599	3.2	0.2	29	3.1	0.2
Tetus	2714	997	0.6	0.5	149	0.5	0.5
Backflash	20965	680	3.5	1.6	109	3.3	0.9
Scipiex	30041	10686	14.2	4	7429	10.9	3.8
Beita_com_beita_contact	30918	10113	4.4	4.6	7421	4.4	4.1
Samsapo	37482	524	1.3	0.2	48	1.2	0.2
Save_me	130504	8845	13.9	7.8	21	12.7	6.8



Correctness Checks

51 benchmark apps · Ubuntu 20.04.2 · Intel i7-10850H (6 cores)

Slicing

DroidBench

18 / 18

*test cases matched documented behavior —
no discrepancies*

- At least one test case selected per microbenchmark category
- Avg. 34.38s per test case

DPV Mapping

DroidBench

95.9%

*concepts correctly mapped (281 of 293,
manually inspected)*

- Remaining 12 cases are intentional over-approximations — return & complex statements conservatively matched to dpv:Processing by design, not errors
- Avg. 34.38s per test case

Source Detection

TaintBench

100%

of detected sources matched the ground truth

- 33 of 39 apps selected — all under 100K LOC, keeping sources comparable against ground truth
- Avg. 39.10s per app



Correctness Checks

App name	LOC	Time elapsed (s)
sms_send_locker_qqmagic	113	34
proxy_samp	1032	33
overlaylocker2_android_samp	8314	36
phospy	11,792	35
threatjapan_uracto	17,115	35
stels_flashplayer_android_update	18,358	35
fakeappstore	26,045	35
scipiex	30,041	157
Jollyserv	33,128	40
smssend_packageInstaller	37,495	35
overlay_android_samp	55,393	35
fakemart	70,008	37

Limitations of Assessor View

1 Dataset coverage

The dataset includes widely used third-party libraries across categories but may not cover all libraries used in Android apps. Identifiability levels are GDPR-specific and may vary across domains and compliance regimes.

2 Obfuscation

Assessor View matches ADG method signatures via keyword matching, so renamed third-party API calls under obfuscation are not detected. It is designed as a proactive measure applied before name mangling or obfuscation occurs.

3 Slice scalability & interpretability

Real-world slices often exceed 100 nodes, too large for meaningful manual interpretation. Current evaluation is restricted to controlled benchmarks: DroidBench micro-apps and TaintBench.

4 Manual DPV mapping

The Developer View-to-DPV mapping was performed manually, grounded in DPV documentation and refined with feedback from the DPV maintenance group¹. It currently supports DPV 2.0 and is modular but not self-updating.

5 No GDPR detection benchmark

The underlying slicing algorithm was verified against DroidBench and TaintBench, but no established benchmark exists for precision/recall of GDPR-specific rule detection.

1. <https://www.w3.org/groups/cg/dpvcg/>

Two Distinct Limitations

① Developer View — UX ceiling

At 100+ node slices, Developer View **still renders a graph...**

But density makes it unreadable: overlapping labels, crossing edges, no visual hierarchy, and a slower browser.

Nature of failure: Scalability

② Jicer — runtime crash

On APKs > 100k LOC, Jicer throws an **unrecoverable NullPointerException** during ADG-based forward slicing.

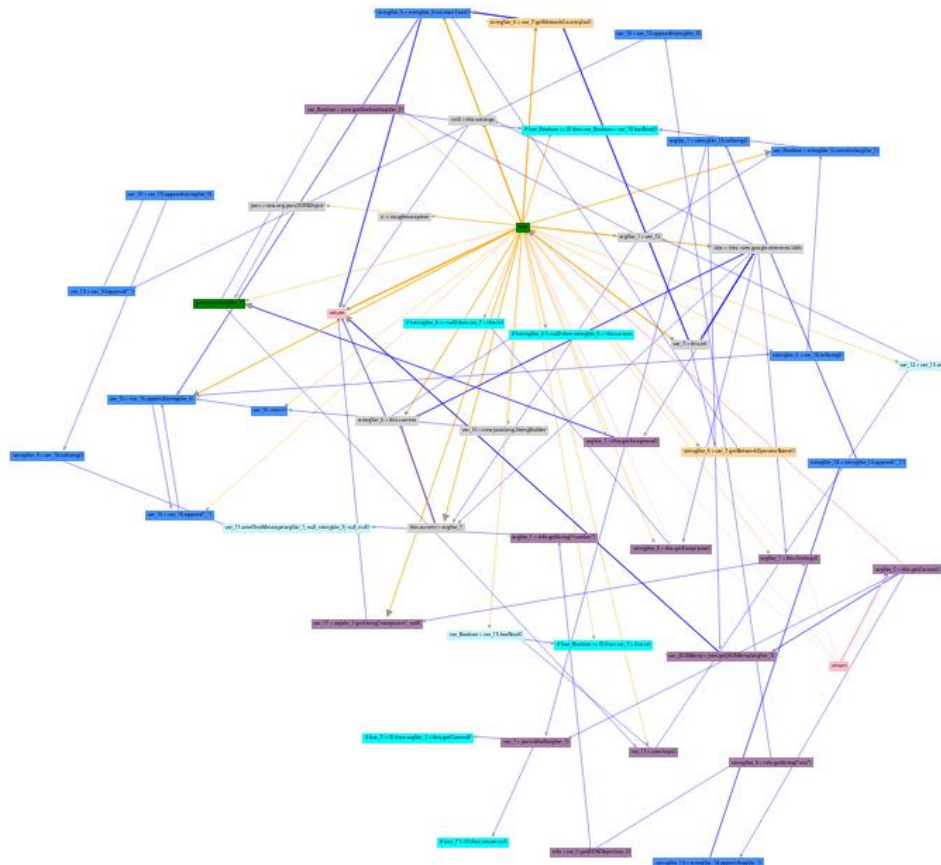
Jimple-to-Java-like mapping is not yet exhaustive.
Larger, more complex apps contain statement patterns outside current coverage (e.g. certain optimized if-constructs) — this triggers the Soot conversion failure behind the Jicer crash.

Nature of failure: Analysis-engine robustness

Limitations of Assessor View: UI Scalability

Developer View at 100+ nodes: renders, but not usable

Privacy Flow Graph for the Risk Source: getNetworkCountryIso()



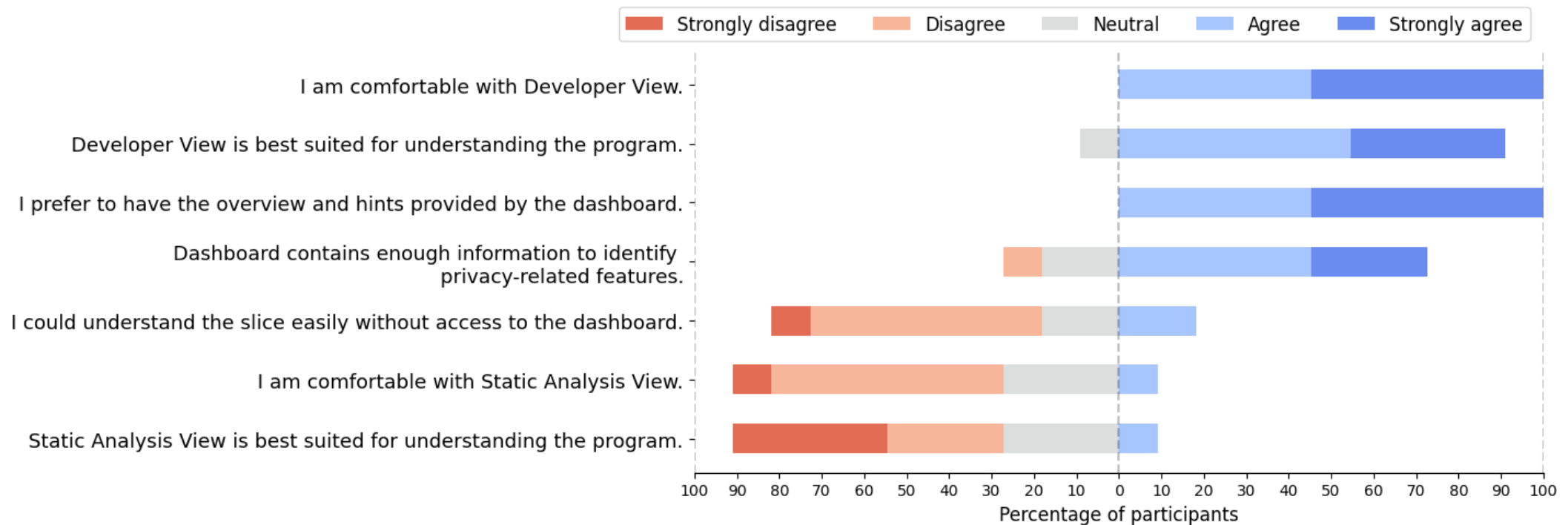
Privacy Flow Graph for getNetworkCountryIso()

Single risk source, one app.

- Graph renders successfully (no crash)
- Overlapping edges and labels at this density
- Colour-coded edges become unreadable at scale
- Browser responsiveness degrades further as node count grows

Developer View: Task-Based User Study

Participants' experience with the Developer View





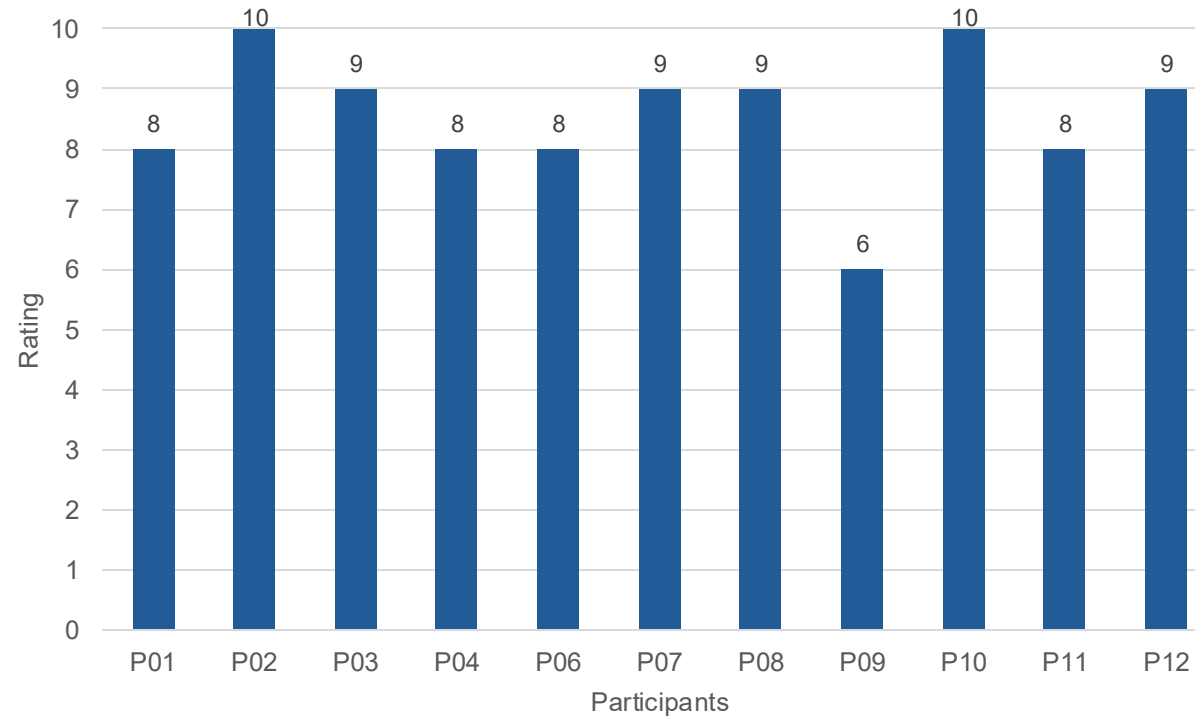
Developer View: Participant Experience

Filled circles represent expertise levels on a Likert scale from 1 (Beginner) to 5 (Expert)

Participant	Android app development	Java development	Jimple understanding	Familiarity with static analysis tools	Graph visualization	Data privacy	GDPR	Java dev experience (yrs)
P01	●●○○○	●●●○○	●○○○○	●○○○○	●●●○○	●●●○○	●●●○○	1
P02	●●●●○	●●●○○	●○○○○	●●○○○	●●○○○	●●●○○	●○○○○	1.5
P03	●●●○○	●●●○○	●○○○○	●●○○○	●●○○○	●●●○○	●●●○○	3
P04	●○○○○	●●●○○	●●●○○	●●○○○	●●●●○	●●●●○	●●●●○	1
P06	●○○○○	●●●●○	●●●○○	●●●○○	●●●○○	●●●○○	●●●○○	5
P07	●○○○○	●●●○○	●●○○○	●○○○○	●●○○○	●●○○○	●○○○○	1.5
P08	●○○○○	●●●○○	●○○○○	●●○○○	●●○○○	●○○○○	●○○○○	3
P09	●○○○○	●●○○○	●●●○○	●●○○○	●●○○○	●●●○○	●○○○○	1
P10	●●●○○	●●●○○	●●○○○	●○○○○	●●●○○	●●●○○	●●○○○	1
P11	●○○○○	●●●○○	●●○○○	●●○○○	●●●●○	●●●○○	●●●○○	0
P12	●○○○○	●●●○○	●○○○○	●○○○○	●●●○○	●●●○○	●●●○○	1

Developer View: Task-Based User Study

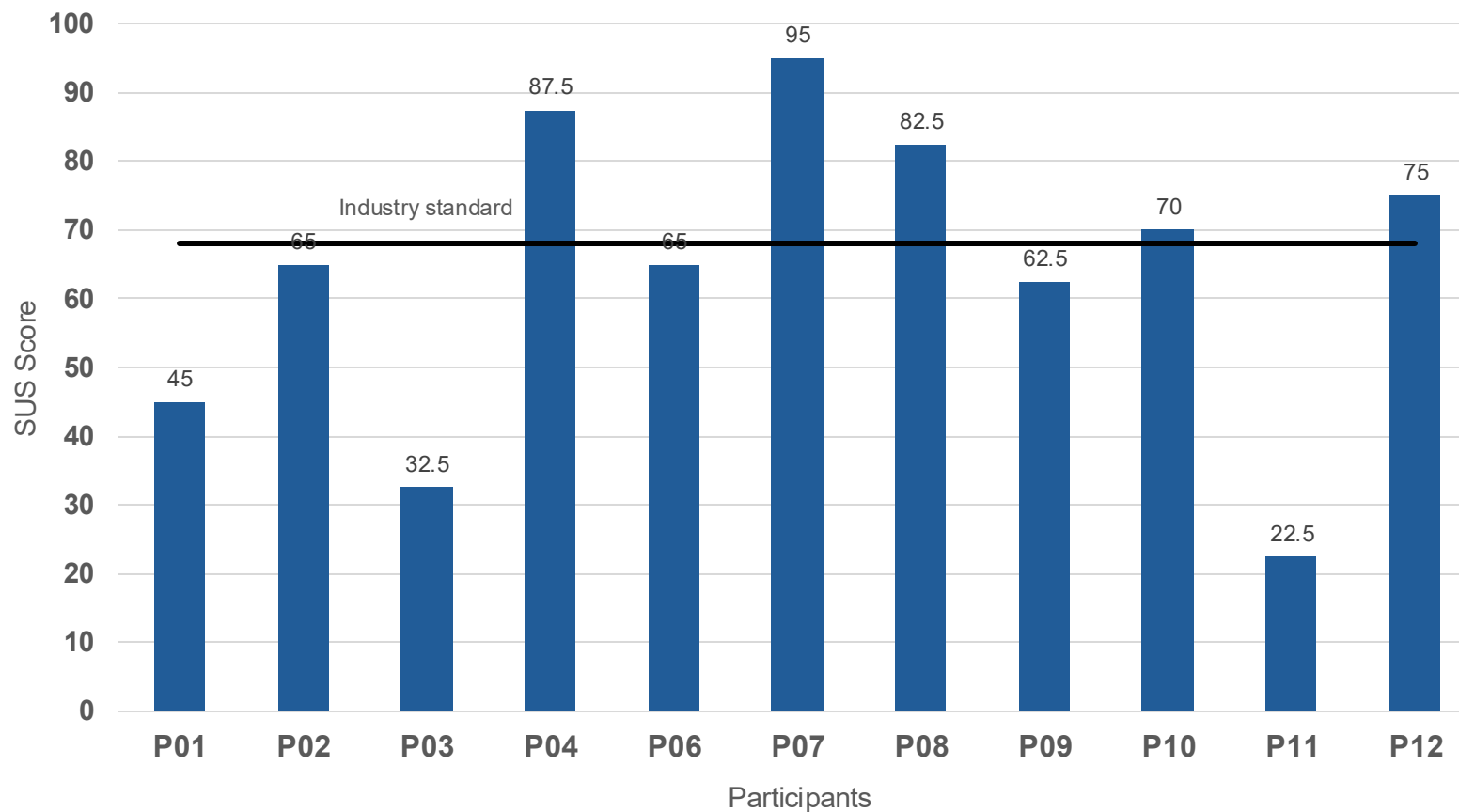
How likely is it you would recommend Developer View to an app developer?



Participant ratings. (0: not recommended, 10: highly recommended)

Developer View: Task-Based User Study

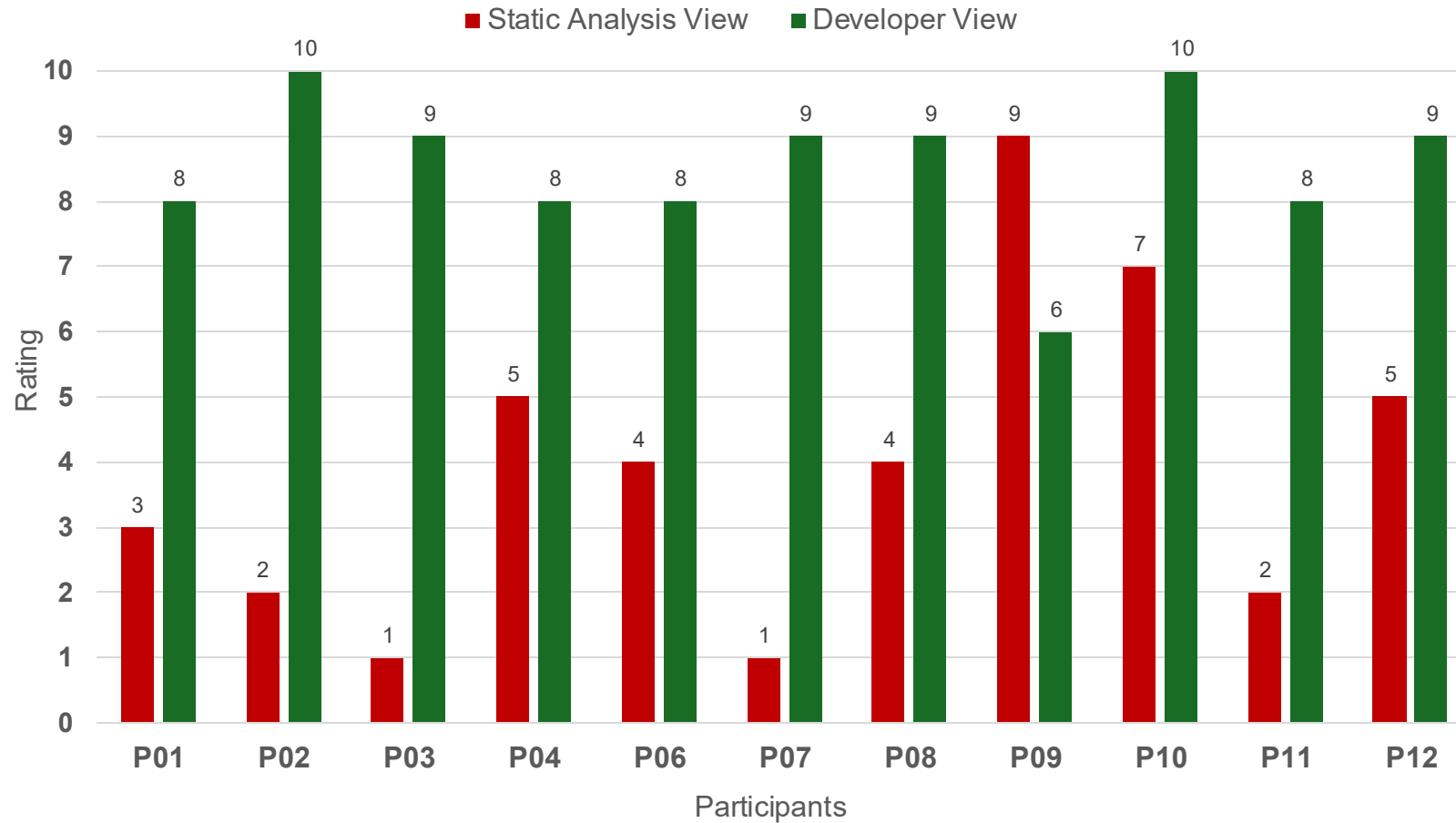
Usability Scores



Average usability score = **63.96**

Developer View: Task-Based User Study

Ratings for Static Analysis View and Developer View



Participant ratings. (0: not recommended, 10: highly recommended)

Developer View: Task-Based User Study

Participants' thoughts about the tool



*"The tool gave me a **good understanding** about privacy-relevant data flows." - P09*

*"I like how all risks are categorized with source and **warning scale**." - P03*

*"I have experience with Java so I could **quickly understand** the Developer View." - P07*

"The Developer View captures the necessary flow without overwhelming the user with too much detail." - P07

*"This is a **good tool for developers** which was reasonably easy to use." - P01*

Developer View Study: Threats to Validity

1 Participant proxy

Since students are considered reasonable proxies in the literature^{1,2}, the user study used students. Their experience, familiarity with privacy assessments, and exposure to real-world Android practices may differ from professionals.

2 Controlled setting

The study ran in a controlled environment with 12 participants over 1 hour, rather than a real development setting, where developers would have more time on more advanced apps. Results may not reflect full real-world workflows.

3 Benchmark app choice

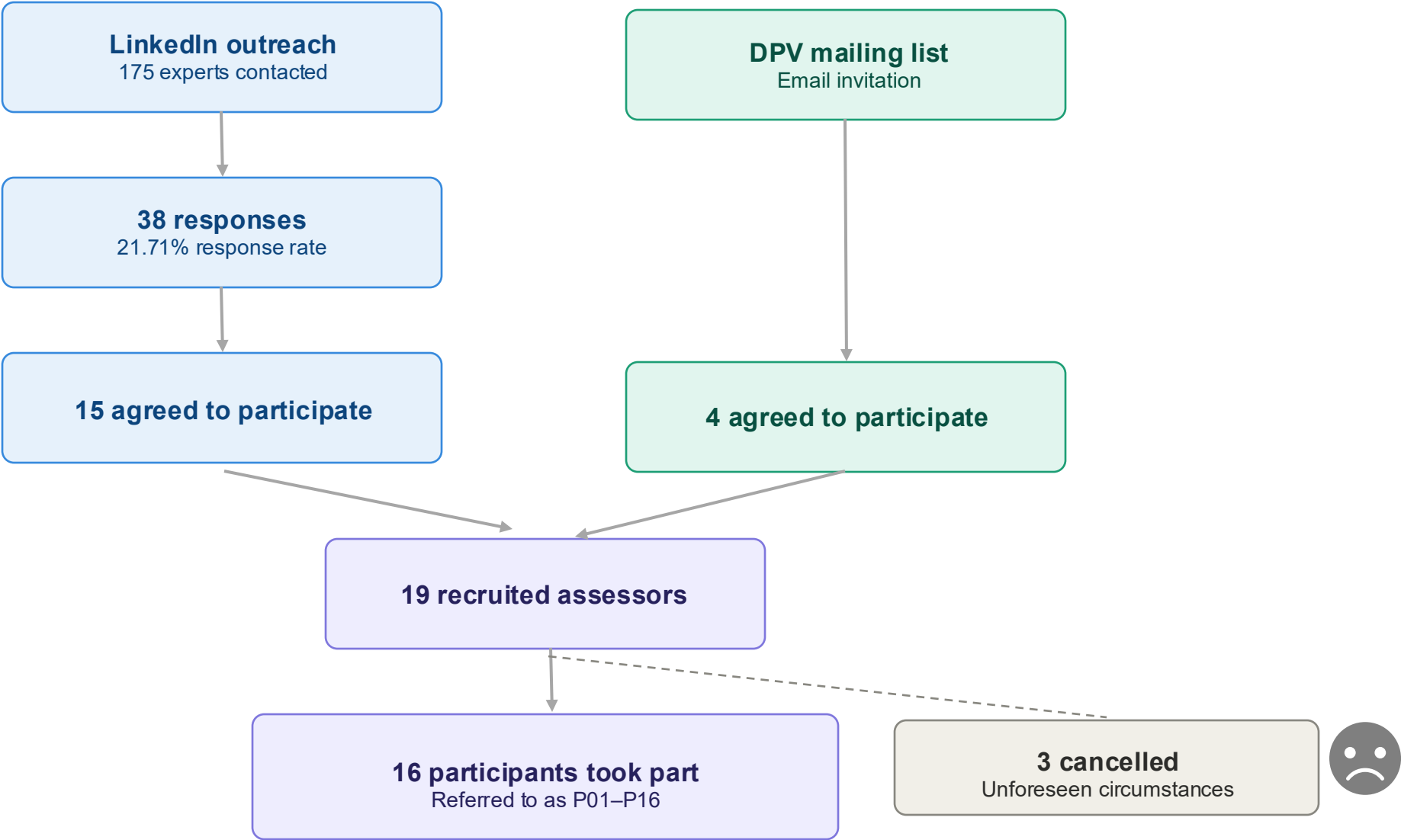
DroidBench and TaintBench apps were used because their source code and documented ground truth allowed comparing participant responses against known data flows. This limits external validity relative to real-world complexity.

4 Visualization scalability

Real-world slices can exceed 100 nodes, too large to interpret manually within a time-constrained study. Automatic visualization of large slices is an open challenge.

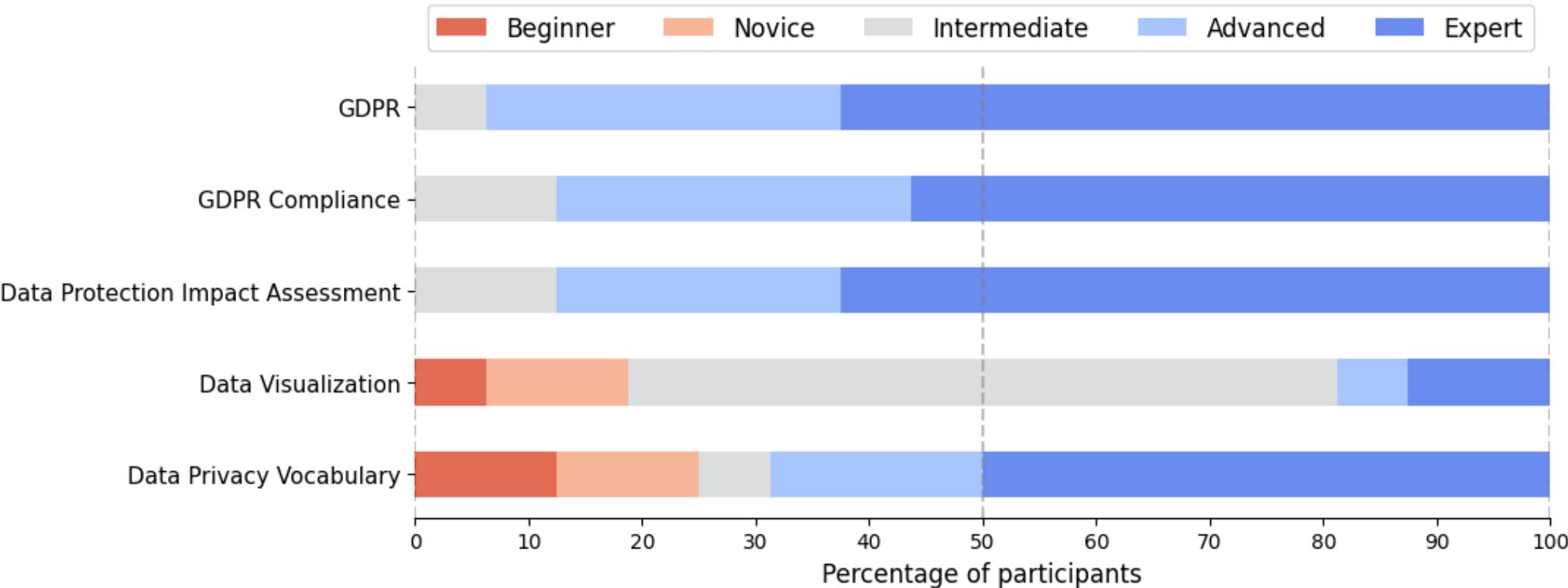
1. P. Berander. “Using students as subjects in requirements prioritization”. In: Proceedings. 2004 International Symposium on Empirical Software Engineering, 2004. ISESE '04. 2004, pp. 167–176. DOI : 10.1109/ISESE.2004.1334904
2. Mikael Svahnberg, Aybuke Aurum, and Claes Wohlin. “Using students as subjects - an empirical evaluation”. In: Proceedings of the Second ACM-IEEE International Symposium on Empirical Software Engineering and Measurement. ESEM '08, pp. 288–290. DOI: 10.1145/1414004.1414055

DPV View Study: Recruitment Process



DPV View: Semi-Structured Interview Study

Participant Familiarity





DPV View: Participant Expertise

Participant	Job title	Country	Experience (yrs)
P01	Legal Counsel	Germany	3.5
P02	Researcher	Germany	7
P03	Assistant Professor	Ireland	11
P04	Privacy Counsel	Germany	8
P05	External DPO	UK	15
P06	Manager	India	12
P07	Researcher	Germany	15
P08	DPO	Cyprus	7
P09	Corporate DPO	Germany	9
P10	Researcher	Greece	14
P11	Regulatory Compliance Analyst	Nigeria	3
P12	DPO	Saudi Arabia	5
P13	DPO	Germany	12
P14	Associate Professor	Spain	20
P15	Legal and Policy Researcher	The Netherlands	4
P16	Legal Researcher	Belgium	7



DPV View: Participant Expertise

- 7 participants (P01, P04, P05, P08, P09, P12, and P13) are DPOs.
- 6 participants (P01, P04, P05, P06, P08, and P09) have additional privacy certifications¹.
- 4 participants (P01, P04, P09, and P13) have German DPO certifications (Datenschutzbeauftragter durch TÜV).
- 3 participants (P02, P03, P14) are researchers from the DPV maintenance group² with a focus on privacy.
- P10 is a legal researcher from the DPV maintenance group.
- 6 participants have a PhD:
 - P03, P07, and P14 have a PhD in Computer Science.
 - P10 and P13 have a PhD in Law.
 - P06 has a PhD in Information Law.

1. <https://iapp.org>

2. <https://www.w3.org/community/dpvcg/>

Summary of Interview Protocol

Topic	Example questions
Privacy assessments/ DPIAs	Can you walk us through a privacy assessment process?
	Who are the stakeholders?
	Which parts of the assessment are manual?
	What is your role in the assessment process?
	How do privacy assessors navigate understanding source code to successfully complete such an assessment?
DPV	Is DPV or any other vocabulary actively used in the assessment process?
	Any plans of long-term support version of DPV?
GDPR Compliance	Have you used any tools to verify whether a software complies with GDPR?
	Which documents do data controllers need to complete to adhere to GDPR?
	Do your clients consult you to help complete these documents?
	Is this a manual process?
Privacy Training	Are there any training programs specific to GDPR that are mandatory for the stakeholders involved in a privacy assessment process?
	Do these training programs cover automation?

RQ1: GDPR Compliance

Documentation

- Record of Processing Activities (RoPA)
- Privacy notice
- Agreements
- Contract
- Assessment Report

Documentation Support

- Manual review
- Standard templates
- Document generators
- Decision tree-based legal tech tools

Compliance support

- Manual compliance
- Cookie compliance tools
- Privacy policy scanner
- Source code analysis for security

RQ1: More Challenges



1 Lack of awareness and information

*“Usually the challenge is that most people don’t know all the information needed for a DPIA, so **you have to hunt for people who have the information**, and figure out a way to convert their answers into what exactly you want in a DPIA.”*

— P03
(Assistant Professor, Computer Science)

2 Delays in considering privacy principles

*“Sometimes we are involved a bit from the outset. Other times we are really a bit of an afterthought. There is no point in lying: **most GDPR is an afterthought.**”*

— P15
(Legal and Policy Counsel)

3 Superficial Advice

*“Majority of recommendations of DPOs or privacy experts **stay superficially** on the principles of GDPR in Article §5 (data minimization, limitation of storage). At least I don’t know anyone that goes inside of it in the development, in trying to influence and recommend PETs.”*

— P01
(Data Protection Legal Counsel)

RQ1: More Challenges



4

Trade-off between privacy and innovation

*“Sometimes technical developers are **more inclined into going to innovation** and first testing and training a certain tool and then thinking about compliance while it is really important to have privacy by design and by default. So even before we know the whole potential of a certain software, it is important to already have these privacy solutions embedded. This **clash of interests** is always a challenge”*

— P16

(Legal Researcher)

DPV View: Semi-Structured Interview Study

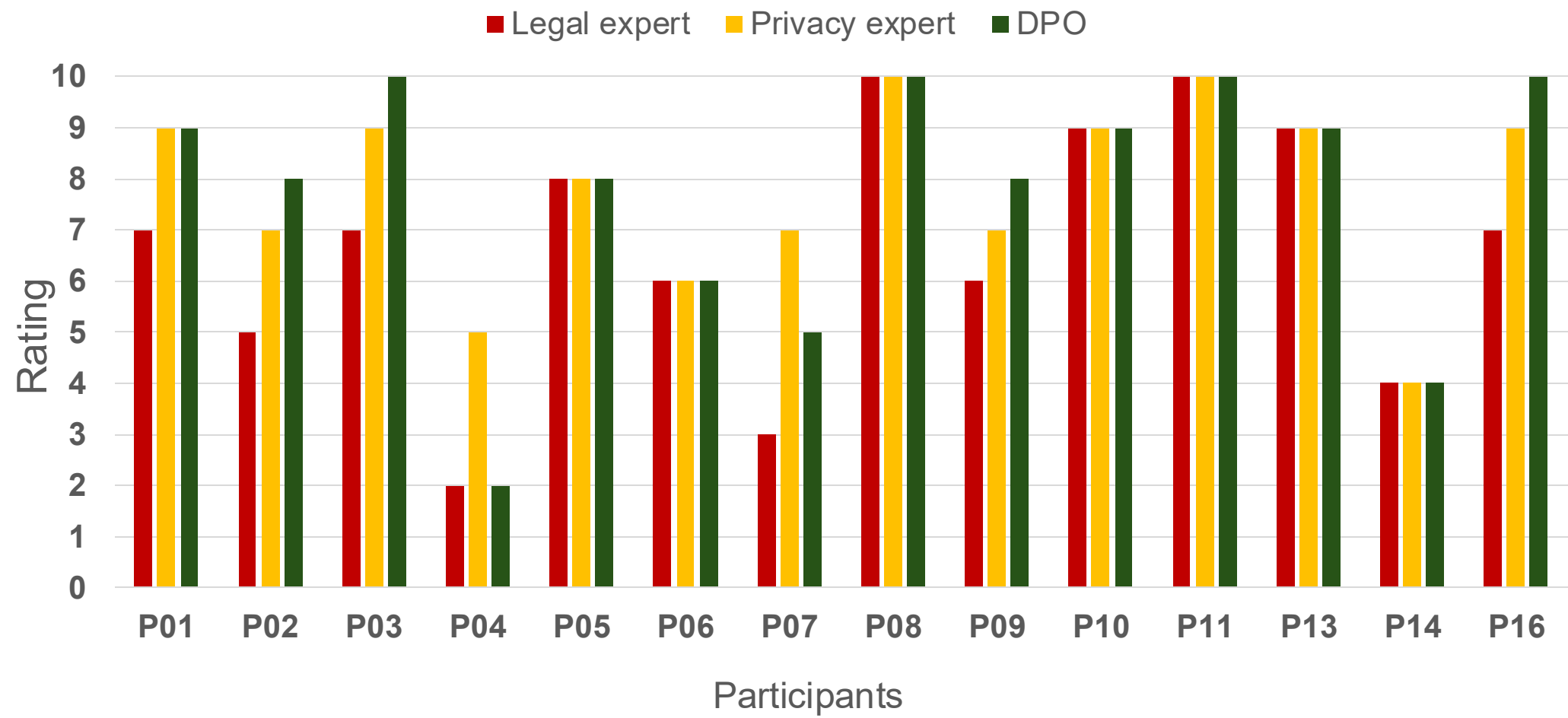
Usability Scores



Average usability score = 75.41

DPV View: Semi-Structured Interview Study

How likely is it you would recommend Assessor View to a privacy assessor?



Rating for legal experts, privacy experts, and DPOs. (0: not recommended, 10: highly recommended)

DPV View: Semi-Structured Interview Study

Assessor View's potential role in privacy assessments



*"It will help to get **answers from the technical team** and developers." - P01 (Data Protection Legal Counsel)*

*"I think this is a **good tool for DPOs**." - P02 (Computer Science Researcher)*

*"If you get this data in a **RoPA** (record of processing activities) template, DPOs would be very happy." - P03 (Computer Science Assistant Professor)*

*"Assessor View will help technical people talk more **legally**." - P04 (Data Protection Privacy Counsel)*

*"It would be great for **tech teams to self-assess their tools**, and use the output to defend their decisions in a DPIA." - P04 P04 (Data Protection Privacy Counsel)*

*"I think the tool is good. I think it could **form part of an assessment very well**, actually." - P05 (External DPO)*

Qualitative Evaluation

Interview-based user study (n = 16)



Organizational responsibilities		Addressed by the tool	
Privacy by default and design	Article 25	Partially (using warnings)	
Security of processing	Article 32	Partially (using encryption checks)	
Maintaining accurate documentation	Article 30	No support!	



DPV View Study: Threats to Validity

1 Participant sampling

Diverse privacy assessors were recruited through multiple outreach rounds, directly contacting 175 experts across 43 countries. The final sample spans 11 countries, including 4 outside the EU.

2 Underrepresentation risk

Experts with strong privacy concerns are typically less likely to participate in interview-based studies, and response rates were low among DPOs and DPVCG members, potentially limiting the breadth of viewpoints captured.

3 Benchmark app choice

TaintBench was used for its real-world apps with documented privacy-related data flows. Though more realistic than hand-crafted benchmarks, it remains a limited set; findings reflect TaintBench-based tasks rather than all real-world Android apps.

4 Coding reliability

Themes were derived via iterative open coding and thematic analysis; a second researcher independently reviewed the codebook, with disagreements resolved through discussion.

5 Quantitative measures

SUS and NPS scores were collected as complementary indicators, not statistically generalizable measures, given the qualitative design. While the sample size is reasonable for qualitative goals, a larger quantitative evaluation is future work.



Related Work

Assessment Automation

Automated GDPR Compliance

- Developers cite lack of automated support as a major obstacle to GDPR compliance¹.
- Ferrara et al.² discuss GDPR-report components & source-to-sink analysis, not DPIA-specific.
- Martin et al.³ recommend privacy-by-design tooling; Li et al.⁴ explore GDPR compliance in CI pipelines.

1. Franke et al.'24
2. Ferrara et al.'18
3. Martin et al.'18; Cavoukian '09 (privacy by design)
4. Li et al.'19

Privacy Vocabularies & Taint Analysis

- Pandit et al.⁵ introduce the Data Privacy Vocabulary (DPV) to standardize personal-data descriptions.
- Taint-analysis tools⁶ (FlowDroid-based) detect flows via predefined sources & sinks.

5. Pandit et al. '19; Pandit et al. '24 (DPV)
6. TS '23; Zhang et al. '23; Mao et al. '24 (FlowDroid-based)

Closest to Our Work

- Tang et al.⁷ present a source-to-sink graph analysis to support DPIAs, closest to our approach.
- We extend this with DPV-based representations for shared understanding among assessors.
- Our source-centric, slicing-based analysis needs no predefined sinks - broader coverage, more actionable GDPR assessment.

7. Tang & Øverby'22

Gap: No prior work supports multi-stakeholder DPIA collaboration without predefined sinks — addressed by **Assessor View's** source-centric, DPV-grounded analysis.

Contribution 4: Generate Reporting Documents

C1



Detect Android data
collection

C2



Diagnose reporting
inconsistencies

C3



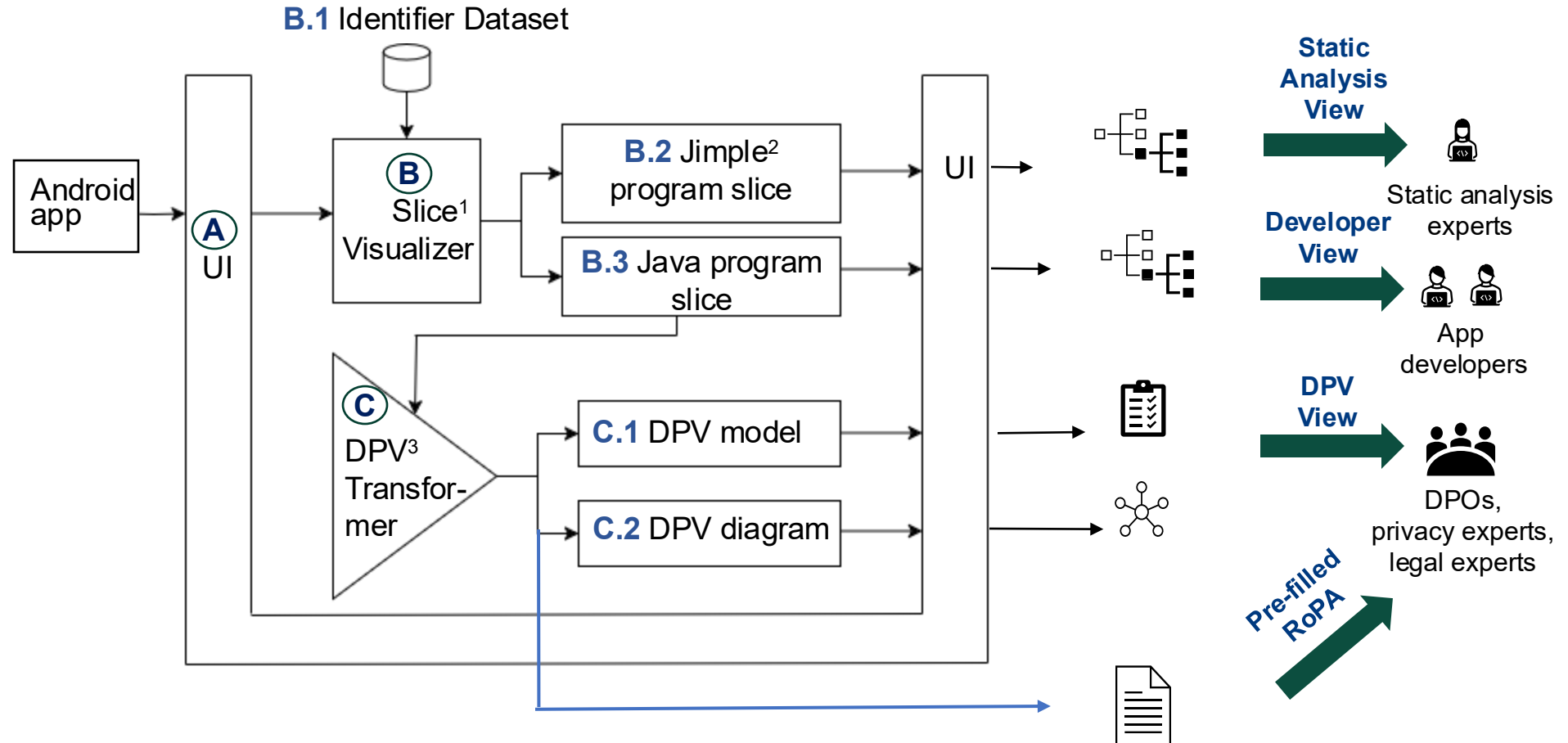
Automate privacy
assessments

C4



Generate reporting
documents

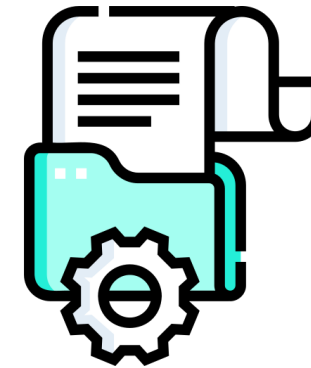
Assessor View: RoPA Extension



1. F. Pauck and H. Wehrheim, *Jicer: Simplifying Cooperative Android App Analysis Tasks*, 2021 IEEE 21st International Working Conference on Source Code Analysis and Manipulation (SCAM), Luxembourg, 2021, pp. 187-197, doi: 10.1109/SCAM52516.2021.00031
2. Raja Vallée-Rai, Phong Co, Etienne Gagnon, Laurie Hendren, Patrick Lam, and Vijay Sundaresan. 1999. *Soot - a Java bytecode optimization framework*. In Proceedings of the 1999 Conference of the Centre for Advanced Studies on Collaborative Research (Mississauga, Ontario, Canada) (CASCON '99). IBM Press, 13.
3. Data Privacy Vocabulary: <https://w3c.github.io/dpv/2.1/dpv/>

Record of Processing Activities (RoPA)

- A mandatory documentation for GDPR compliance¹.
- A foundation for conducting privacy assessments.
- RoPA must accurately identify:
 - The *actors* involved in the data processing,
 - The *categories* of data processed,
 - The *purpose* of the processing,
 - The *technical and organizational security measures* implemented.



1. <https://gdpr-info.eu/art-30-gdpr/>

RoPA

Table



Editable fields for DPOs



ROPA Table							
Personal Data	Process Activity	Description of Processing Activity	Thlrd Party Libraries	Purpose	GDPR Articles	Special Categories of Data?	DPO Remarks
Approximate location	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			
Phone number	Collect	To gather data from someone.	Not Found	Enter purpose for the processing activity here	§ 13 § 25	Is this a special category of Data?	Enter DPO remarks
	Copy	To produce an exact reproduction of the data.	Not Found	Enter purpose for the processing activity here			
	Combine	To join or merge data.	Not Found	Enter purpose for the processing activity here			

RoPA Form

Editable fields for DPOs



▼ **Personal Data Type: Approximate location** 50%

▼ **Processing Activities: Collect, Combine** 50%

☐ **Processing activity: Collect**
Description: To gather data from someone.
Purpose:
Third-Party Libraries: Not Found

☒ **Processing activity: Combine**
Description: To join or merge data.
Purpose: Find exact location
Third-Party Libraries: Not Found

GDPR Articles: [Article 13](#), [Article 25](#)
Special Category of Data:
Risks Identified: Risk 2
DPO Comment:

▼ **Personal Data Type: Phone number** 0%

► **Processing Activities: Collect, Copy, Combine**

Progress bar



Participant Experience

Filled circles indicate expertise from 1 (Beginner) to 5 (Expert)

ID	Job title	Country	Exp in privacy/ law (yrs)	Familiarity				
				Data Visualization	GDPR	GDPR Compliance	DPIA	DPV
P01	Corporate DPO	Germany	9	●●●●○	●●●●●	●●●●●	●●●●○	●●○○○
P02	DPO	Germany	12	●○○○○	●●●●●	●●●●●	●●●●●	●●●●○
P03	DPO	Cyprus	7	●●●●○	●●●●●	●●●●●	●●●●●	●●●●●
P04	Data Protection Advisor	Germany	3.5	●●●●○	●●●●●	●●●●○	●●●●○	●●●●●
P05	External DPO	UK	15	●●●●○	●●●●●	●●●●●	●●●●●	●●●●○
P06	Privacy Counsel	Germany	8	●●●●○	●●●●○	●●●●○	●●●●○	●○○○○

Summary of Interview Protocol

Topic	Example questions
State-of-the-art	How do you typically compile a RoPA in your current work?
	How often do you do this?
	Do you use any templates? Which ones?
Assessor View-generated RoPA	What were your first impressions when using the RoPA feature in Assessor View?
	Do you think a partially pre-filled RoPA generated from source code would reduce manual workload during DPIA or pre-DPIA screening phases? Why or why not?
	Do you think Assessor View-generated partial RoPA output would be a useful starting point for documenting processing activities in compliance with GDPR Article 30?
	Would it make the process easier for beginners or external DPOs?
Usability, Feedback, and Suggestions	Could you understand and interpret the RoPA output generated by the tool?
	Were there any parts of the output that you found unclear or ambiguous or that required additional validation?
	Which representation (table or form) have you used more often for completing the RoPA? Which would you prefer to communicate with developers?
	To what extent can a DPO rely on the RoPA output from Assessor View to meet legal obligations under Article 30?
	What changes or additions would make the RoPA feature more useful for you?
	What more would you like to see in Assessor View to better support RoPA generation?

Interview Study

Assessor View-generated RoPA



*"In theory, it should start at this level. In practice, this is not possible because this **granularity is missing**. This would be the first representation I've seen of a concept that actually does the proper theory on designing processing activities." - P01*

"Maybe it could provide a good understanding of how and where data has been used, as opposed to just having to trust whatever the developers tell you." - P03

*"Because you already have a lot of pre-information, we can make **better questions for the colleagues**." - P04*

*"The bigger plus to me would be that it **reduces the chance of something being missed**." - P05*

Interview Study

RoPA Formats



"Table provides a good view of what data you have in your codebase, and you can see everything at the same time." - P03

"Form feels a lot more similar to other methodologies that you can use to talk through points." - P01

"I think it's good to allow both options, because different people would work in different ways" - P05

RoPA Study: Threats to Validity

1 Slice granularity

Slices exceeding 100 nodes can make generated RoPA outputs overly granular and difficult for privacy experts to inspect efficiently, requiring further summarization techniques to scale.

2 Participant pool

Participants were drawn from the same outreach as the DPV View Study (175 experts across 43 countries, yielding 11 countries and 4 non-EU participants). From this pool, six Europe-based DPOs were invited for the RoPA follow-up.

3 Benchmark app choice

TaintBench apps were used again for their real-world, documented data flows, making them suitable for generating RoPA outputs and discussing results with DPOs. Findings reflect TaintBench-based tasks rather than the full real-world Android app ecosystem.

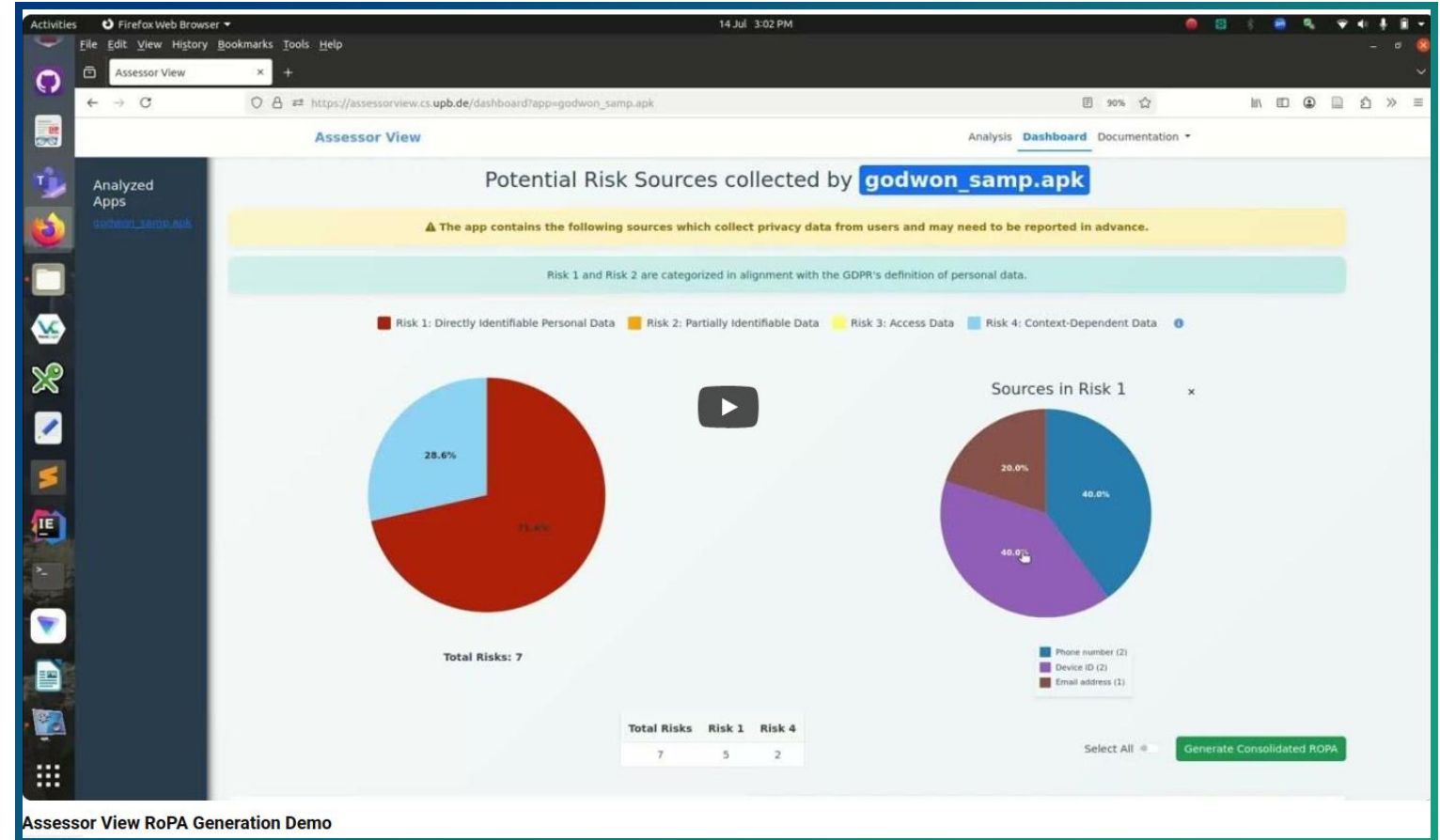
4 Sample size

The sample of six DPOs is appropriate for evaluating GDPR-oriented RoPA generation but remains limited and may not capture the full range of organizational practices across different contexts and compliance regimes.

5 Exploratory scope

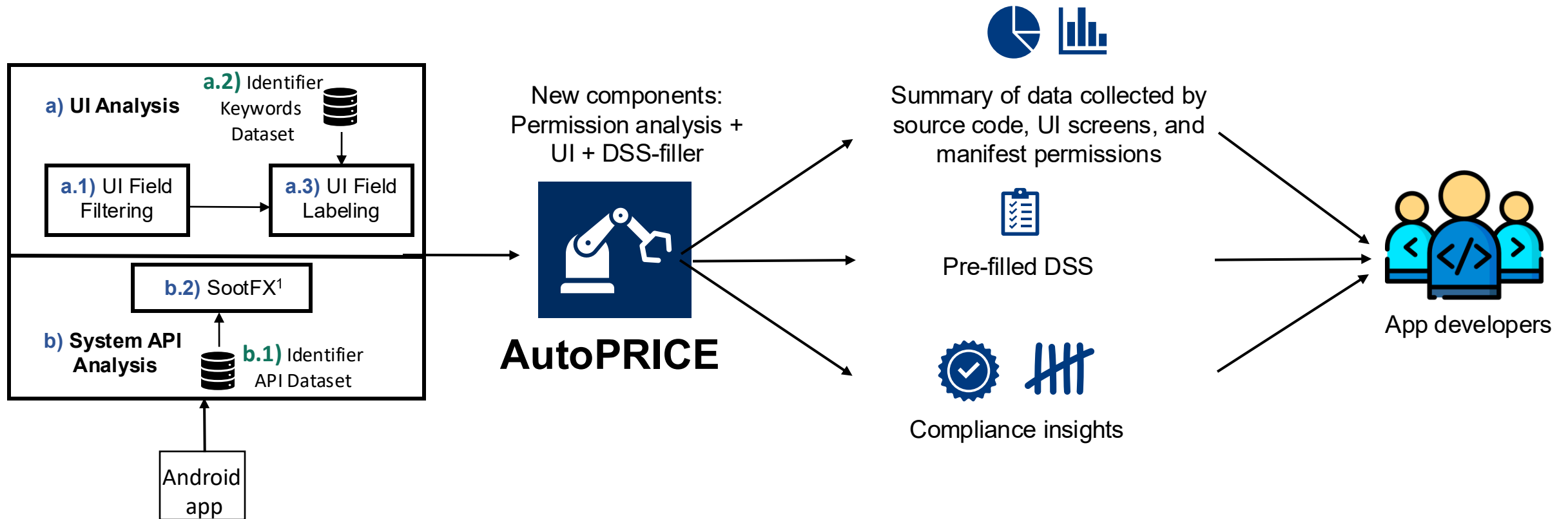
RoPA generation is positioned as an exploratory feature demonstrating how automated analysis can support privacy documentation, rather than a fully validated production capability.

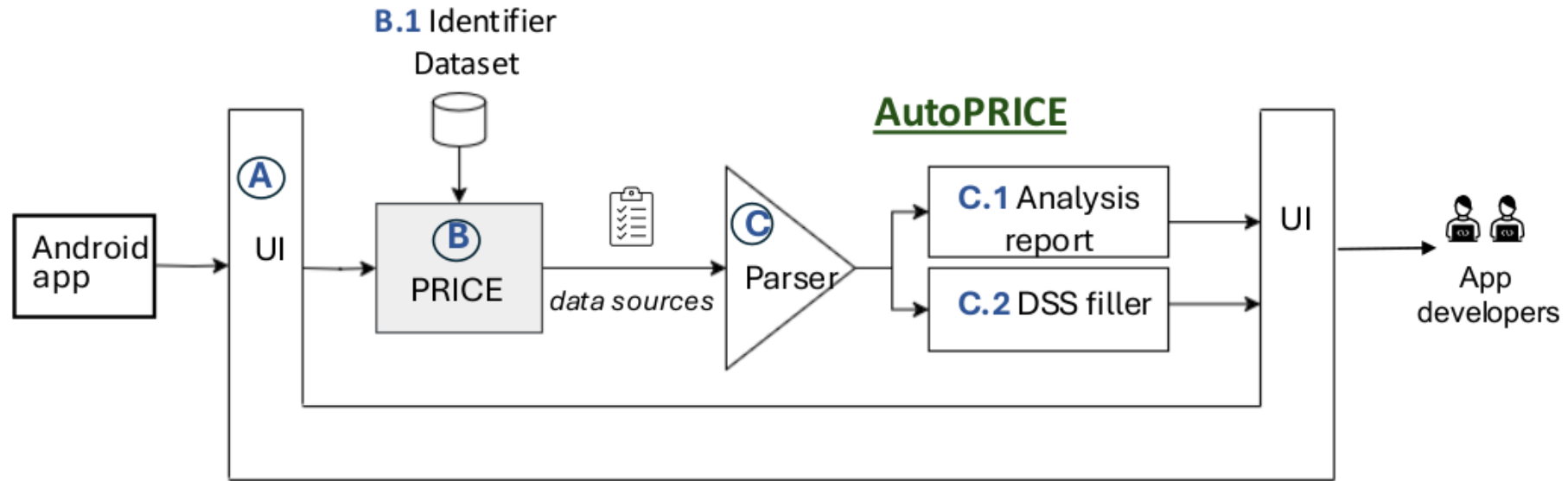
Watch the tool demonstration here:



AutoPRICE: PRICE Extension

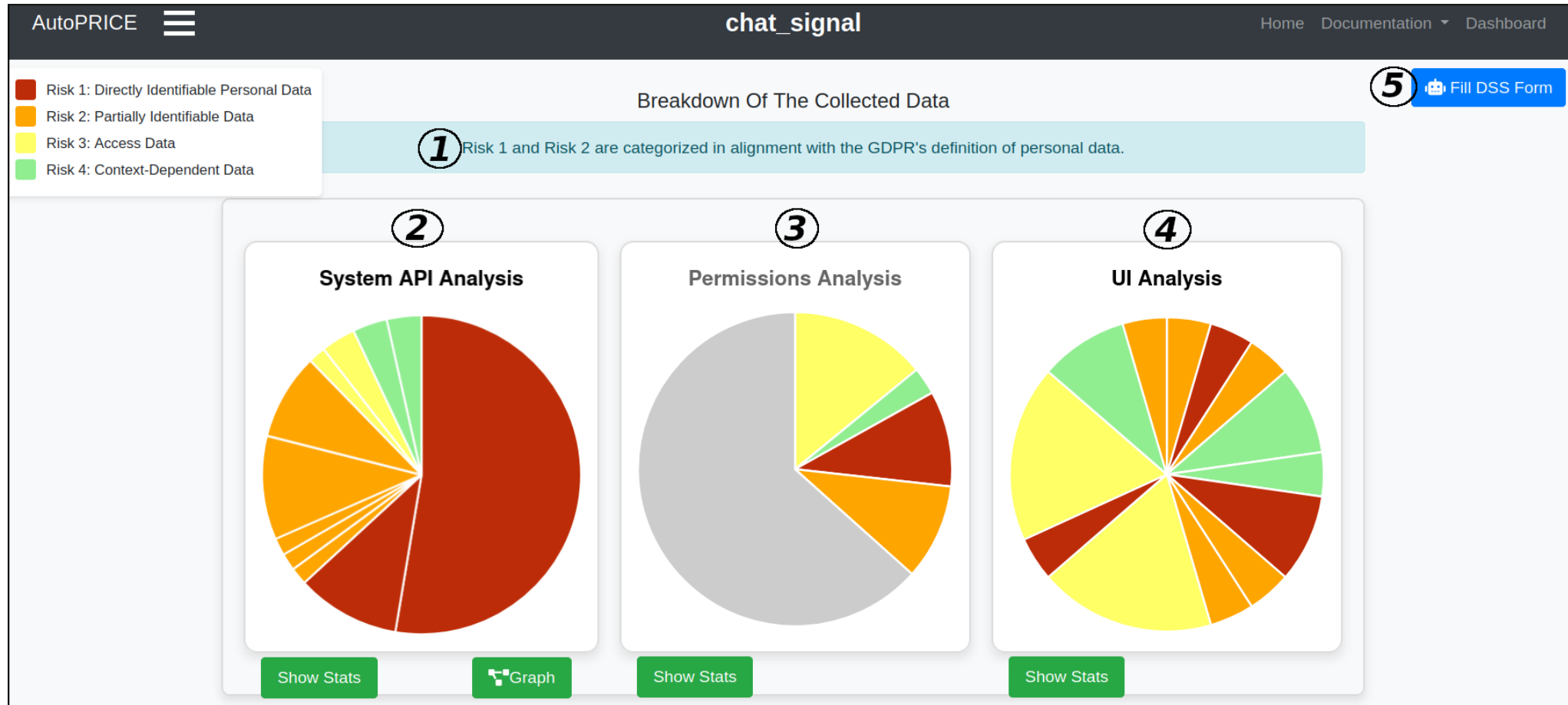
Automatic Privacy-Related Input Classification Engine





Module **B** is the existing component from Contribution 1

AutoPRICE: Dashboard



1 legends to identify data, **2** data collected via system APIs, **3** data collected via permissions, **4** data collected via appUI,

5 button to automatically populate the Data collected part of the DSS form.

AutoPRICE: Pre-filled DSS

Based on the AutoPRICE results, you can fill the Data Safety Section (DSS) form as shown below.

Legend

☐ Category ☐ Data Type

Device or other IDS

Device or other IDs [Show Details](#)

Personal info ①

Email address ② [Hide Details](#)

Collected from: methods, keywords ③

Details:

- Method: <com.google.android.gms.auth.api.signin.internal.Storage: com.google.android.gms.auth.api.signin.GoogleSignInAccount getSavedDefaultGoogleSignInAccount()>
- Method: <com.google.android.gms.auth.api.signin.GoogleSignInOptions: android.accounts.Account getAccount()>
- Method: <com.google.android.gms.auth.api.signin.GoogleSignInAccount: java.lang.String getEmail()>
- Keyword: cc

User IDs [Show Details](#)

Name [Show Details](#)

Other info [Show Details](#)

Phone number [Show Details](#)

Data category

Data category

Data type

Explanation on how the data type has been collected

Preliminary Evaluation

Methodology

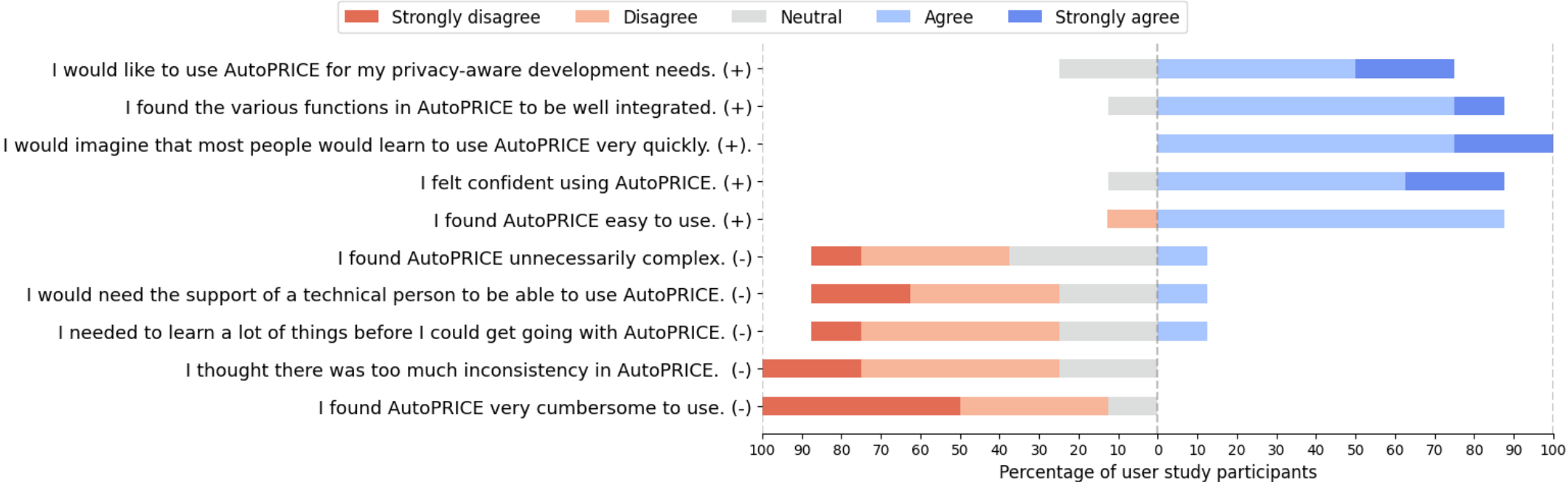
- User study with 8 Computer Science Master students.
- Participants were randomly given one of the following apps:



- Study tasks:
 - Analyze the app's data collection.
 - Use AutoPRICE to pre-fill DSS.
 - Compare generated DSS with the app's actual DSS on the Play Store.
- Research Question:

How can AutoPRICE support app developers in understanding and disclosing the data collected by their apps?

Usability Results



General Feedback



*"AutoPRICE's findings are more **in-depth** and visible on the **main** screen. The DSS on Google Play Store was somewhat difficult to find. I would prefer the **visual view** that AutoPRICE provides over textual content on Google Play Store." - P08*

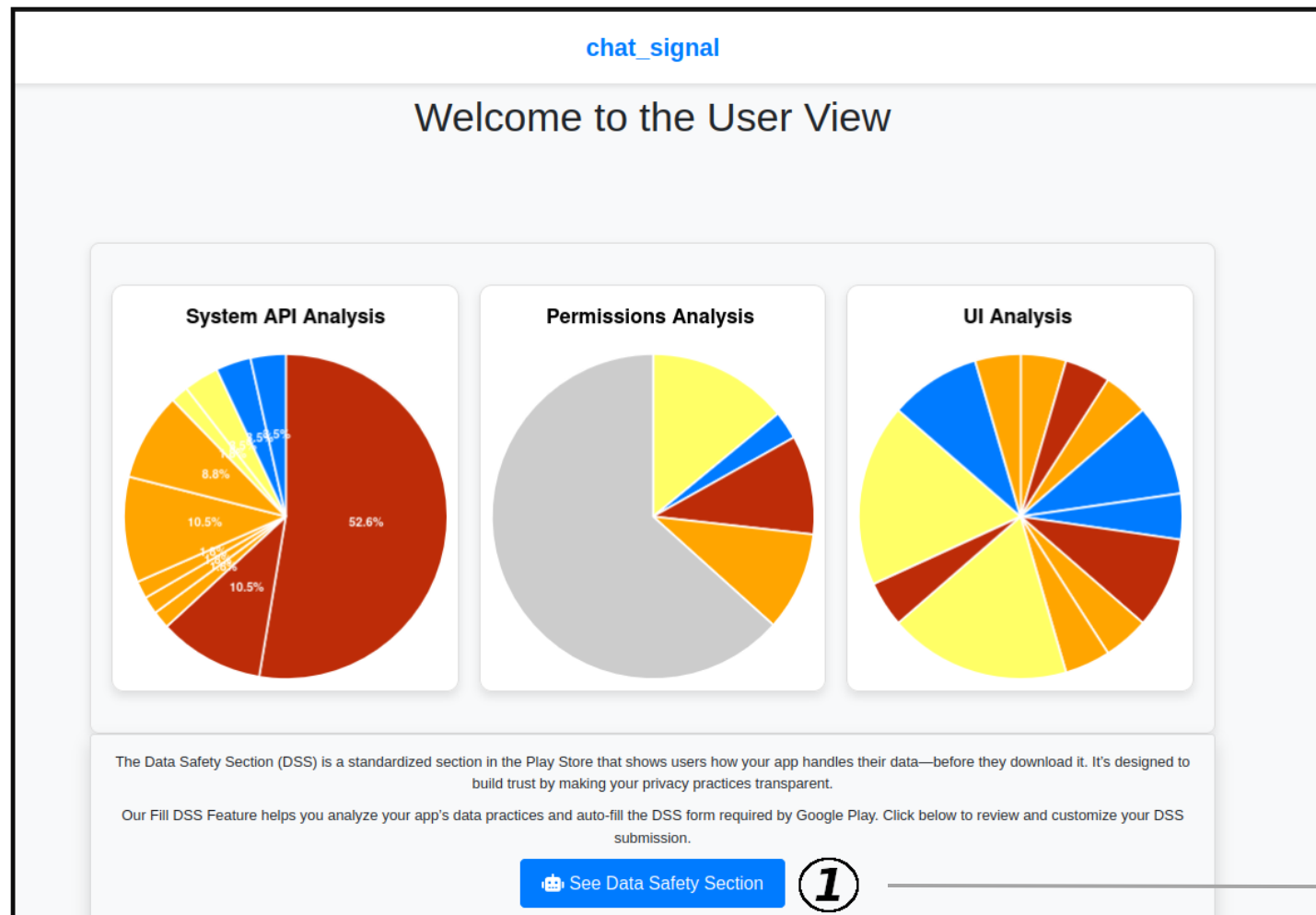
"Graph visualization, categories of collected data, and easy-to-navigate documentation are useful." - P02

*"**Android developers** integrating any open-source SDK could use AutoPRICE for permission analysis." - P03*

"AutoPRICE gives more transparency about the actual hidden data collected by apps." - P01

Feature Extensions

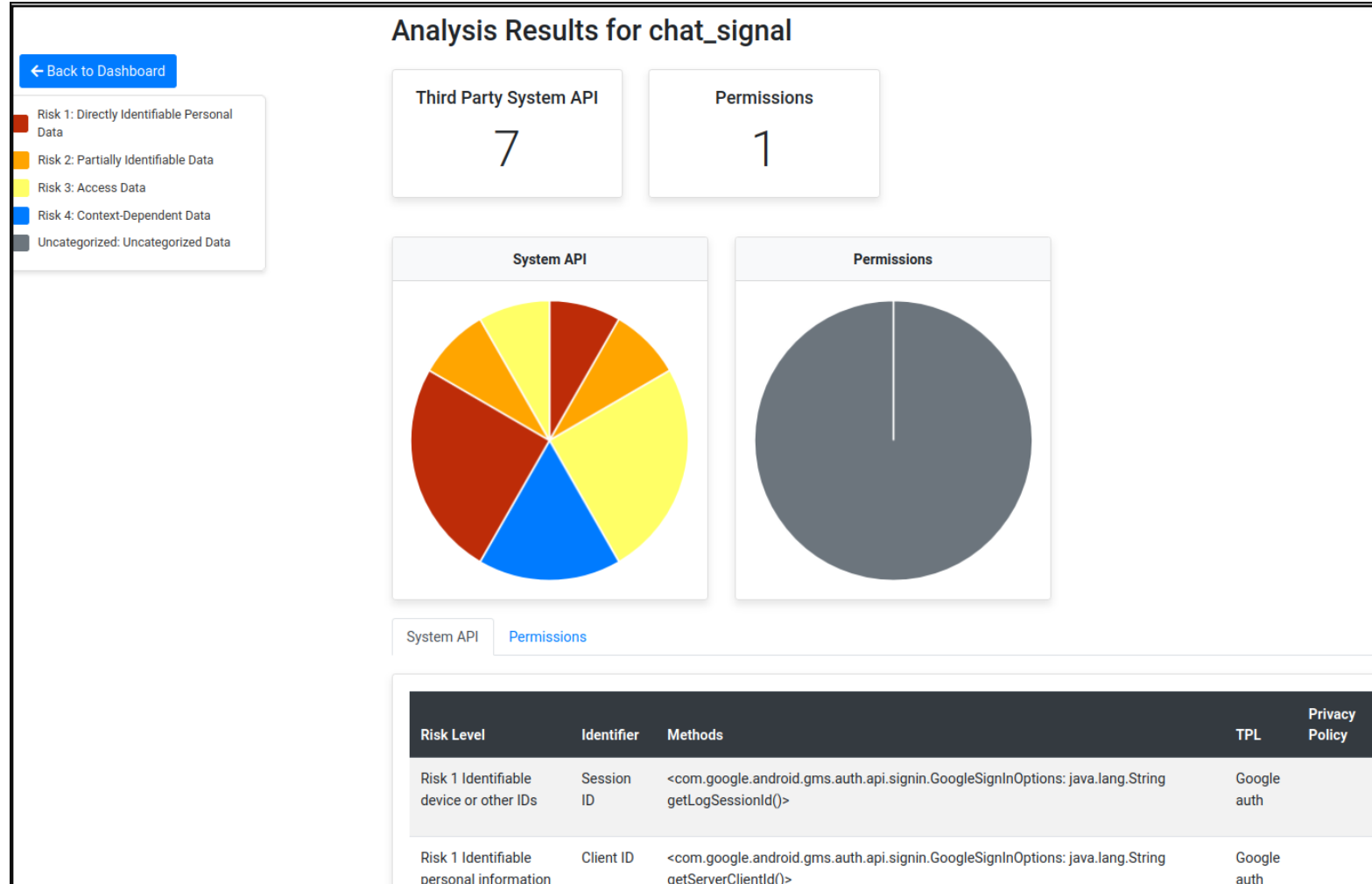
Dedicated view for users



Button to view the DSS

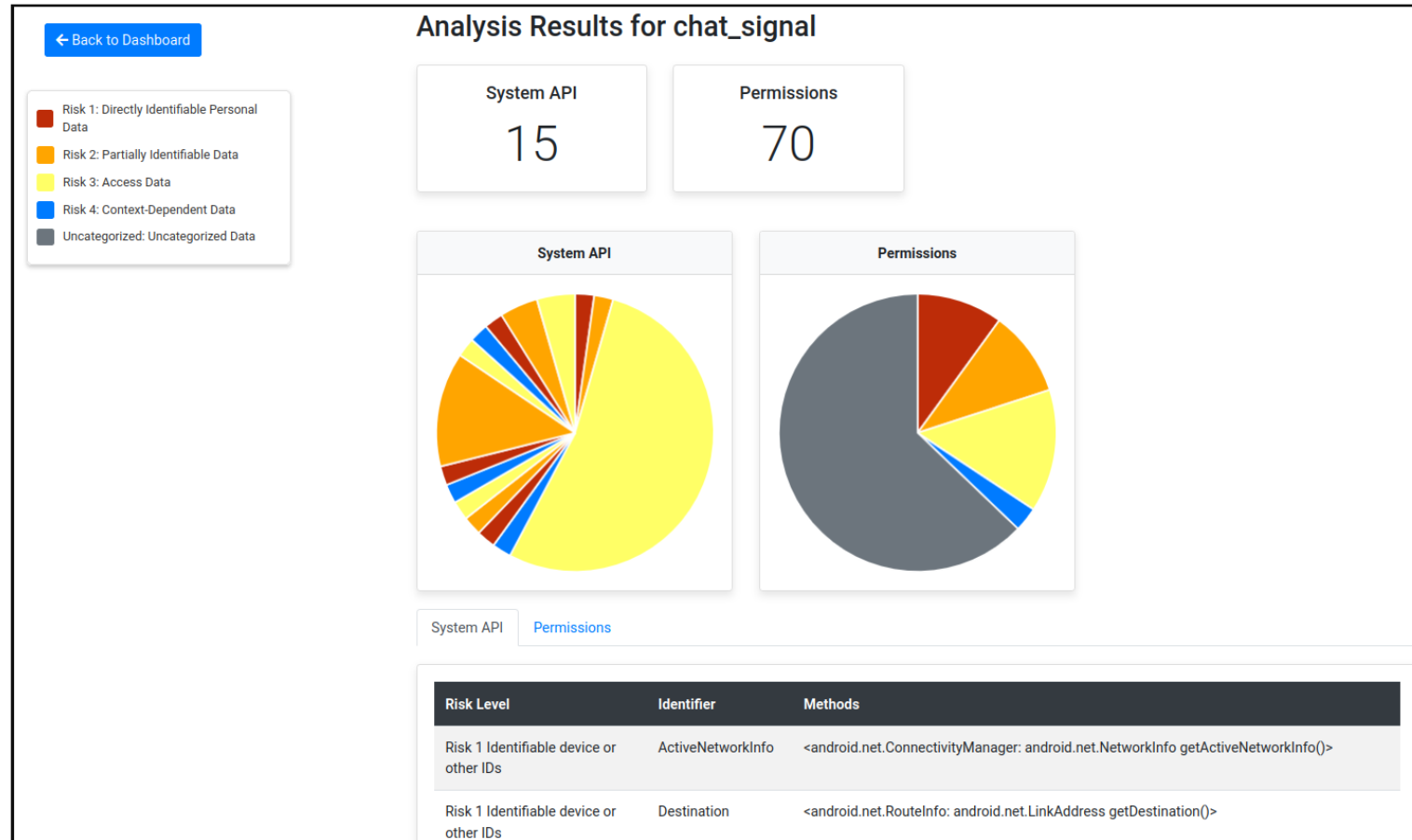
Feature Extensions

Data collected by third-party libraries



Feature Extensions

Data collected by in-app methods



Feature Extensions

Enhanced DSS filler component

Explanation of how the data type has been collected

1 Data Collected 2 Data Shared

This table shows data collected from the APK with permissions and purposes—download the full table or select rows and click Next to continue to the Data Shared View and include them in your report.

1 2 3 4

Data category

Data types

Editable purposes of data collection

Data Collected from APK						
Select	Category	Data Type	Methods	Permissions	Data Collected from UI	Purpose
☐	App activity	App interactions	<android.media.session.MediaController: android.media.MediaMetadata getMetadata()> <android.app.Activity: android.view.View findViewById(int)> <android.content.Intent: java.lang.String getAction()>			Select purpose(s) App functionality Analytics Developer communications Advertising or marketing Select purpose(s)
☐		Other actions		android.permission.download_without_notification android.permission.access_notification_policy android.permission.receive_boot_completed android.permission.vibrate android.permission.wake_lock android.permission.foreground_service android.permission.read_sync_settings android.permission.write_sync_settings android.permission.install_shortcut com.android.launcher.permission.install_shortcut android.permission.set_wallpaper android.permission.bluetooth android.permission.use_full_screen_intent		Select purpose(s)
☐		Other action		android.permission.request_install_packages		Select purpose(s)

Feature Extensions

Comparison with Play Store DSS

DSS generated
By AutoPRICE

A summary of
under-reporting,
over-reporting,
and other
observations

Fetch Data Safety Section

Data from AutoPrice Analysis

Data collected:

- App activity
- App info and performance
- Audio files
- Calendar
- Contacts
- Device or other IDs
- Files and docs
- Location
- Messages
- Personal info
- Photos and videos
- Web browsing

Data Safety Section from the playstore

Data collected:

- Personal info

Summary

Matching data categories: 1
Underreported data categories: 11
Overreported data categories: 0

Matching Data Categories:

- Personal info

Underreported:

- App activity
- App info and performance
- Audio files
- Calendar
- Contacts
- Device or other IDs

Manually
entered
URL of Play
Store DSS

DSS
extracted
from the
given link

Ongoing Collaborations

- Combining static and dynamic analysis for stronger guarantees:
 - Comparing network traffic observations¹ with our existing static analysis, and then comparing it with DSS.
 - Understanding benefits and limitations of both kinds of analyses to explore how they can be combined for holistic privacy analyses.

Partner institutes: Max Planck Institute for Security and Privacy, University of Innsbruck



- Studying the intersection of DSS and Apple Privacy Labels
 - Comparing reporting challenges between iOS and Android developers.
 - Examining how privacy manifest files affect self-disclosed reports², comparing DSS against Apple privacy labels.

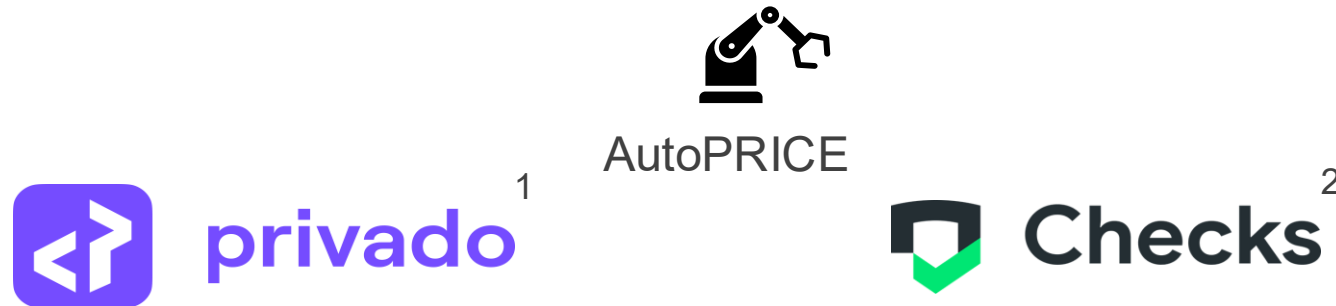
Partner institutes: George Washington University, EPFL

1. Koch, S., Altpeter, B., and Johns, M. The OK is Not Enough: Large Scale Study of Consent Dialogs in Smartphone Applications. In *USENIX Security Symposium*. USENIX Association, Anaheim, USA, 2023.
2. "Because I didn't touch these and even don't know why I should to change these": Why App Developers Do (Not) Update Apple's Privacy Labels. Arwa Alsahdi, Jialiang Yan, Monica Kodwani, Matthias Fassl, Chris Kanich, Adam J. Aviv, PETS 2026

Future Work

Reporting tools

- Updating AutoPRICE to add more features, reveal information about *why* each data item needs to be disclosed.
- Conducting a usability evaluation of the existing tools developers may use for reporting.



- Conducting semi-structured interviews with Android developers to understand deeper issues with the reporting process.

1. Introducing Checks: simplifying privacy for app developers - Google: The Keyword. <https://blog.google/technology/area-120/checks/>

2. Privado.ai: <https://www.privado.ai/data-safety-report>

Future Work

Scalability and LLMs

- Conducting larger empirical studies and extending AutoPRICE and Assessor View to support scalable analysis pipelines.
- Improving precision and reliability of privacy analyses.
- Designing privacy analyses for systems integrating LLMs.
- Generating privacy-aware code with LLMs.